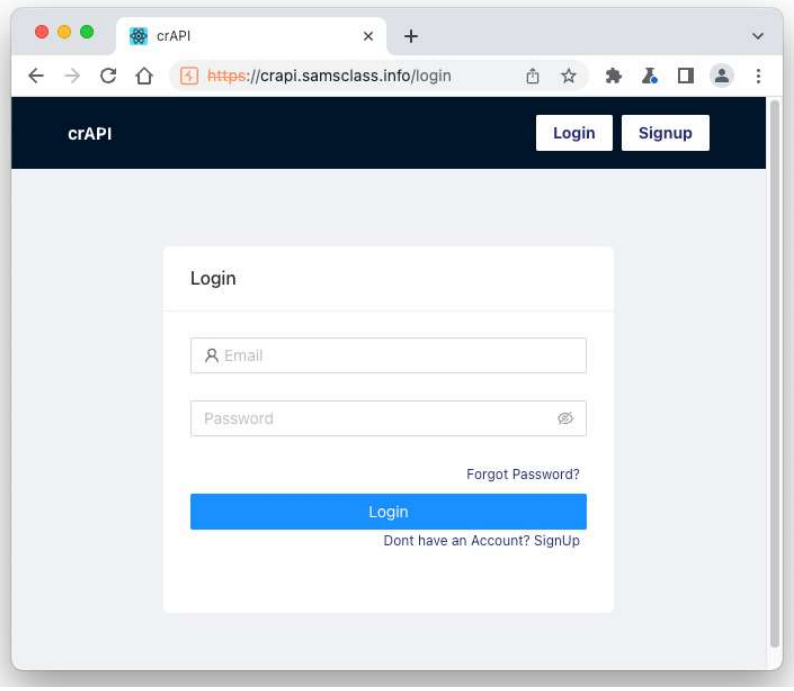
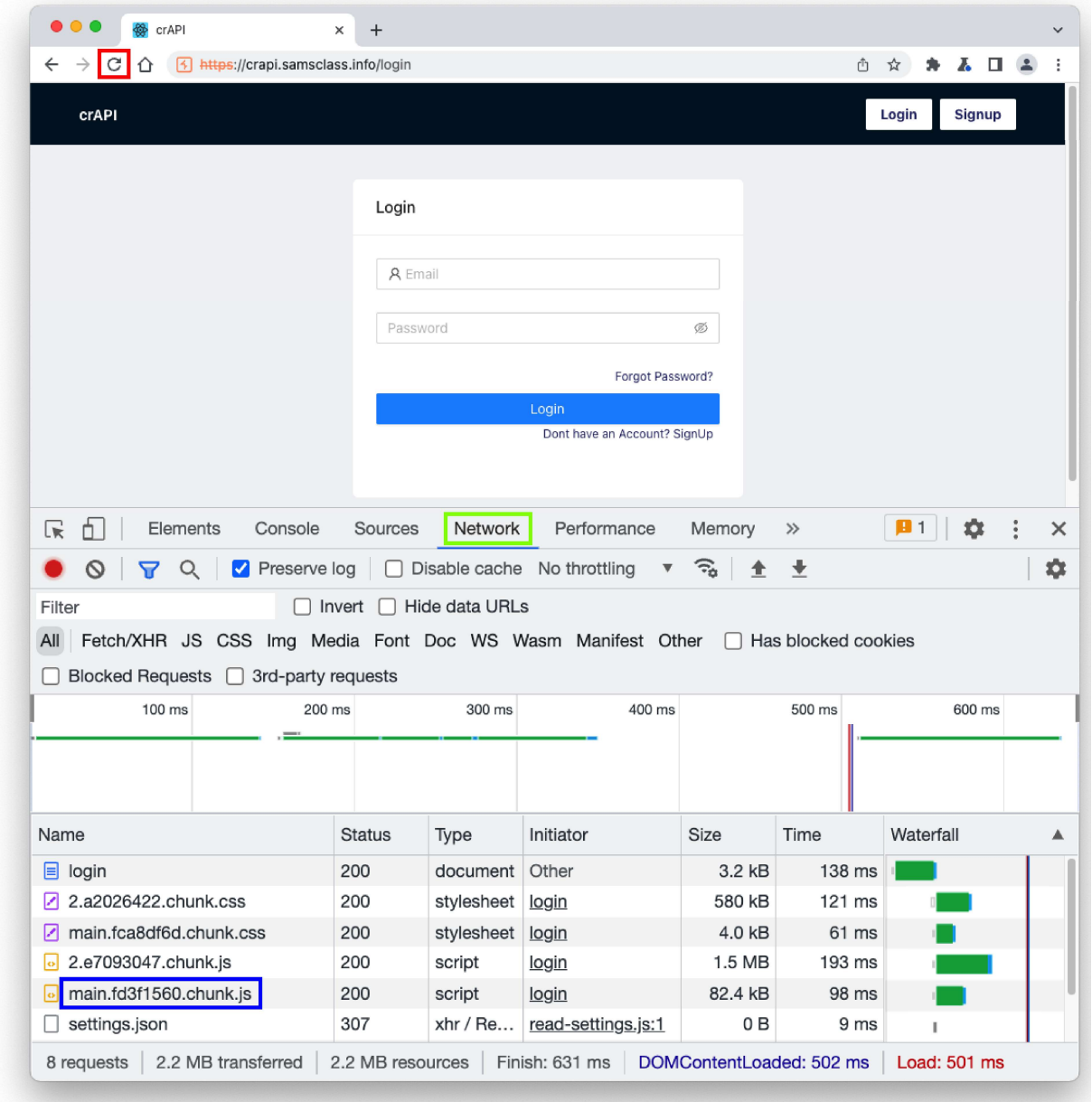
BÀI 1: API ENDPOINTS, POSTMAN VỚI BURP

1.1 TÌM KIẾM CÁC ENDPOINT API

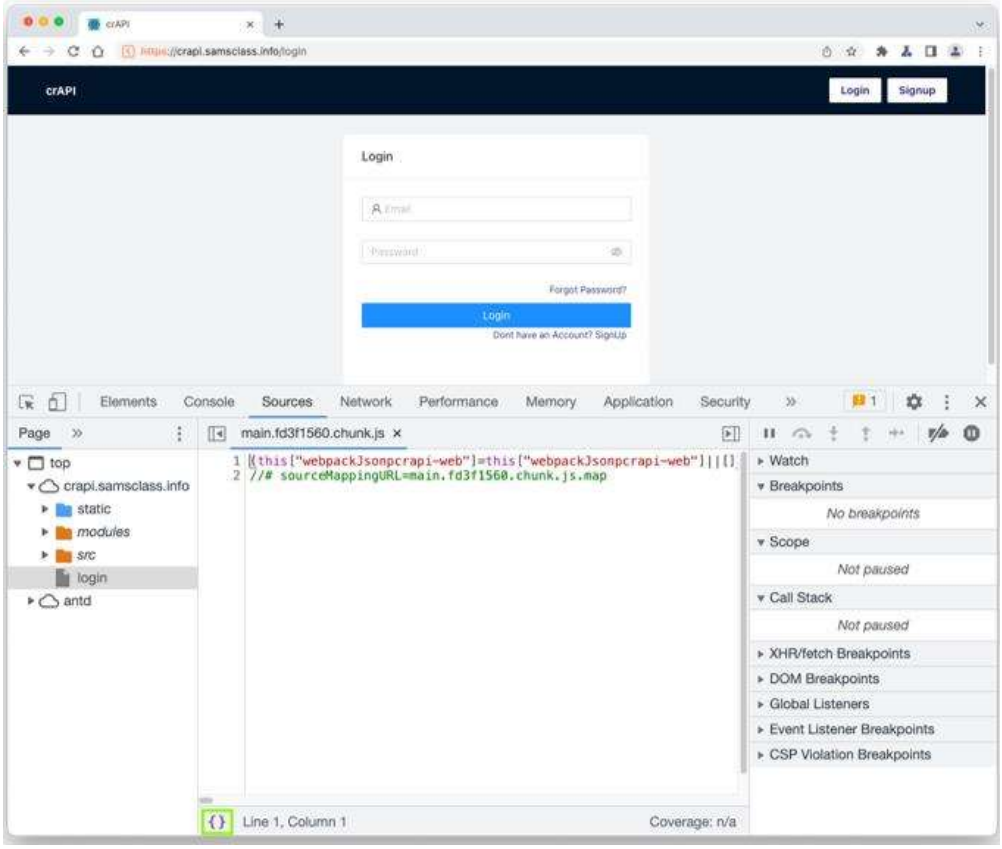
- **Phần mềm:** Burp Suite (https://portswigger.net/burp/communitydownload)
- **Mục tiêu:** Tìm các endpoint API trên máy chủ huấn luyện OWASP crAPI.
- **Kết nối đến crAPI:**
  - Mở Burp Suite. Chọn tab **Proxy**, sau đó chọn tab **Intercept**.
  - Nhấn nút "Intercept is on" để chuyển sang "Intercept is off".
  - Nhấn nút "Open Browser".
  - Trong trình duyệt của Burp, truy cập: https://crAPI.samsclass.info
  - Trang đăng nhập crAPI sẽ xuất hiện.



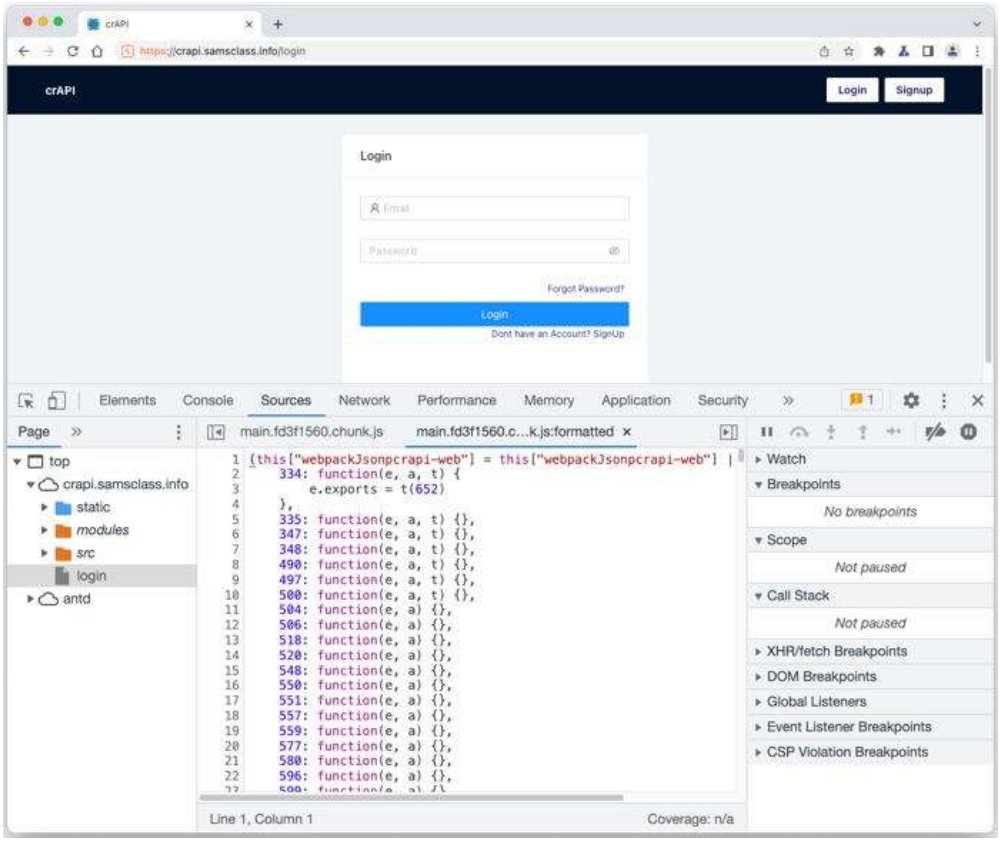
- **Sử dụng Developer Toolsđể khám phá tệp nguồn:**
  - Trong trình duyệt của Burp, từ thanh menu, chọn **View > Developer > Developer Tools**.
  - Chọn tab **Network**. Nhấn biểu tượng Refresh ở góc trên bên trái.
  - Nhiều tên tệp nguồn sẽ xuất hiện. Nhấp chuột phải vào `main.fd3f1560.chunk.js` và chọn "Open in Sources Panel".



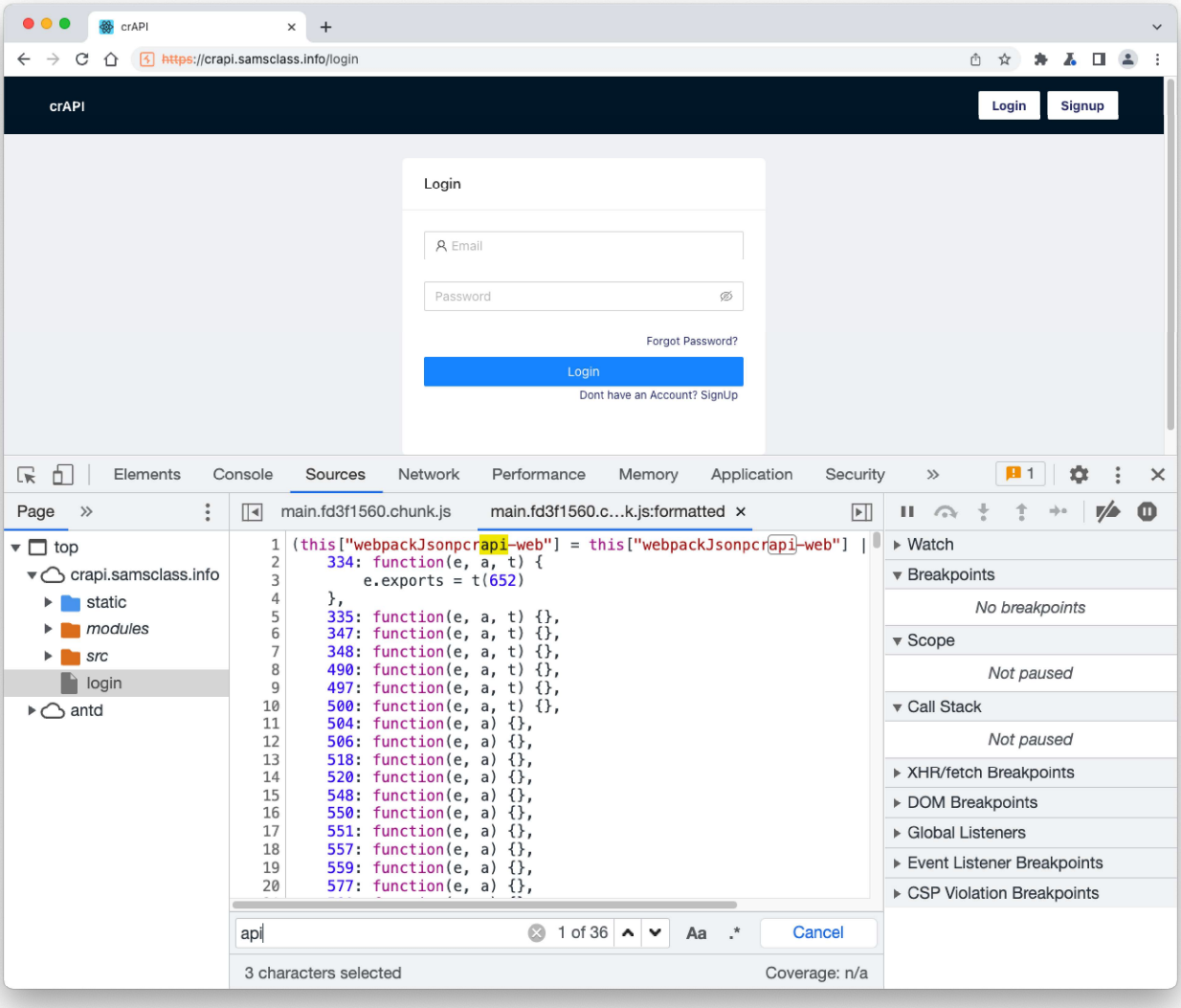
  - Tab **Sources** sẽ hiển thị, với một dòng dài chứa mã JavaScript.
  - Ở góc dưới bên trái, nhấn nút **{}** để "pretty-print" mã, giúp dễ đọc hơn.



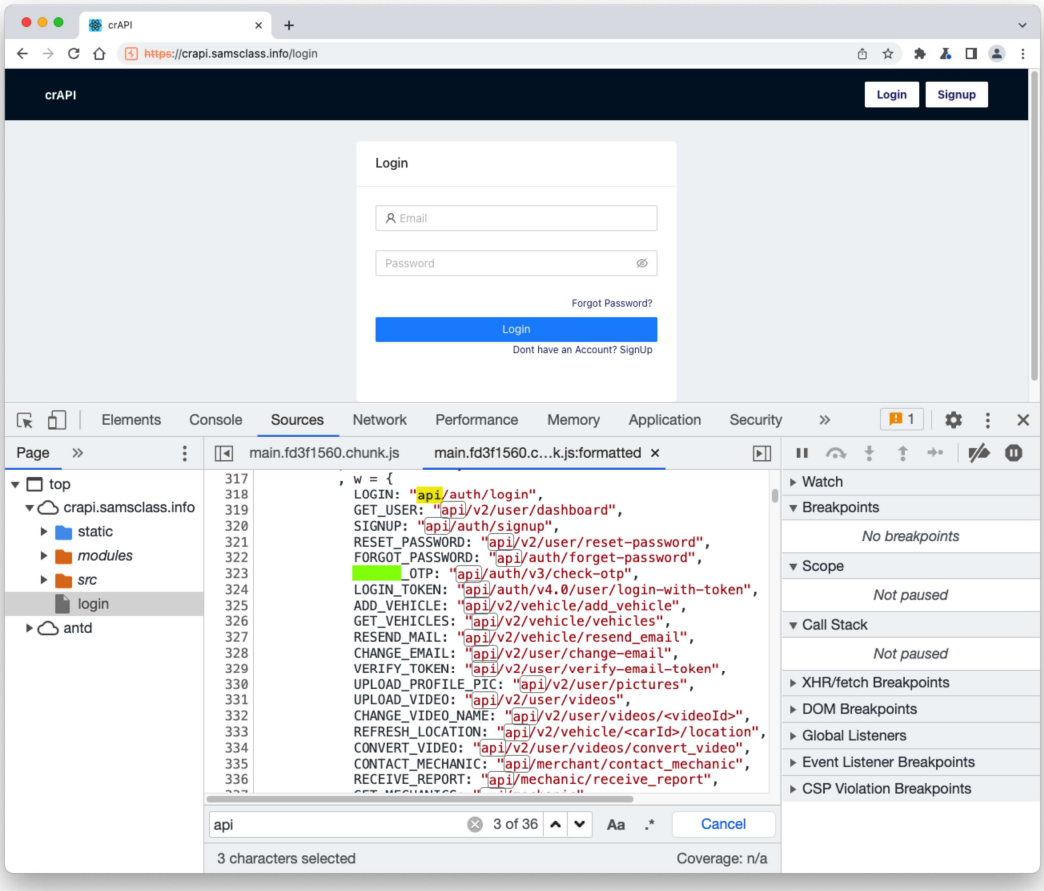
- Màn hình trở nên dễ đọc hơn nhiều như hình minh họa bên dưới.



- Nhấp vào khung trung tâm dưới cùng, nơi chứa mã JavaScript.
- Trên bàn phím, nhấn Ctrl+F. Một hộp tìm kiếm xuất hiện ở dưới cùng. Nhập từ khóa: `api`



- **Cờ AP 100.1 - Từ khóa:**
  - Nhấn Enter hai lần.
  - Cuộn xuống để xem danh sách các endpoint API.
  - Cờ là từ được bao quanh bởi hình chữ nhật màu xanh lá cây trong hình ảnh minh họa.



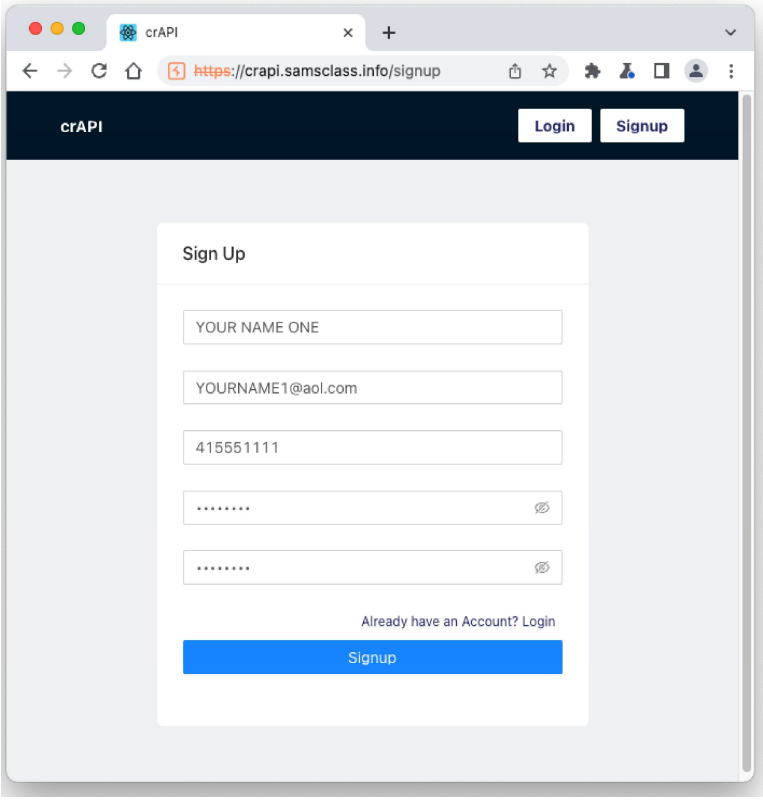
- **Cờ AP 100.2 - Endpoint API bên ngoài:**
  - Tìm kiếm trong tất cả các tệp JavaScript được sử dụng trên trang này.
  - Tìm URL khớp với hình ảnh minh họa.
  - Cờ là từ được bao quanh bởi hình chữ nhật màu xanh lá cây trong hình ảnh.

> See https://redux.js.org/api-reference/store#

1.2 SỬ DỤNG POSTMAN VỚI BURP

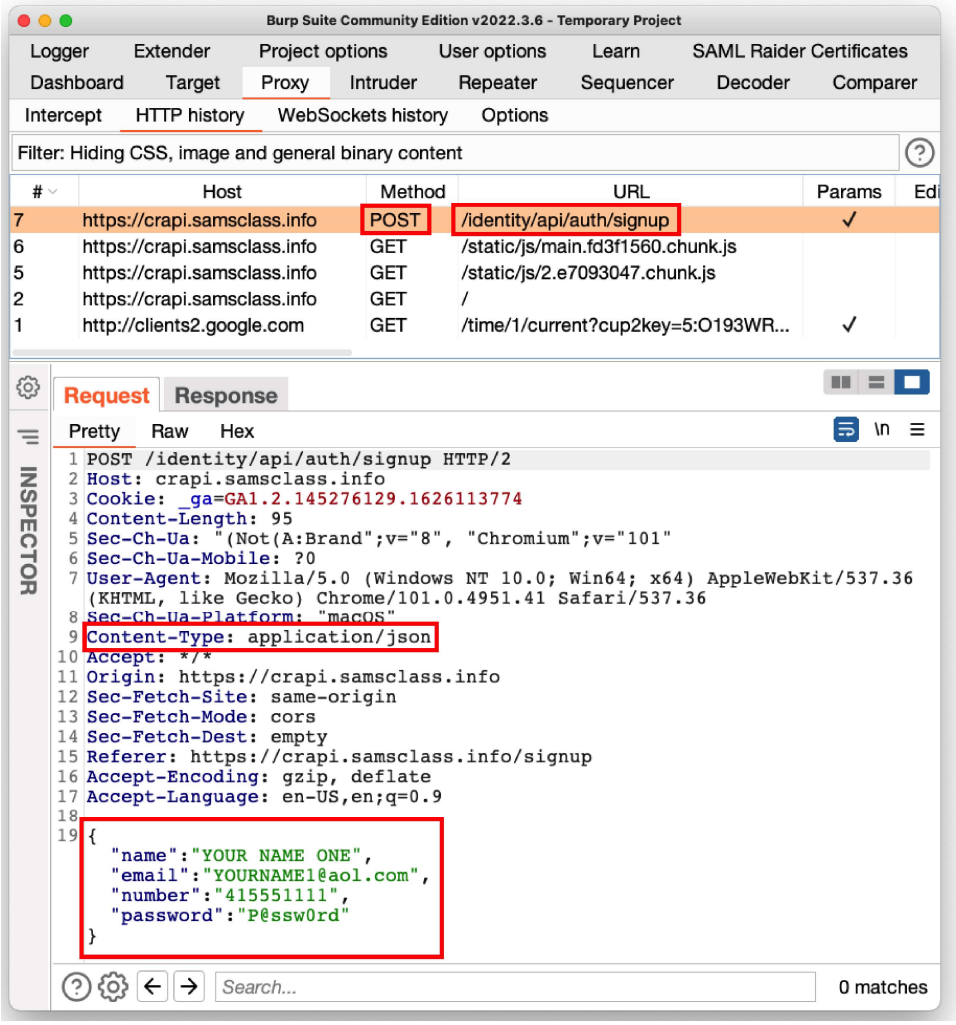
- **Phần mềm:** Burp Suite.
- **Mục tiêu:** Tìm dữ liệu nhạy cảm bị lộ qua các yêu cầu API tới máy chủ đào tạo crAPI của OWASP sử dụng Postman cùng với Burp.
- **Kết nối đến crAPI:** Tương tự các bài tập trước.

- **Đăng ký tài khoản:**
  - Trong trình duyệt Burp, trên trang đăng nhập crAPI, hãy nhấp vào liên kết SignUp.Điền vào biểu mẫu với dữ liệu thử nghiệm. Sau đó nhấp nút Signup.

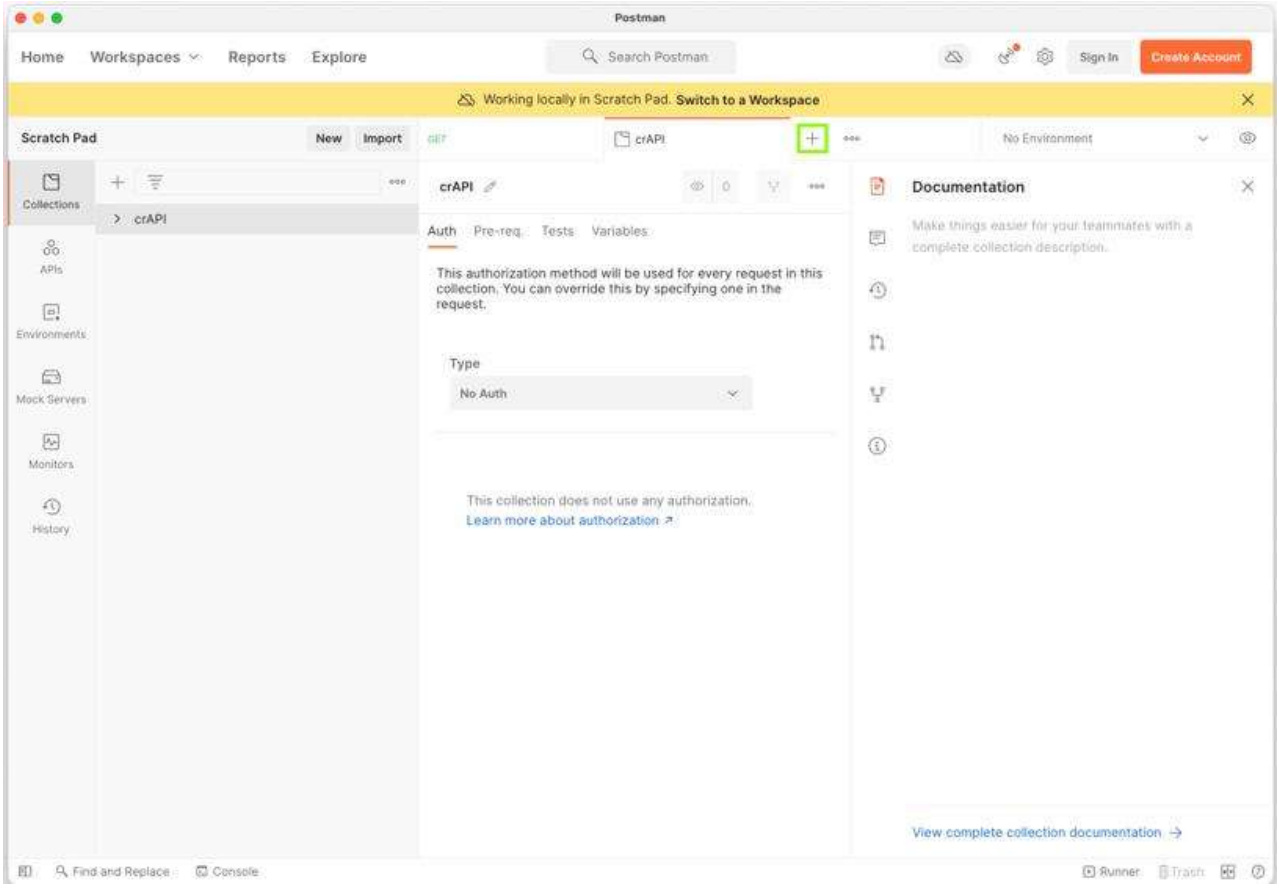


  - Bạn sẽ thấy thông báo "Người dùng đã đăng ký thành công!".

- **Xem Signup Request:**
  - Trong Burp, trên tab Proxy, trên tab phụ "HTTP history", hãy nhấp vào dòng "`POST /identity/api/auth/signup`".
  - Trong ngăn bên dưới, trên tab Request, bạn có thể thấy yêu cầu được sử dụng để đăng ký.
  - Lưu ý các tính năng sau:
    - Đây là yêu cầu `POST`.
    - URL: `/identity/api/auth/signup`
    - Content-Type: `application/json`
  - Dữ liệu bạn nhập vào biểu mẫu sẽ xuất hiện dưới dạng đối tượng JSON ở cuối.



- **Cài Postman:** Postman là công cụ chính được sử dụng để làm việc với API. Tải xuống và cài đặt từ trang web này https://www.postman.com/downloads/
- **Khởi động Postman:**
  - Khởi chạy Postman. Nếu được yêu cầu thiết lập tài khoản, hãy nhấp vào "Skip signing up and take me straight to the app".
  - Từ trang Postman chính, ở giữa trên cùng, hãy nhấp vào dấu +, được viền màu xanh lá cây trong hình ảnh bên dưới, để mở một tab mới.

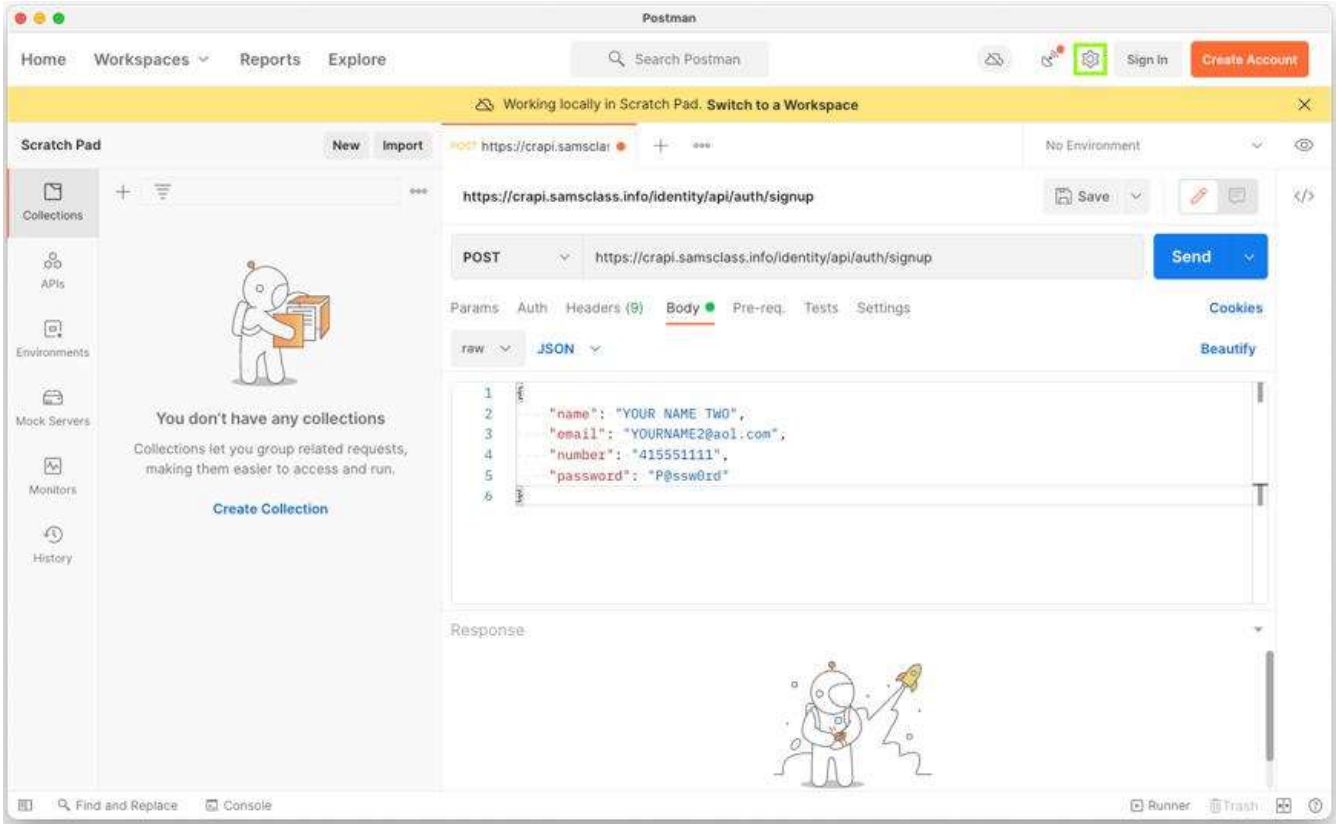


- **Xây dựng Request:**
  - Một tab có tiêu đề "Untitled Request" sẽ mở ra, như được hiển thị bên dưới.
  - Tại đây, bạn có thể xây dựng một yêu cầu HTTP.
  - Thực hiện các lựa chọn sau để khớp với yêu cầu bạn thấy trong Burp:
  - Thay đổi phương thức từ GET thành POST.
  - Nhập URL: https://crapi.samsclass.info/identity/api/auth/signup
  - Bên dưới dòng POST, hãy nhấp vào tab Body. Thực hiện các lựa chọn sau:
    - Thay đổi loại từ "none" thành raw.
    - Thay đổi loại phụ từ "Text" thành JSON.
    - Dán dữ liệu này, thay đổi tên người dùng, email và số điện thoại thành thông tin chưa từng được sử dụng trước đây:

```
  {"name": "YOUR NAME TWO", "email": "YOURNAME2@aol.com", "number":
"415551112", "password": "P@ssw0rd"}.
```

- Ở bên phải, hãy nhấp vào Beautify.

- Yêu cầu của bạn sẽ trông giống như hình ảnh bên dưới, nhưng với tên người dùng khác:

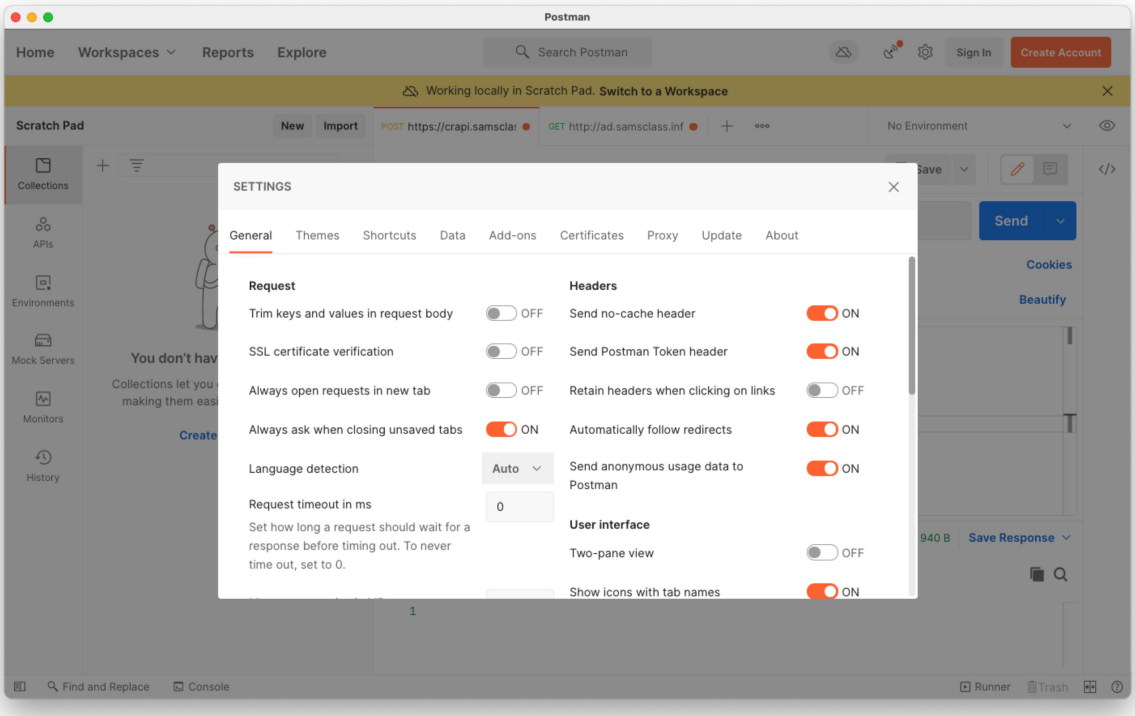


- **Sử dụng Burp Proxy trong Postman:**

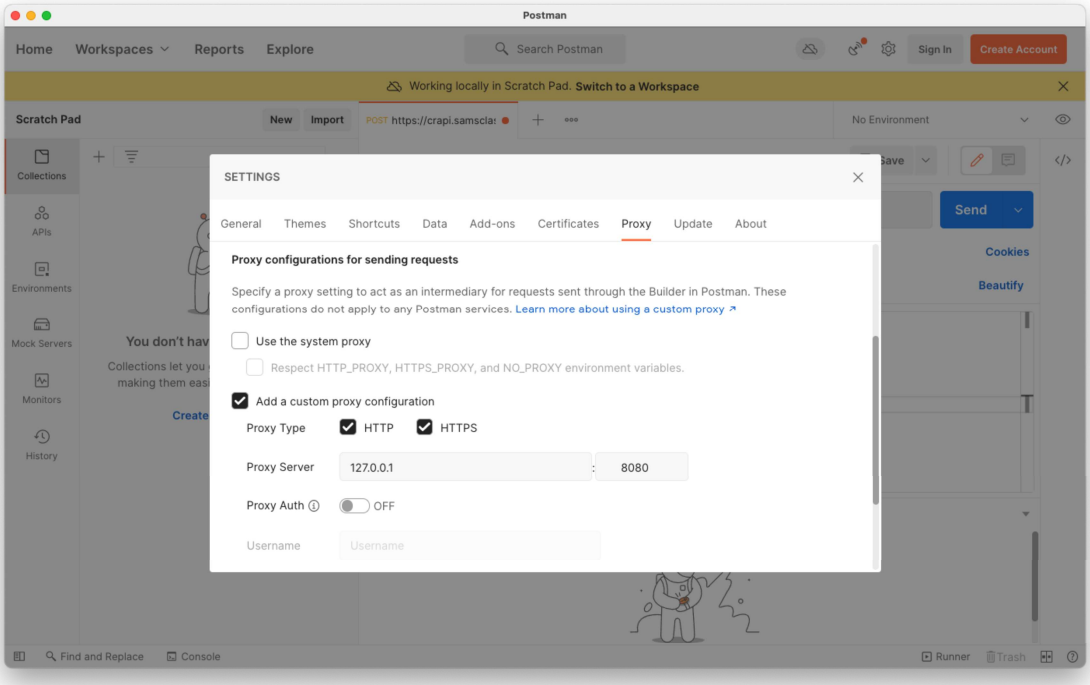
  - Trong Postman, ở góc trên bên phải, nhấp vào biểu tượng bánh răng, được viền màu xanh lá cây trong hình ảnh ở trên.

  - Nhấp vào Settings.Trong SETTINGS, trên tab General, nhấp vào thanh trượt "SSL certificate verification" để tắt, như hiển thị bên dưới.

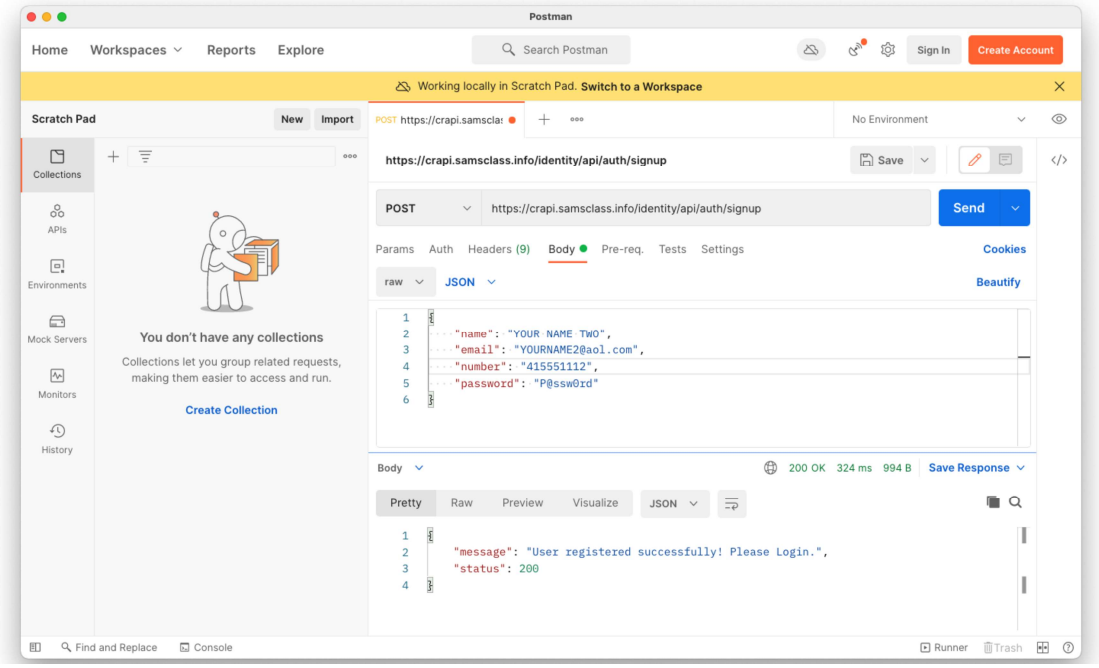
  - Nếu bạn không làm điều này, nó sẽ từ chối chứng chỉ Burp.



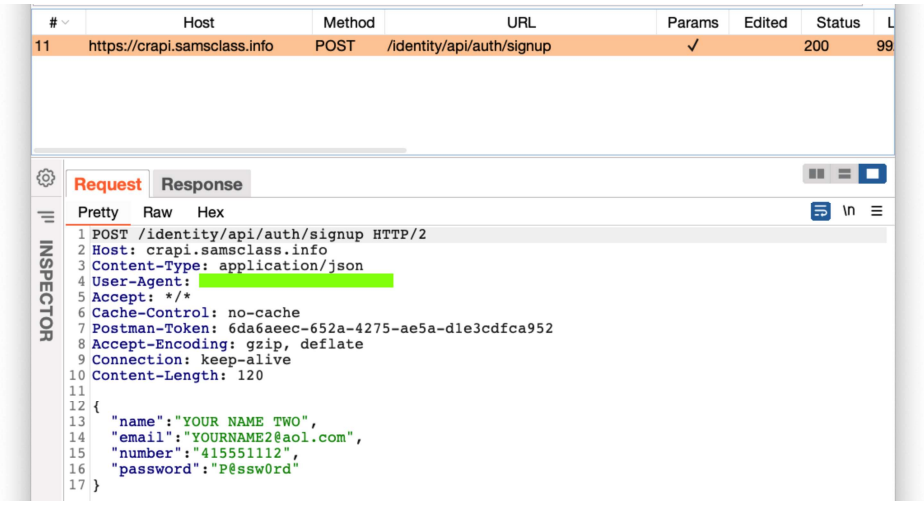
- Trong SETTINGS, nhấp vào tab Proxy.
- Đánh dấu vào ô "Add a custom proxy configuration"và đặt máy chủ thành 127.0.0.1 trên cổng 8080, như hiển thị bên dưới. Sau đó đóng hộp SETTINGS.



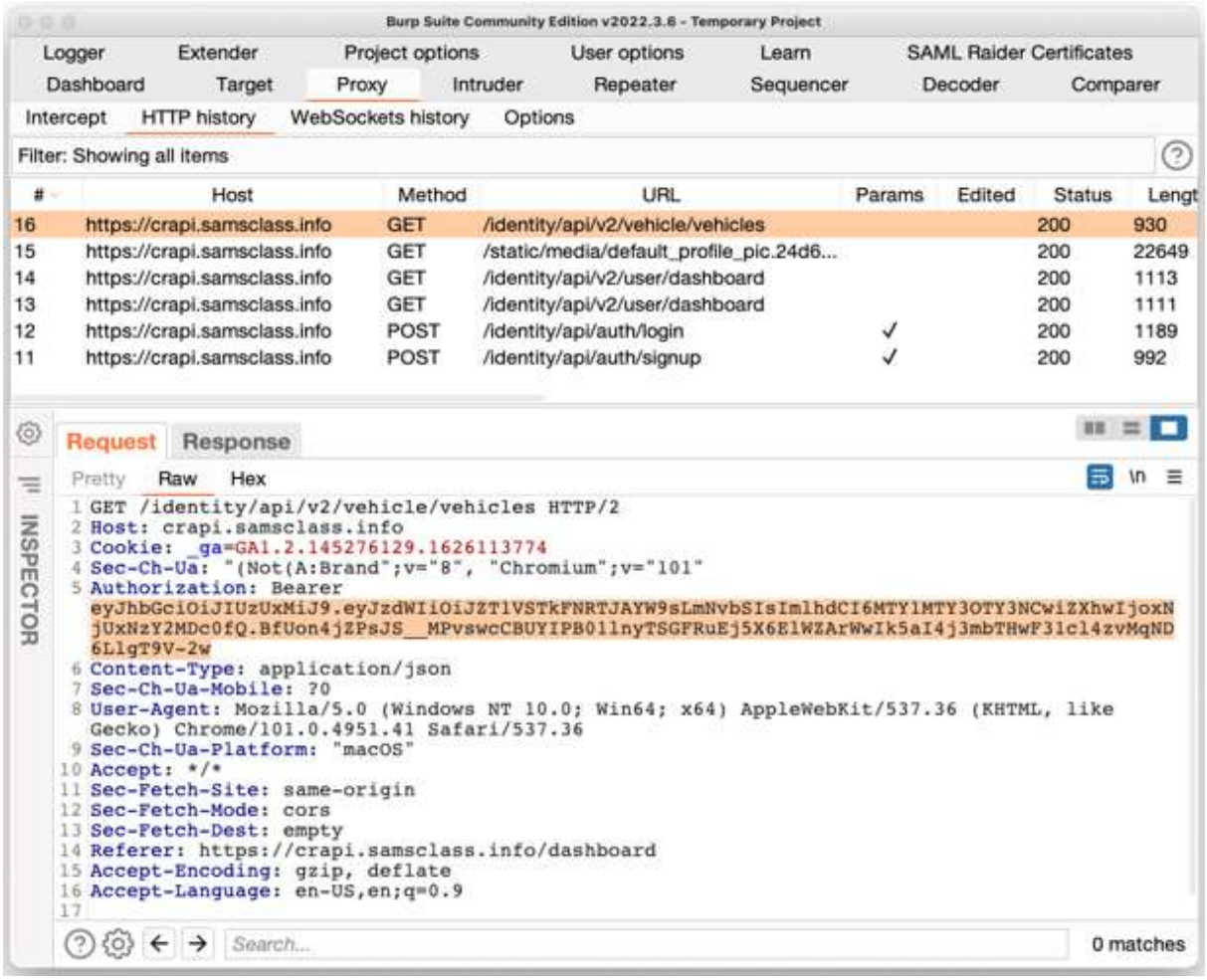
- **Gửi Signup Request:**
  - Trong Postman, ở phía bên phải, nhấp vào nút Send màu xanh lam.
  - Khung bên dưới sẽ hiển thị "User registered successfully! Please Login", như hiển thị bên dưới.



- **Cờ AP 101.1 - User-Agent:**
  - Trong Burp, trên tab Proxy, trên tab phụ "HTTP history", hãy nhấp vào dòng "`POST /identity/api/auth/signup`" gần đây nhất.
  - Trong ngăn bên dưới, trên tab Yêu cầu, bạn sẽ thấy yêu cầu được Postman gửi.
  - Cờ được che bởi hình chữ nhật màu xanh lá cây trong hình ảnh bên dưới.

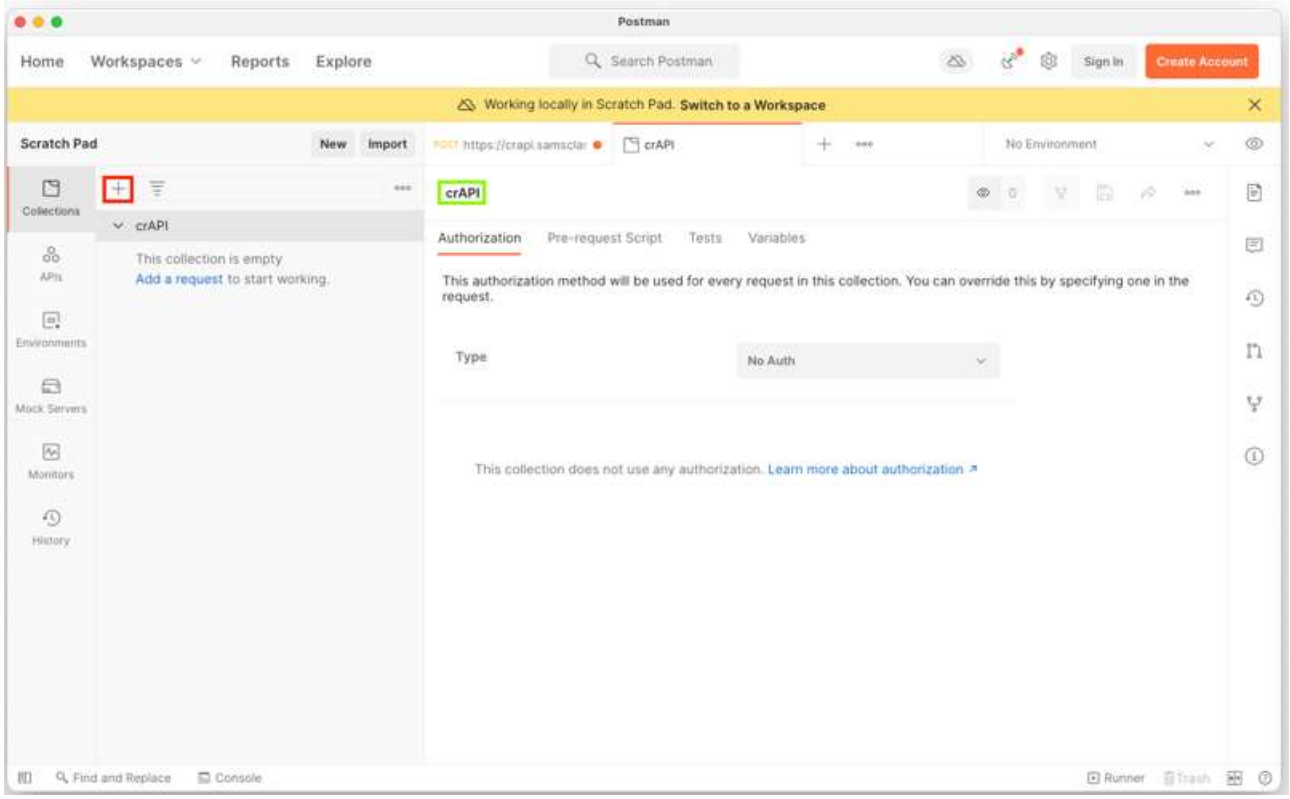


- **Đăng nhập:** Trong trình duyệt Burp, hãy đăng nhập bằng email và mật khẩu bạn đã chọn khi đăng ký.
- **Bearer Token:**
  - Trong Burp, trên tab Proxy, trên tab phụ "HTTP history", bạn thấy yêu cầu POST đến `/identity/api/auth/login`, theo sau là một số yêu cầu GET.
  - Nhấp vào yêu cầu GET đến `/identity/api/v2/vehicle/vehicles`.
  - Như được hiển thị bên dưới, tab Request hiển thị Authorization header với một khối dữ liệu được mã hóa Base64 dài. Đây là **Bearer Token**.
  - Tô sáng khối dữ liệu được mã hóa Base64 và sao chép nó, như được hiển thị bên dưới.

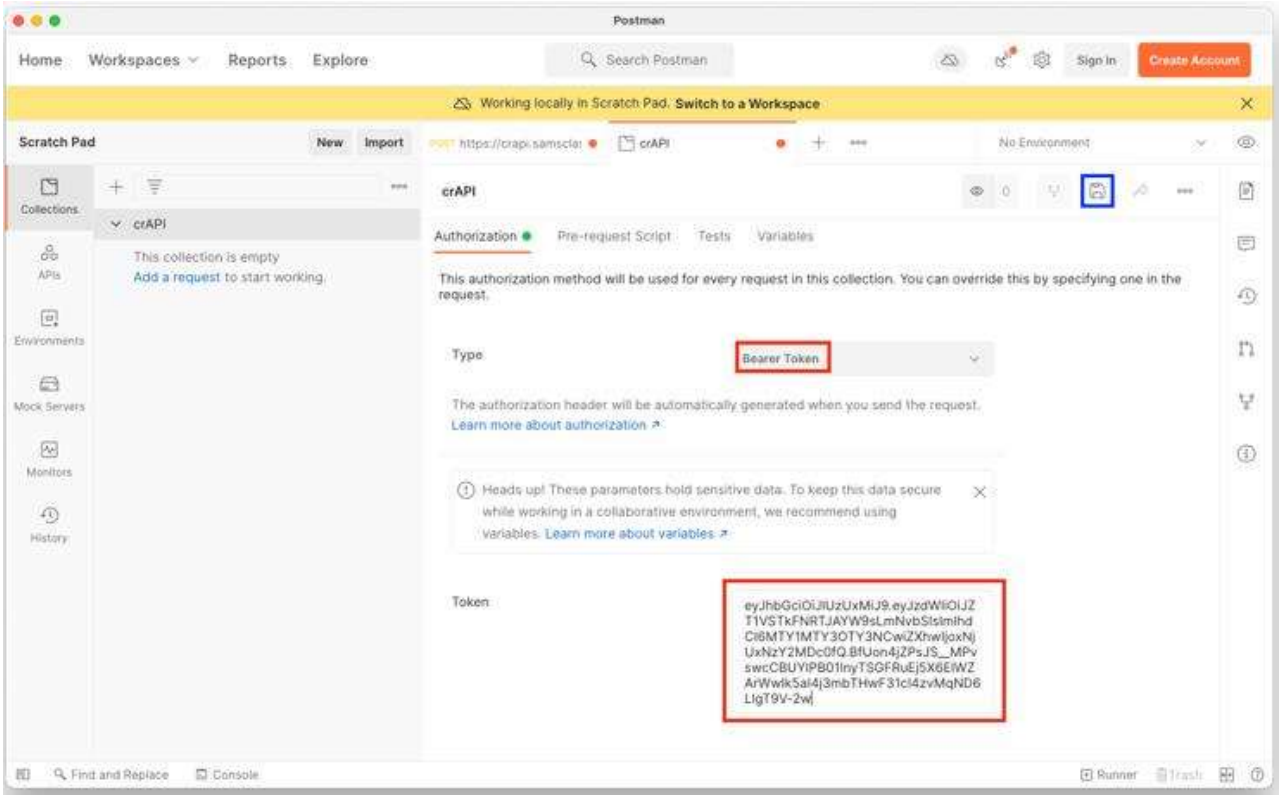


- **Tạo Postman Collection:**
  - Chúng ta sẽ tạo một Collection để chứa các yêu cầu API đã xác thực cho máy chủ crAPI.

- Trong Postman, ở phía bên trái, hãy xác minh rằng Collections đã được chọn. Sau đó, nhấp vào dấu + bên cạnh "Collections", được viền màu đỏ trong hình ảnh bên dưới, để tạo một Collection mới.
- Đặt tên Collection crAPI của bạn, như được viền màu xanh lá cây trong hình ảnh bên dưới.

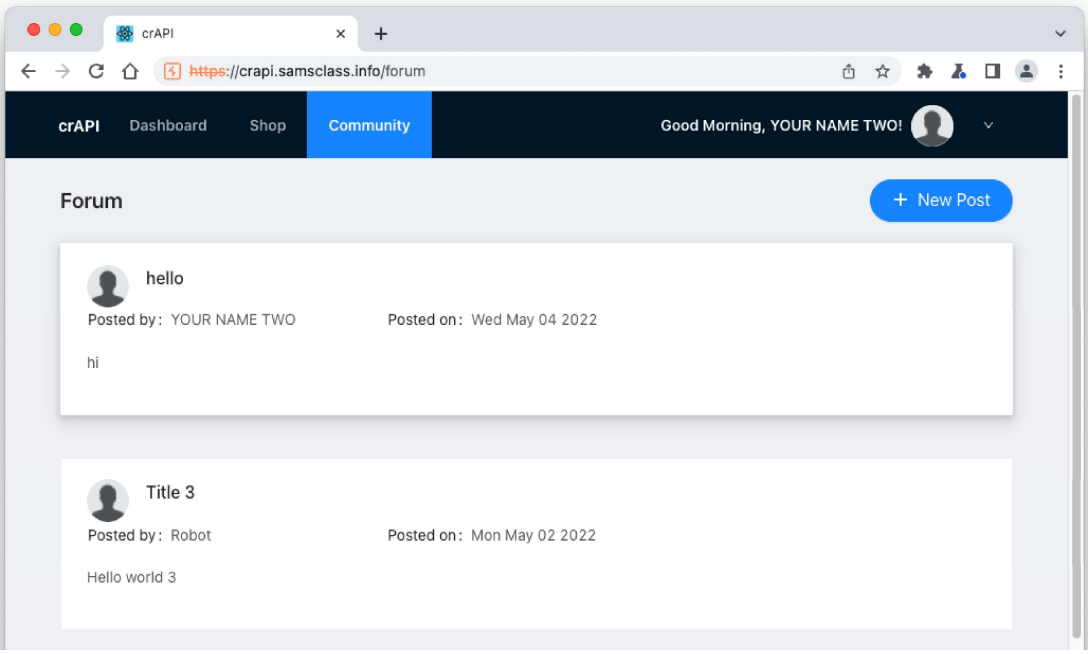


- **Thêm Bearer Token cho Postman:**
  - Trong ngăn giữa, tab Authorization được chọn. Chọn Loại "Bearer Token". Dán giá trị Tokencủa bạn vào, như hiển thị bên dưới. Ở trên cùng bên phải, nhấp vào biểu tượng đĩa mềm, được viền màu xanh lam trong hình ảnh bên dưới, để lưu thông tin xác thực ủy quyền của bạn.
  - Bây giờ, các yêu cầu trong vùng chứa crAPI sẽ được tài khoản của bạn ủy quyền.



- **Đăng lên Community:**

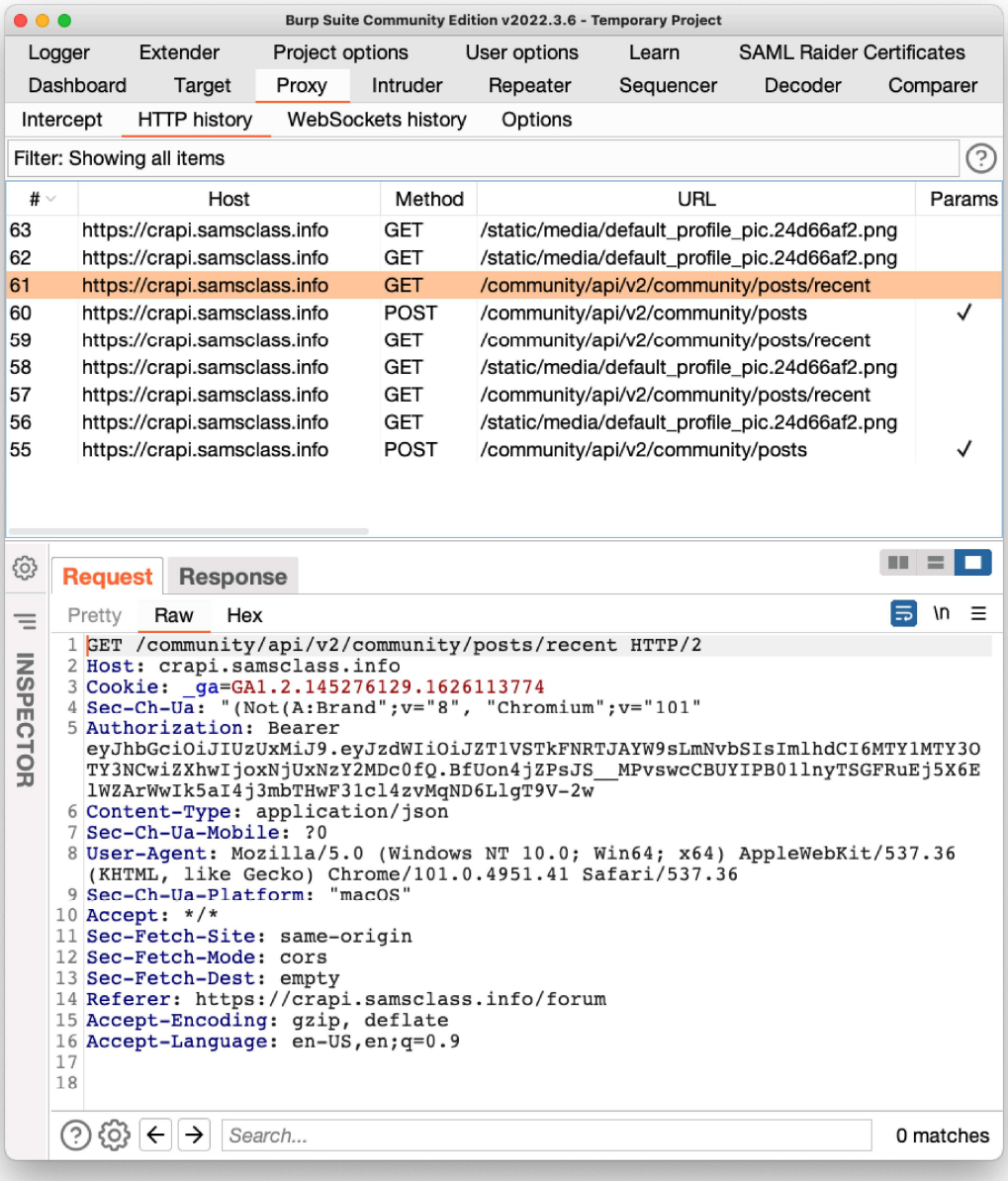
  - Trong trình duyệt Burp, ở trên cùng, nhấp vào Community.
  - Nhấp vào nút " New Post", như hiển thị bên dưới và thêm bài đăng mới với bất kỳ tiêu đề và bình luận nào bạn chọn.



- Một hộp thoại hiện lên với nội dung "Post Created". Nhấp vào OK.
- Kiểm tra Recent Posts Request:
  - Trong Burp, hãy kiểm tra yêu cầu:

```
GET /community/api/v2/community/posts/recent
```

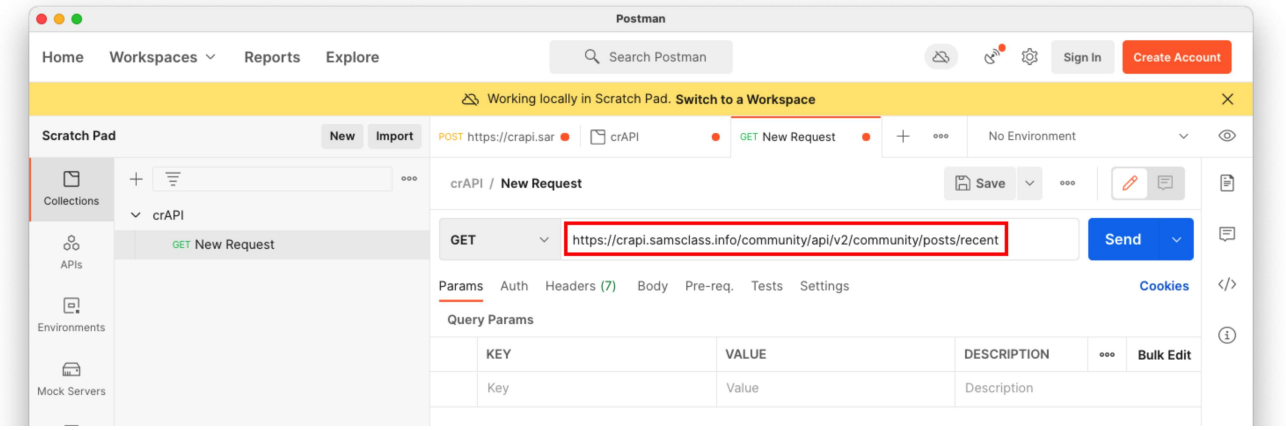
  - Đây là yêu cầu GET, như hiển thị bên dưới.



- **Gửi Recent Posts Request từ Postman:**

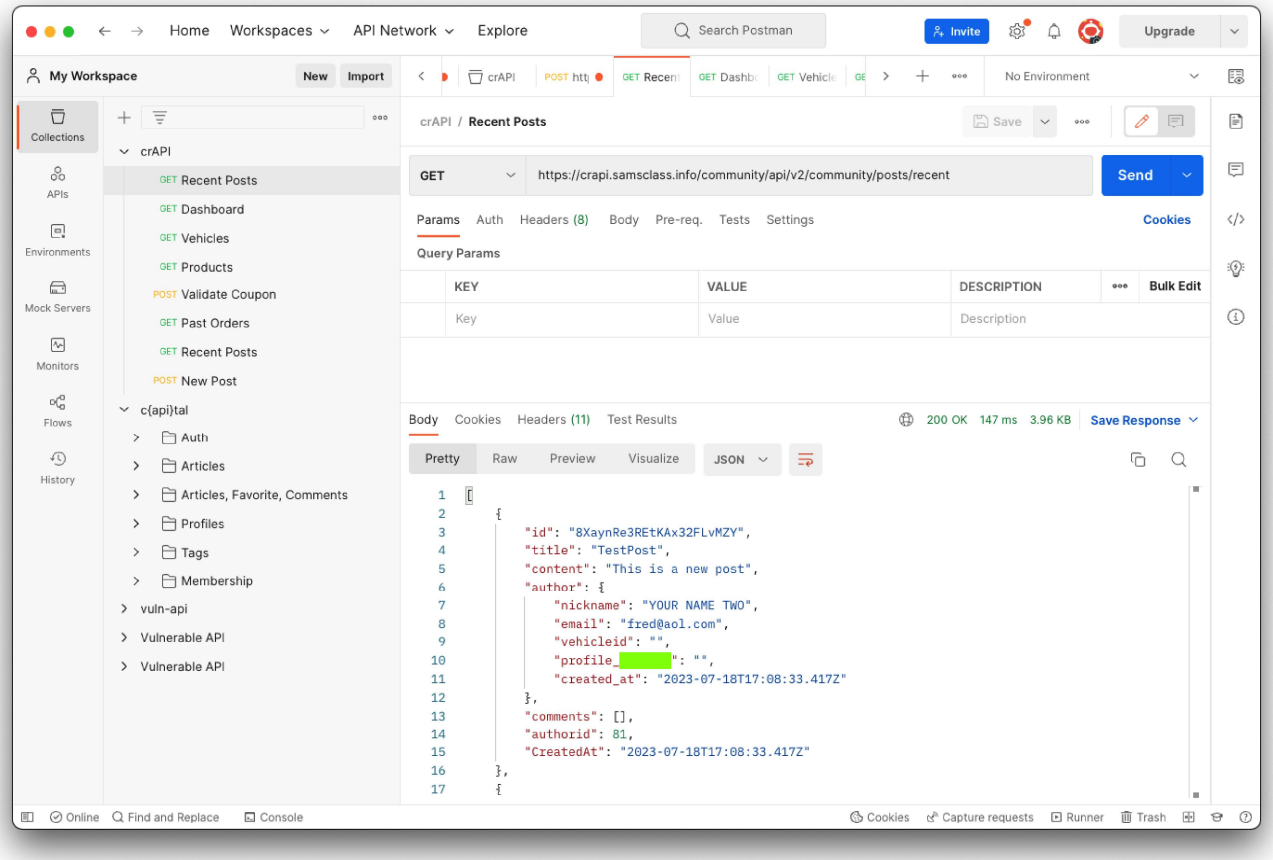
- Trong Postman, ở phía bên trái, trong vùng chứa crAPI, hãy nhấp vào "Add a request". Trong Burp, nhấp chuột phải vào yêu cầu và nhấp vào "Copy URL".

- Dán URL vào Postman, như hiển thị bên dưới.



- **Cờ AP 101.2 - External API Endpoint:**

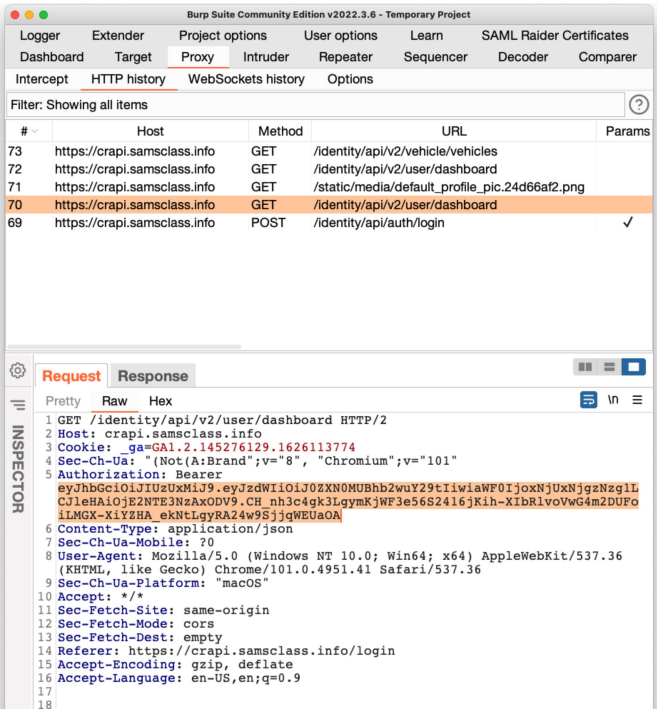
- Trong Postman, nhấp vào nút Send màu xanh lam.
- Phản hồi sẽ xuất hiện ở ngăn bên dưới. Lá cờ được che bởi một hình chữ nhật màu xanh lá cây trong hình ảnh bên dưới.



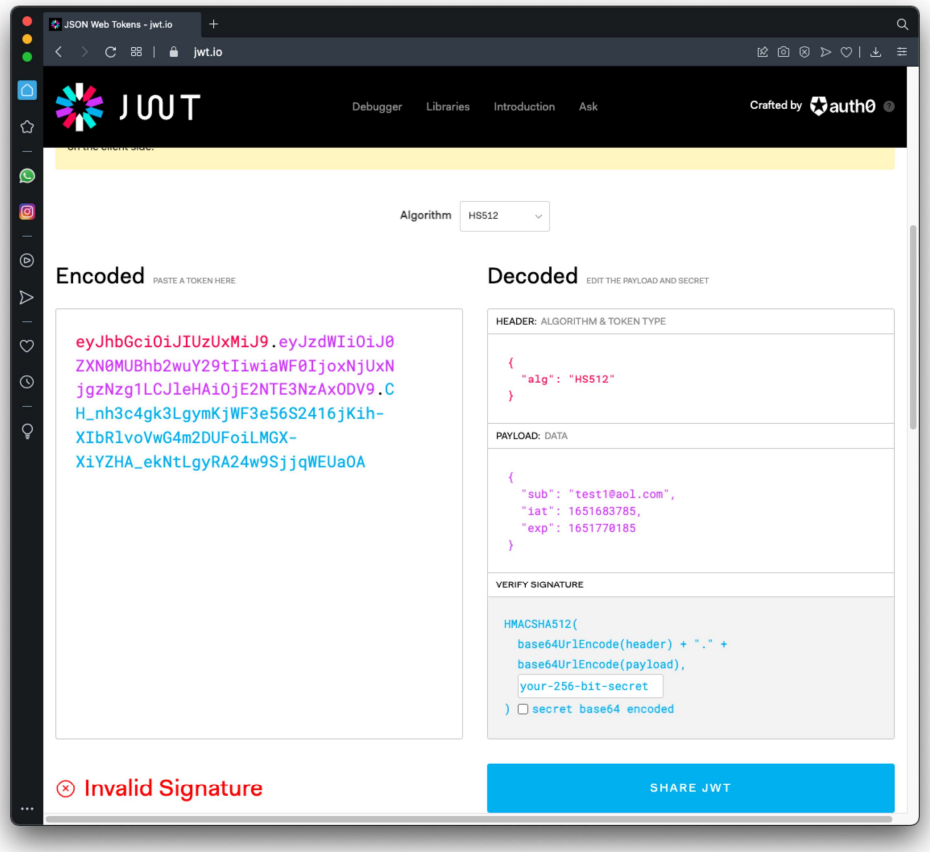
BÀI 2: JSON WEB TOKEN

2.1 PHÁ VỠ CHỮ KÝ JSON WEB TOKEN

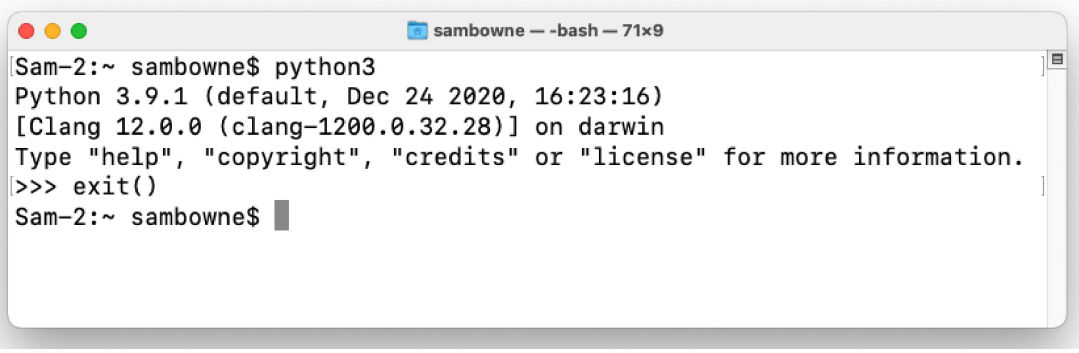
- **Phần mềm:** Burp Suite, Python 3.
- **Mục tiêu:** Tấn công JSON Web Token (JWT) bằng phương pháp tấn công từ điển.
- **Kết nối đến crAPI:** Tương tự các bài tập trước.
- **Đăng nhập:** Trong trình duyệt của Burp, đăng nhập vào crAPI với bất kỳ tài khoản nào. Nếu bạn chưa có tài khoản, nhấn SignUp để tạo một tài khoản mới.
- **Lấy Bearer Token của bạn:**
  - Trong Burp, chọn tab Proxy, sau đó chọn tab phụ HTTP history.
  - Nhấp vào dòng `GET /identity/api/v2/user/dashboard`.
  - Trong khung dưới, chọn tab Request, bạn sẽ thấy dòng Authorization chứa Bearer token. Sao chép token này vào clipboard.



- **Sử dụng JWT.IO:**
  - Trong trình duyệt web, truy cập:https://jwt.io/
  - Dán token của bạn vào ô Encoded.Ở phần Decoded, bạn sẽ thấy:
    - Token được chia thành ba phần, mỗi phần có màu sắc khác nhau.
    - Phần Payload chứa địa chỉ email của bạn và hai giá trị timestamp.
    - Ở góc dưới bên phải, trong ô VERIFY SIGNATURE, có trường `your-256-bit-secret`.



- **Kiểm tra Python 3:**
  - Mở Terminal hoặc Command Prompt.
  - Gõ `python` hoặc `python3` để kiểm tra xem bạn đã cài đặt Python 3 chưa.
  - Nếu đã cài đặt, bạn sẽ thấy tiêu đề Python 3. Gõ exit() để thoát.
  - Nếu chưa cài đặt, tải Python 3 tại:https://www.python.org/downloads/



- **Chuẩn bị danh sách từ (wordlist):** Sử dụng Notepad hoặc Nano, tạo một tệp văn bản đơn giản tên là words.txt với nội dung sau:

```
Crapi2020
JWT
Jwt2020
Jwt2022
Jwt_2020
Jwt_2022
OWASP
Owasp2021
community
crAPI2020
crAPI2021
crAPI2022
crapi
crapi2022
iparc
iparc2020
iparc2021
iparc2022
iparc2023
jwt2020
owasp
```

- **Tải và cài đặt jwt_tool:** Thực hiện các lệnh sau. Nếu bạn sử dụng Windows và không có wget, hãy sử dụng trình duyệt web để tải tệp.

```
python3 -m pip install termcolor cprint pycryptodomex requests

wget https://github.com/ticarpi/jwt_tool/raw/master/jwt_tool.py

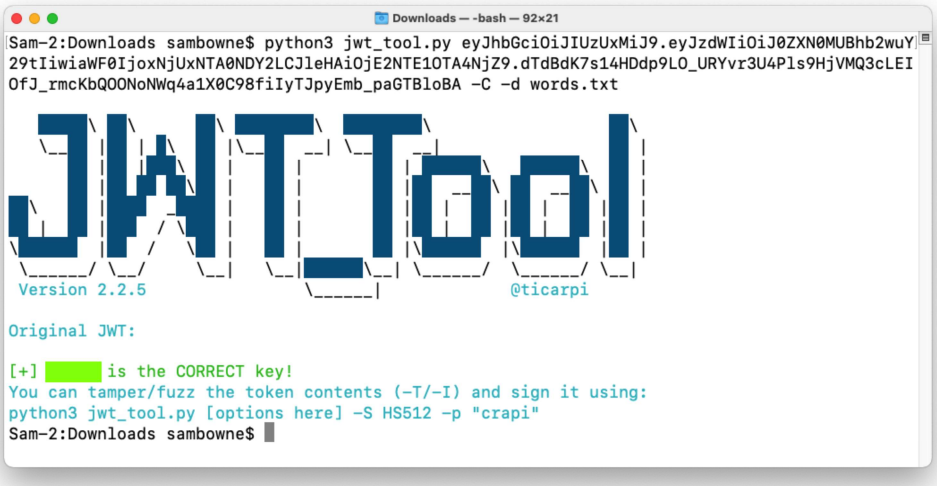
python3 jwt_tool.py

python3 jwt_tool.py -h
```

- **Thực hiện tấn công:** Thực hiện lệnh sau, thay xxxxxxxxx bằng JWT token bạn đã sao chép từ Burp:

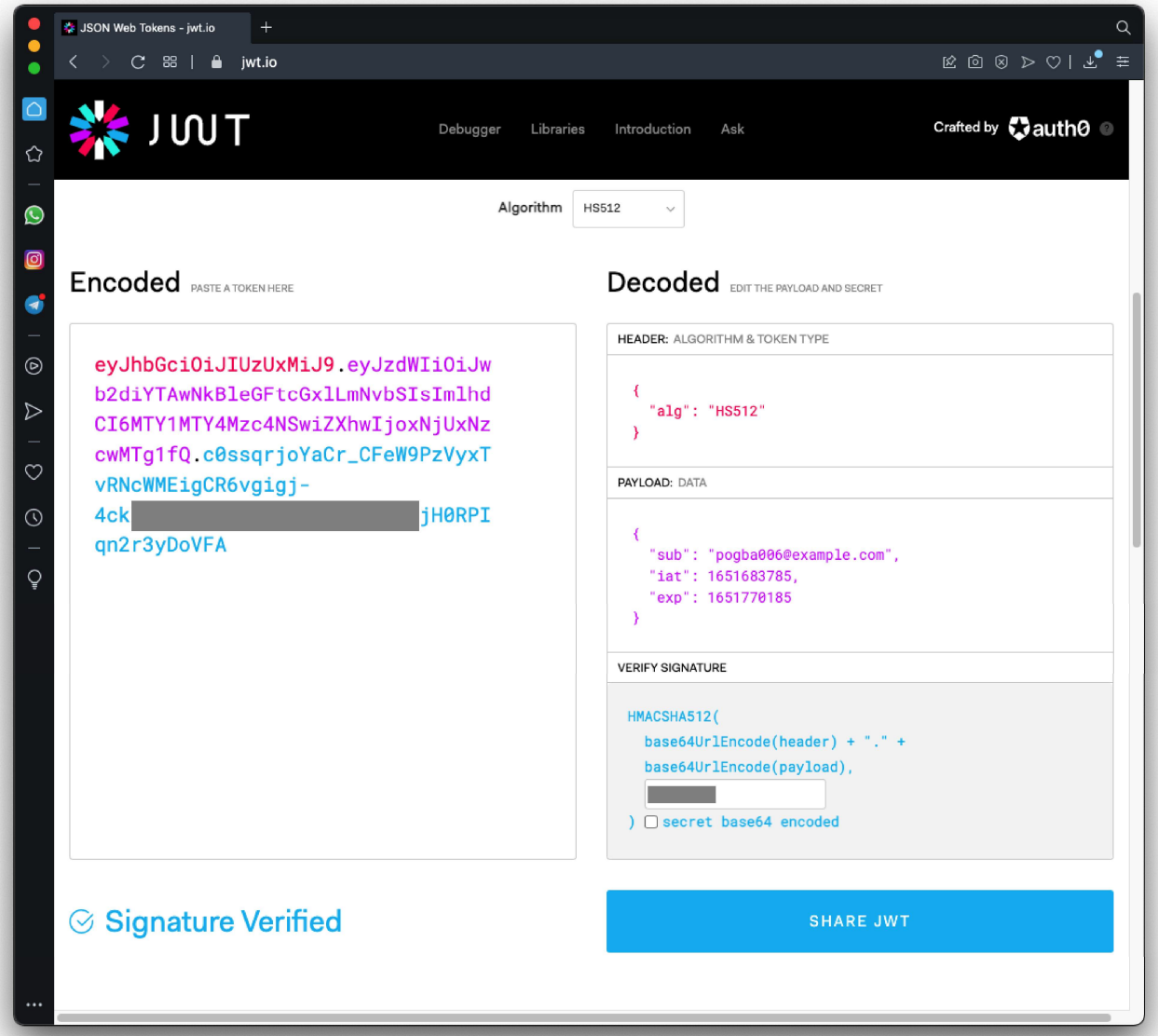
```
python3 jwt_tool.py xxxxxxxxx -C -d words.txt
```

- **Cờ AP 102.1 - Secret Word:**
  - Cờ là khóa chính xác, được hiển thị trong hình ảnh minh họa.



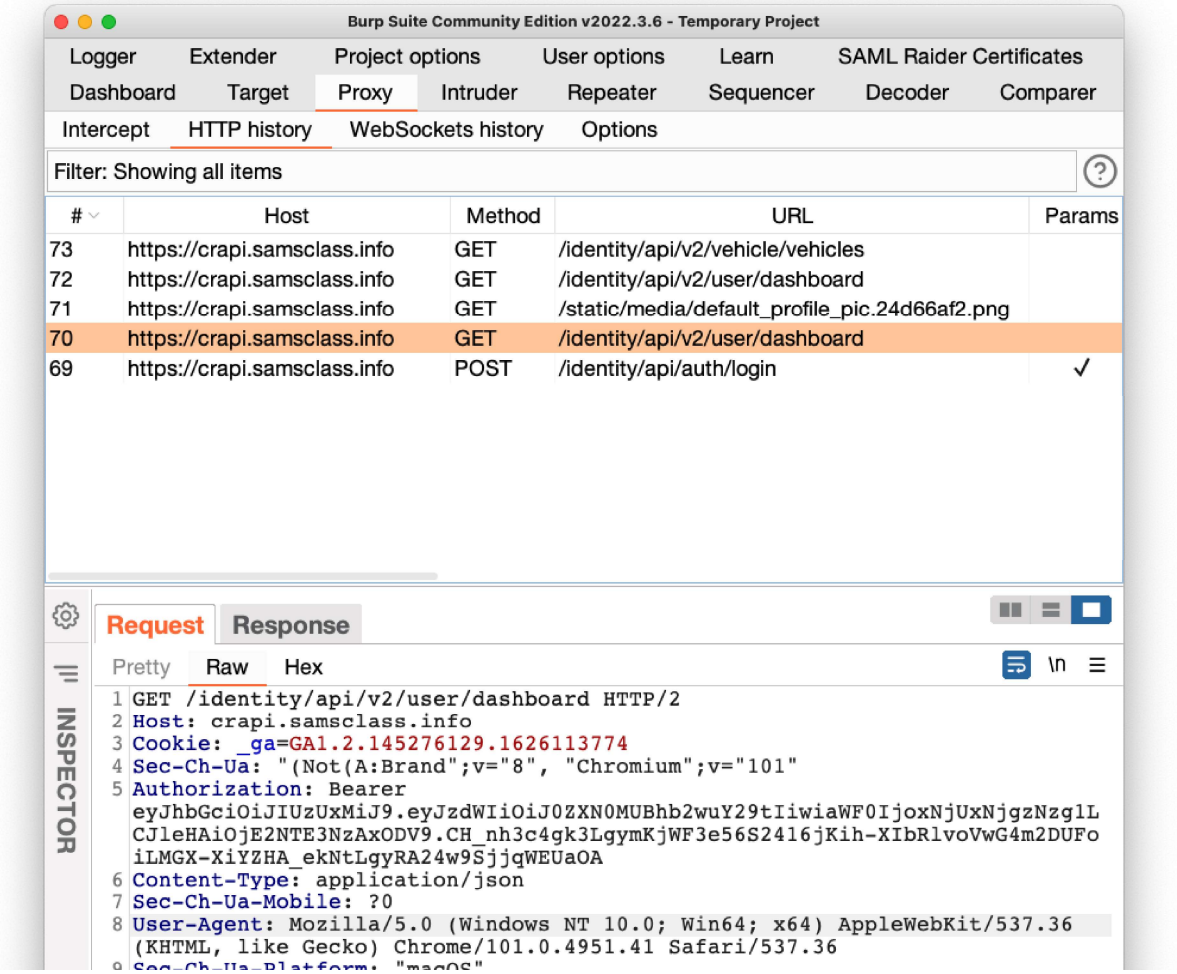
- **Giả mạo JWT:**
  - Trong trang jwt.io, nhập khóa bí mật bạn đã tìm thấy vào trường VERIFY SIGNATURE.
  - Trong phần PAYLOAD DATA, thay đổi địa chỉ email thành:

    `pogba006@example.com`
  - Trang sẽ tạo một JWT mới trong ô Encoded.

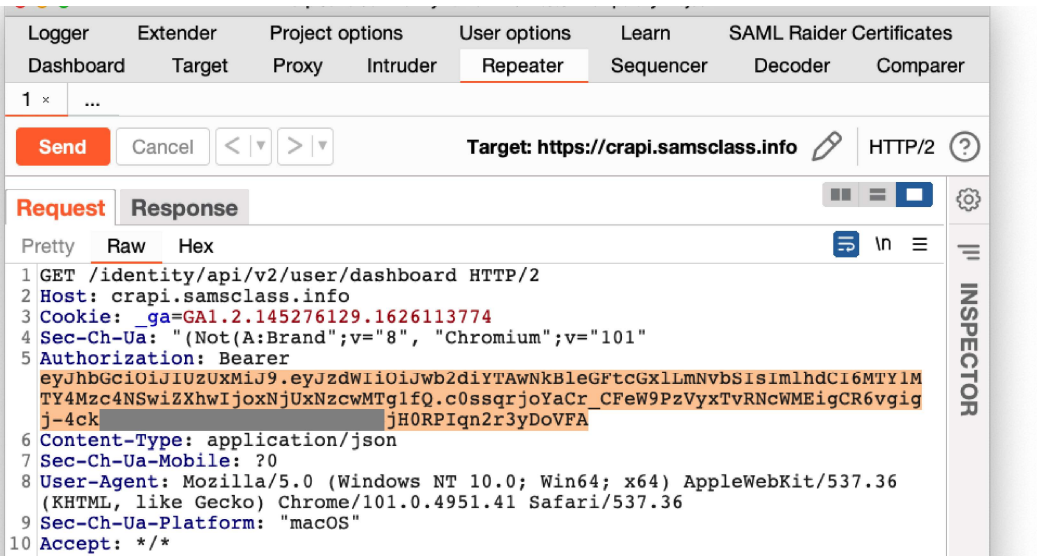


- **Sử dụng token giả mạo:**
  - Trong Burp, chọn tab HTTP History, nhấp vào yêu cầu:

```
GET /identity/api/v2/user/dashboard
```



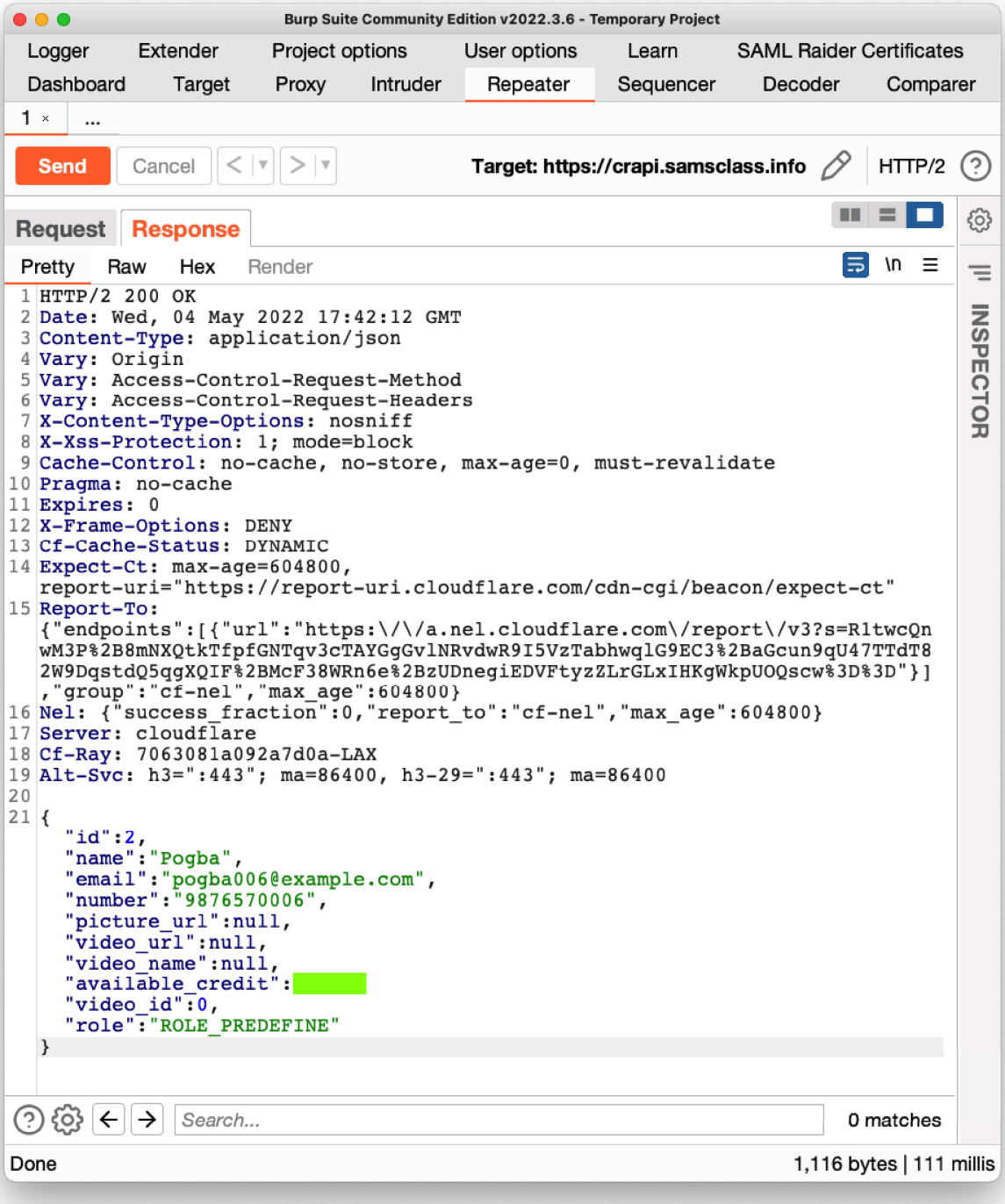
- Nhấp chuột phải vào yêu cầu và chọn "Send to Repeater".
- Trong tab Repeater, thay thế token bằng token giả mạo của bạn.



- Gửi yêu cầu.

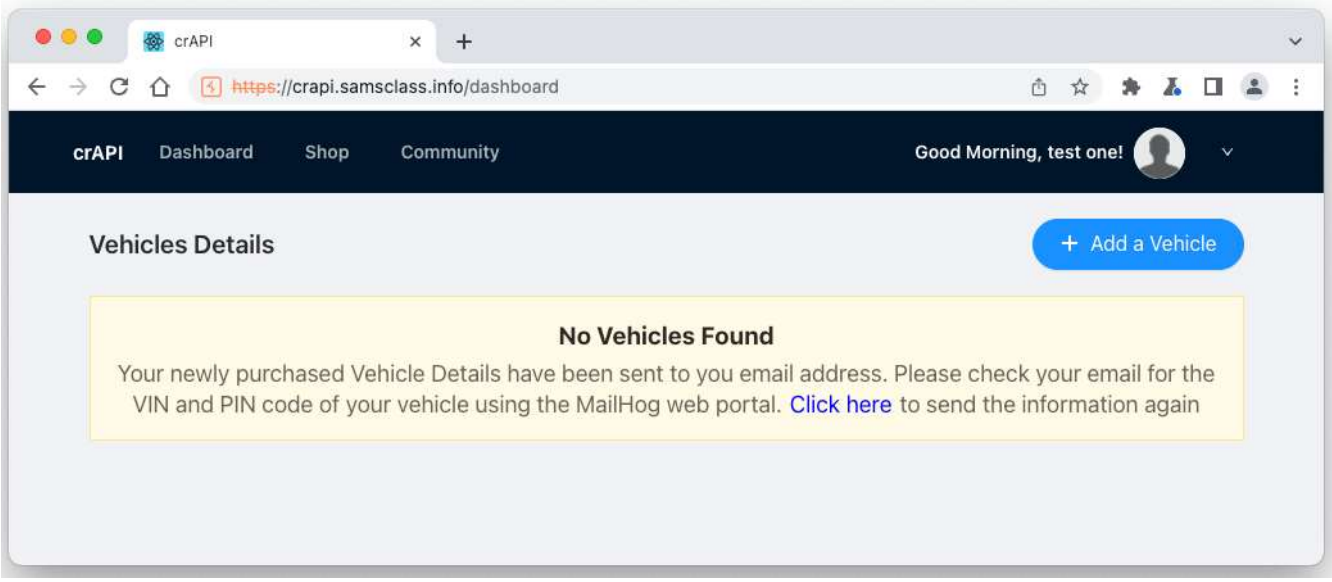
- **Cờ AP 102.2 - Available Credit:**

  - Phản hồi sẽ xuất hiện trong khung dưới. Cờ là số dư khả dụng của Pogba, được hiển thị trong hình ảnh minh họa.

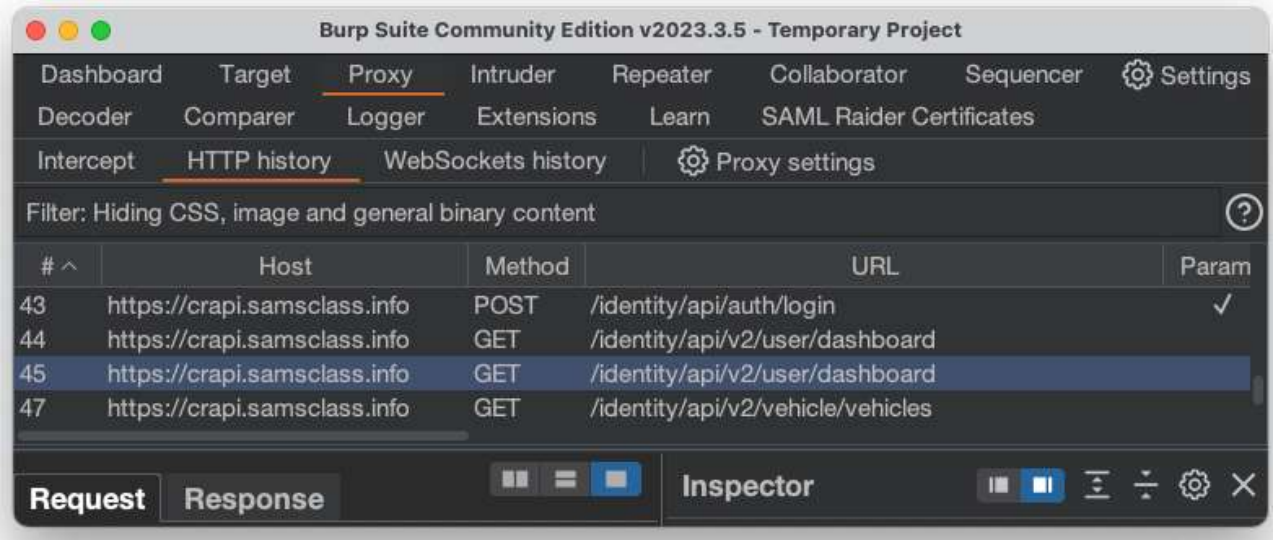


2.2 FUZZING VỚI POSTMAN

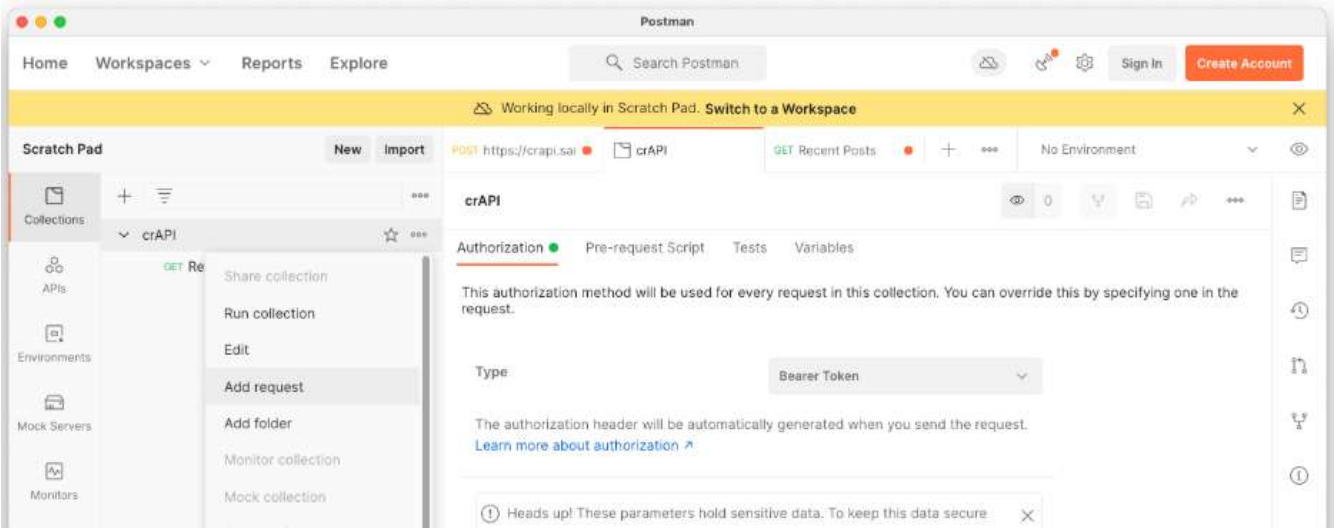
- **Phần mềm:** Suite, Postman.
- **Mục tiêu:** Thêm nhiều yêu cầu (request) vào bộ sưu tập crAPI trong Postman, chuẩn bị cho việc fuzzing các endpoint API.
- **Kết nối đến crAPI:** Tương tự các bài tập trước.
- **Đăng nhập:**
  - Trong trình duyệt của Burp, đăng nhập vào crAPI với bất kỳ tài khoản nào. Nếu bạn chưa có tài khoản, nhấn SignUp để tạo một tài khoản mới.
  - Sau khi đăng nhập, bạn sẽ thấy trang "Vehicles Details".



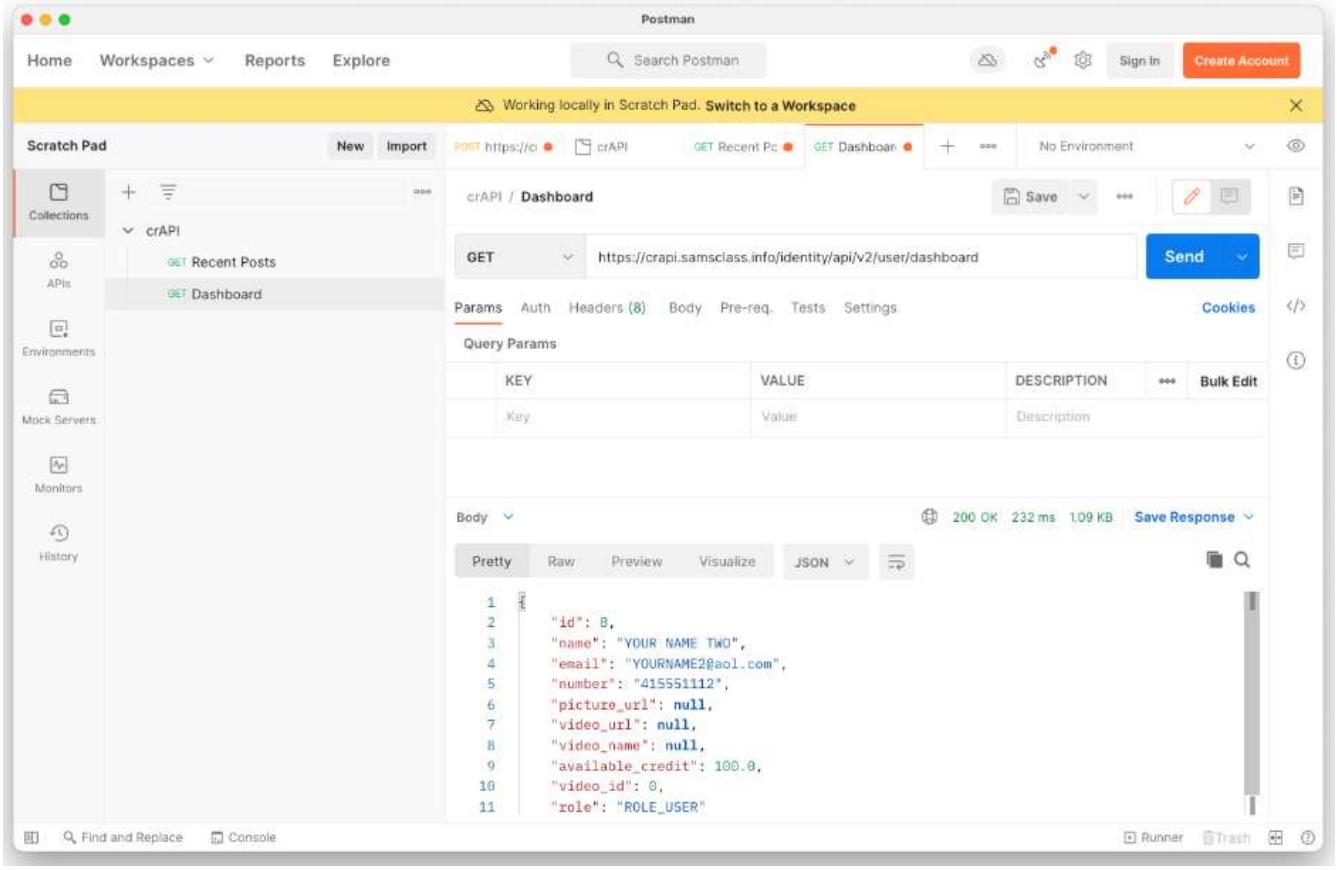
- **Tìm các yêu cầu API:**
  - Trong Burp, chọn tab HTTP History. Bạn sẽ thấy ba yêu cầu API được sử dụng để tải trang này.
  - Tất cả đều là yêu cầu GET, và URL chứa `/api/`.
  - Hai yêu cầu đầu tiên giống nhau, tải Dashboard, và yêu cầu thứ ba tải thông tin Vehicles.



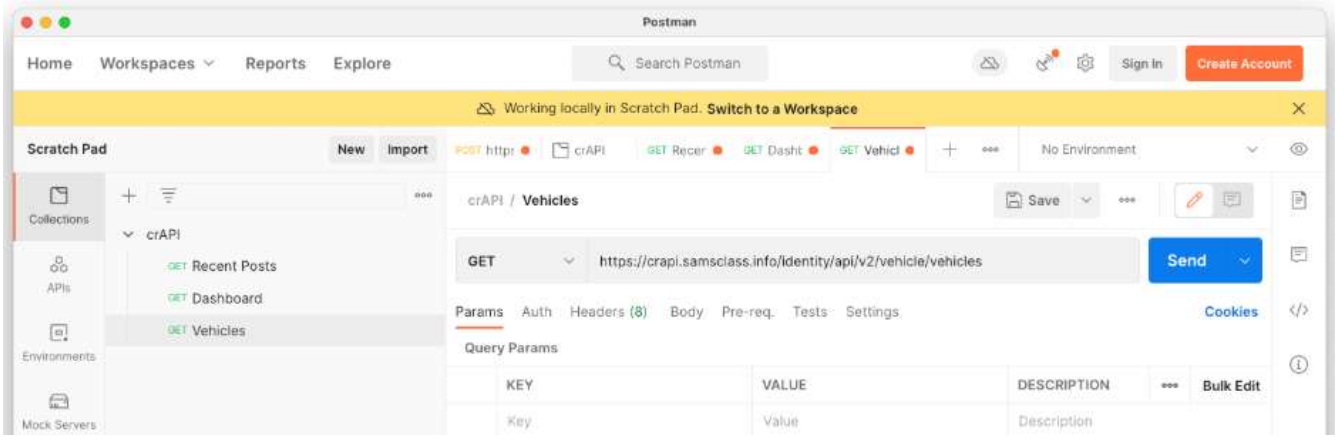
- **Thêm yêu cầu vào bộ sưu tập crAPI trong Postman:**
  - Trong Postman, ở bên trái, nhấp vào bộ sưu tập crAPI.
  - Ở bên phải dòng crAPI, nhấp vào biểu tượng ba chấm. Chọn "Add request".



  - Đặt tên yêu cầu là Dashboard và dán URL từ Burp vào.
  - Nhấn nút Send và xác nhận rằng phản hồi hiển thị dữ liệu JSON từ tài khoản của bạn.

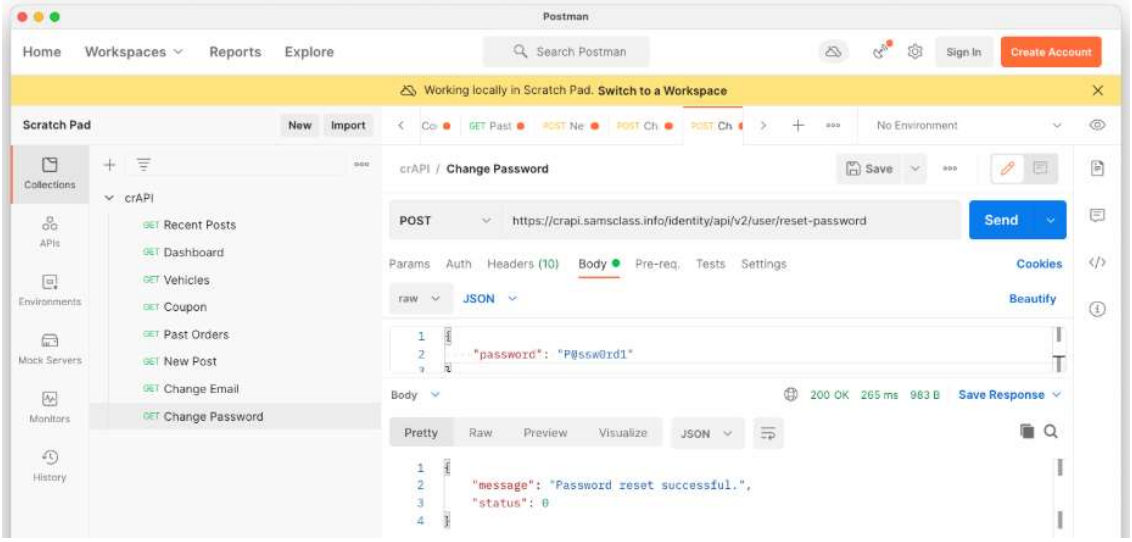


- Lặp lại quy trình để thêm yêu cầu Vehicles.

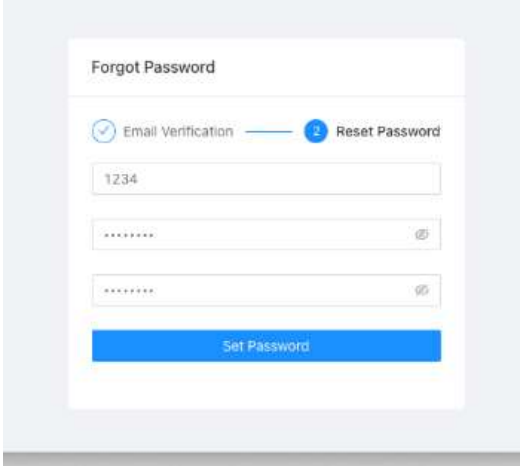


- **Thêm một Vehicle:**
  - Trong trình duyệt của Burp, ở góc trên bên phải, nhấp vào nút "+ Add a Vehicle".
  - Thử nhập dữ liệu thử nghiệm vào biểu mẫu.
  - Nếu không thể nhập bất kỳ VIN nào mà hệ thống chấp nhận, bạn có thể bỏ qua yêu cầu này.

- **Hoàn thiện bộ sưu tập:** Tiếp tục theo cách này trên các trang Shop và Community, thêm tất cả các yêu cầu có thể vào bộ sưu tập crAPI trong Postman.

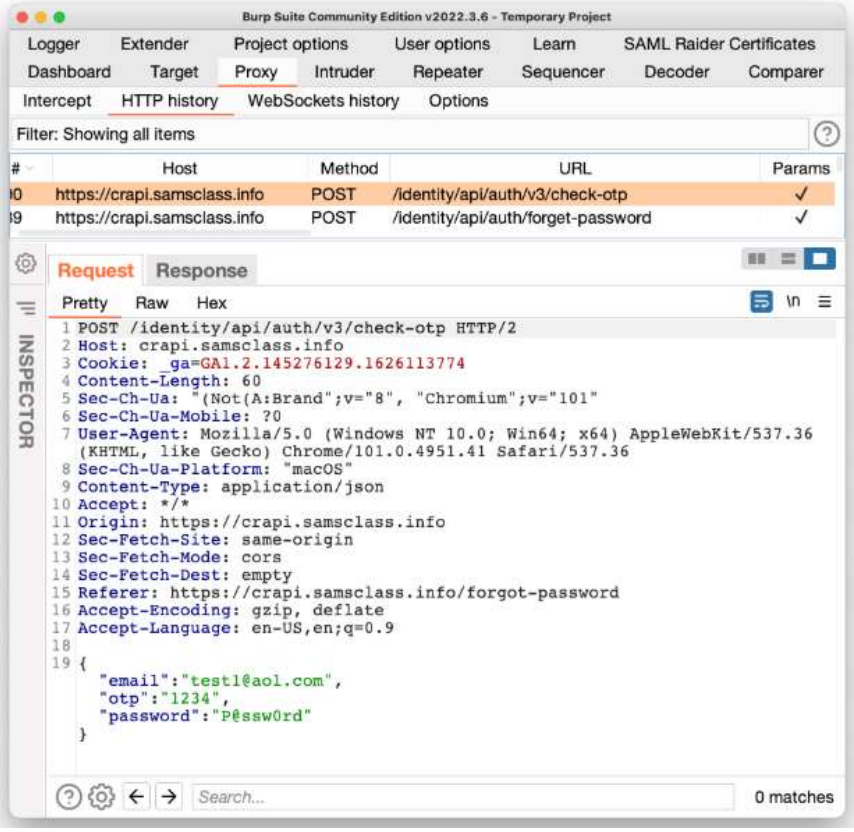


- **Khôi phục mật khẩu:**
  - Trong trình duyệt của Burp, đăng xuất khỏi crAPI.
  - Trên trang đăng nhập, nhấp vào "Forgot Password".
  - Trong hộp "Forgot Password", nhập địa chỉ email của bạn.
  - Nhấp vào "Send OTP", sau đó nhấp OK.
  - Trong hộp tiếp theo, nhập bất kỳ giá trị nào cho OTP và nhập mật khẩu mới hai lần. Nhấp vào "Set Password".



  - Việc đặt lại mật khẩu sẽ thất bại, nhưng chúng ta đã tìm thấy endpoint API.

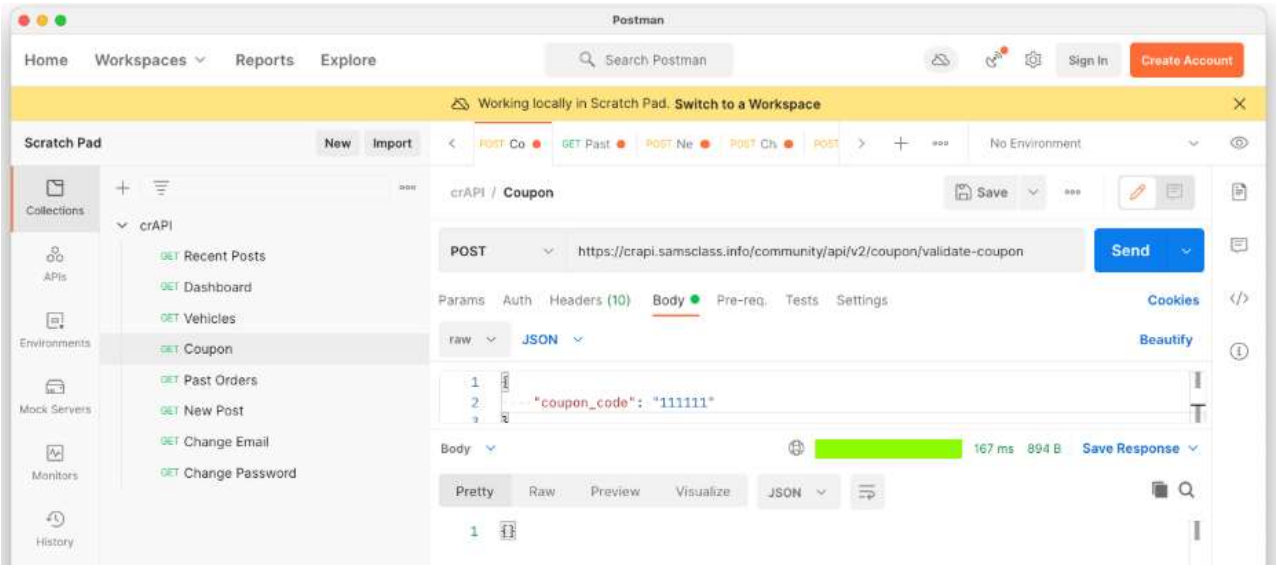
- Tìm yêu cầu này trong Burp: `POST /identity/api/auth/v3/check-otp`



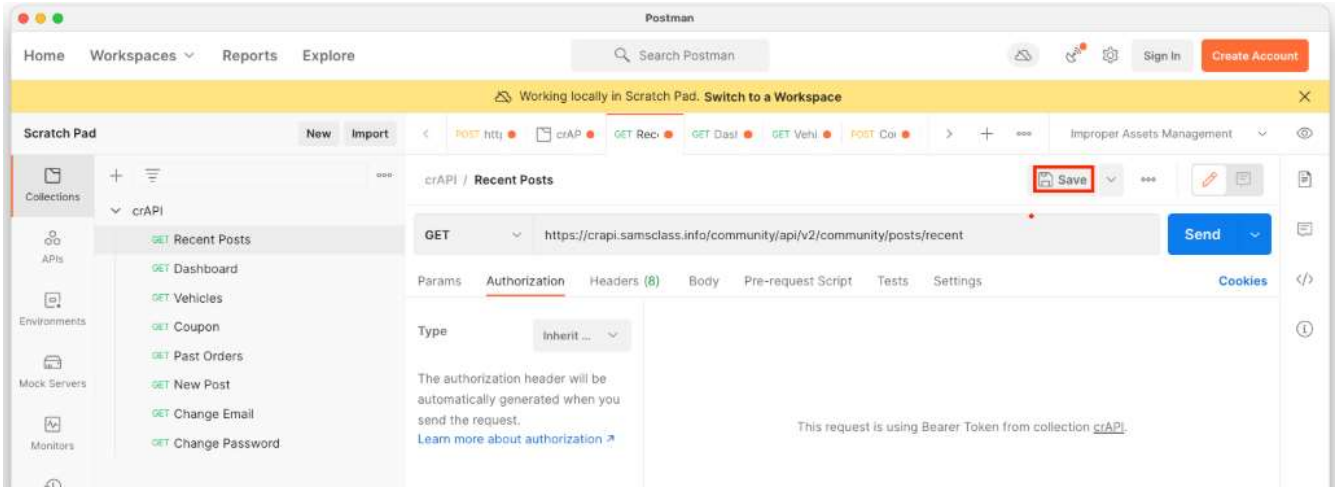
- Thêm yêu cầu này vào bộ sưu tập crAPI trong Postman. Lưu ý rằng yêu cầu này sử dụng "v3" trong URL, trong khi tất cả các yêu cầu khác sử dụng "v2".

- **Cờ AP 103.1 – Status:**

  - Chạy yêu cầu validate-coupon với mã coupon là 111111.
  - Cờ là thông báo trạng thái, được hiển thị trong phản hồi.

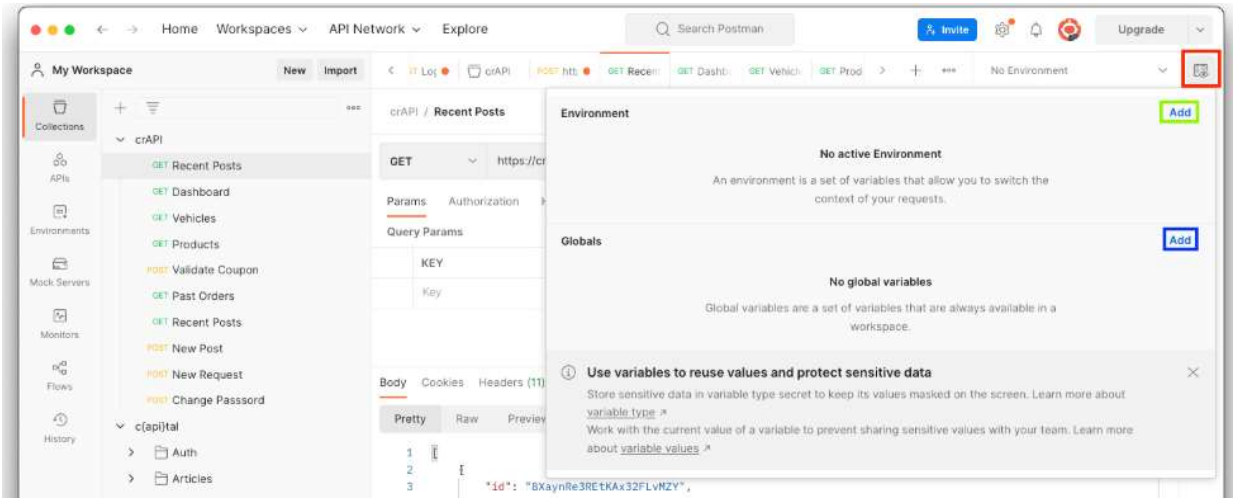


- **Lưu các yêu cầu:**
  - Trong Postman, trong bộ sưu tập crAPI, nhấp vào từng yêu cầu, ví dụ như "Recent Posts". Ở góc trên bên phải, nhấp vào Save.



  - Lặp lại quy trình này cho tất cả các yêu cầu trong bộ sưu tập crAPI.

- **Thêm biến môi trường trong Postman:**
  - Hầu hết hoặc tất cả các yêu cầu API đều có "v2" trong đường dẫn. Chúng ta muốn thay đổi số phiên bản này để xem liệu có các phiên bản khác của endpoint API trên máy chủ hay không, một lỗi được gọi là "Improper Assets Management Vulnerabilities".
  - Trong Postman, ở góc trên bên phải, nhấp vào biểu tượng con mắt trên tờ giấy. Hộp Environment sẽ xuất hiện.



- Trong phần Environment, nhấp vào Add.
- Đặt tên Environment là Improper Assets Management.
- Thêm một biến có tên là path với giá trị ban đầu là v3. Nhấp vào Save.

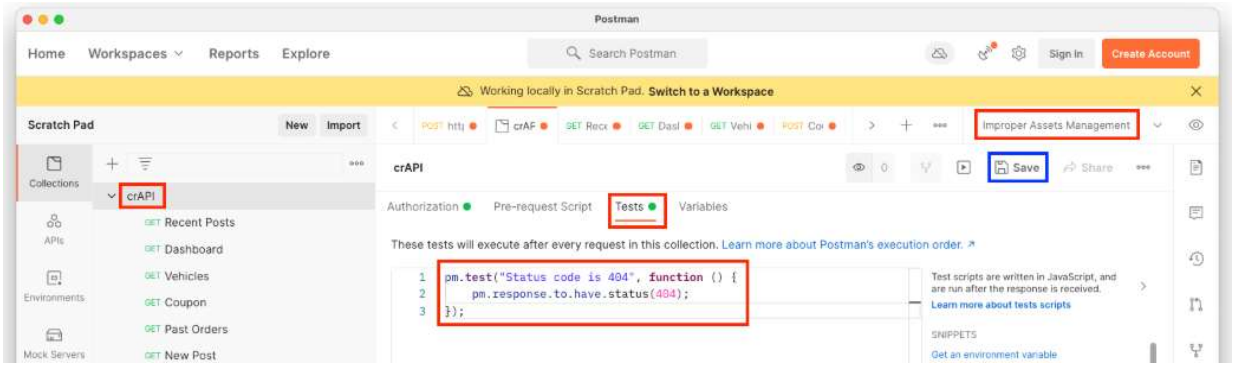
- **Thêm một bài kiểm tra:**
  - Trong Postman, ở bên trái, nhấp vào bộ sưu tập crAPI.
  - Ở góc trên bên phải, chọn Environment Improper Assets Management.
  - Ở khung trung tâm, nhấp vào tab Tests.
  - Nhập đoạn mã sau vào hộp Tests:

```
pm.test("Status code is 404", function () {

    pm.response.to.have.status(404);

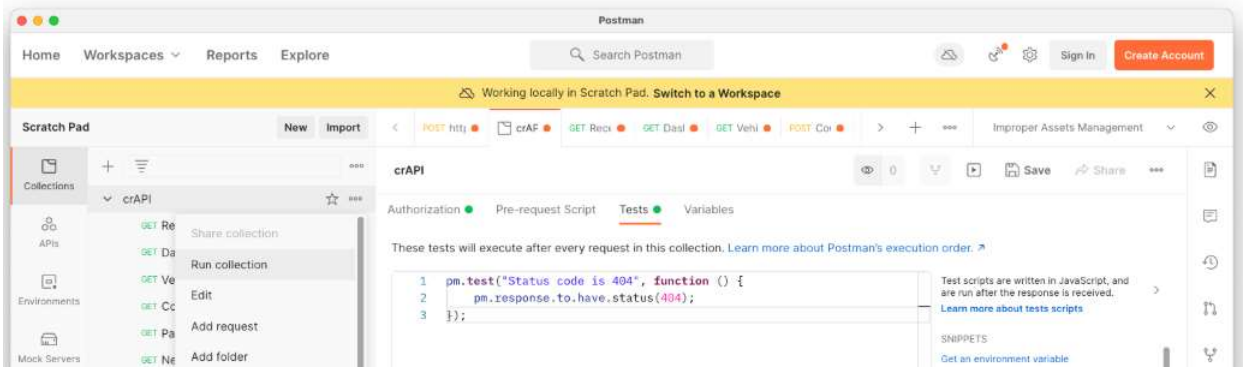
});
```

- Nhấp vào Save.

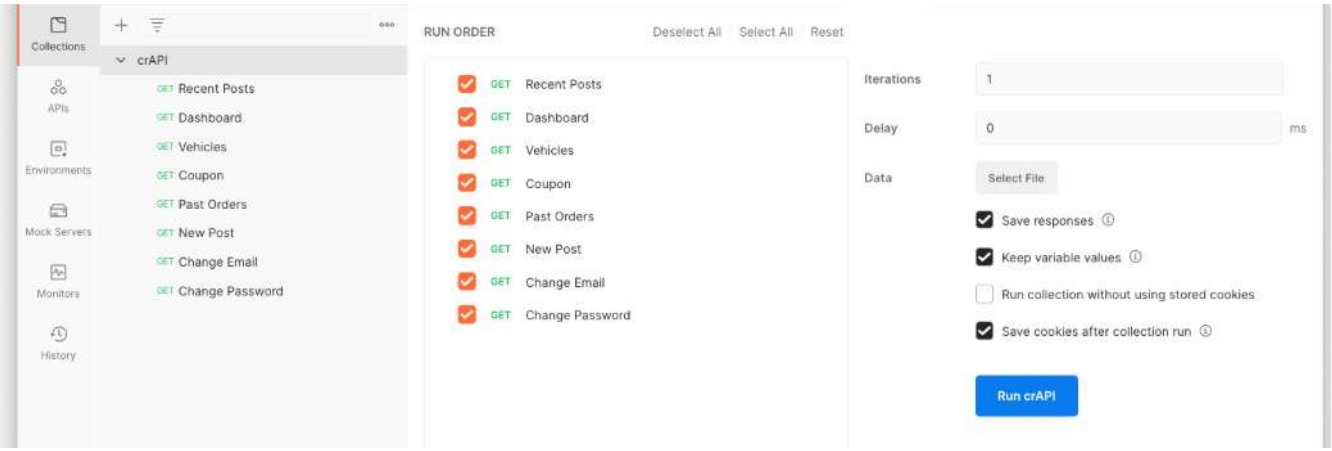


- **Chạy bộ sưu tập crAPI:**

  - Trong Postman, ở bên trái, trên dòng crAPI, nhấp vào biểu tượng ba chấm và chọn "Run collection".

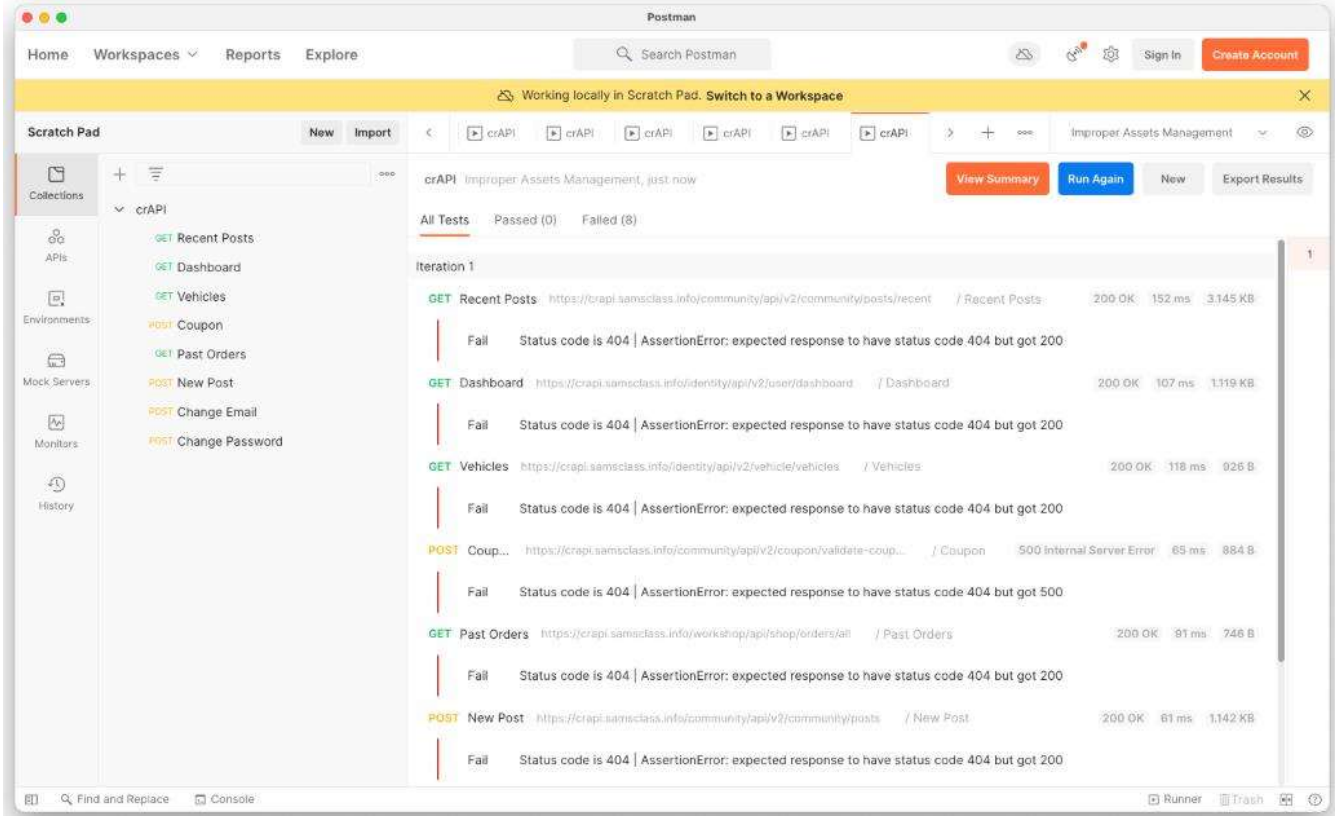


  - Trang RUN ORDER sẽ xuất hiện. Ở bên phải, đánh dấu vào "Save responses".

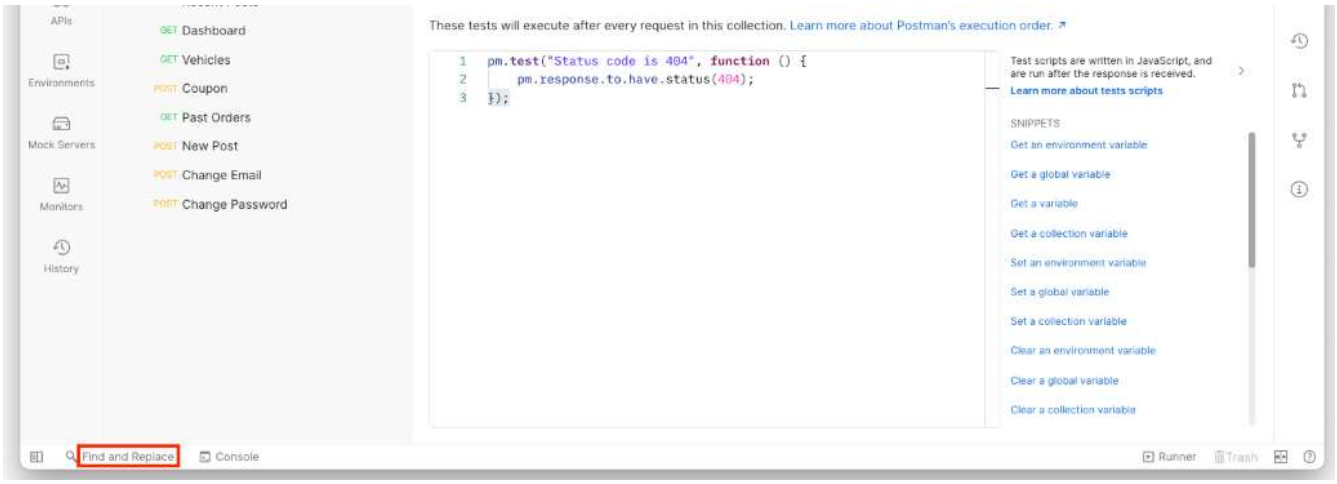


  - Nhấp vào nút "Run crAPI" màu xanh.

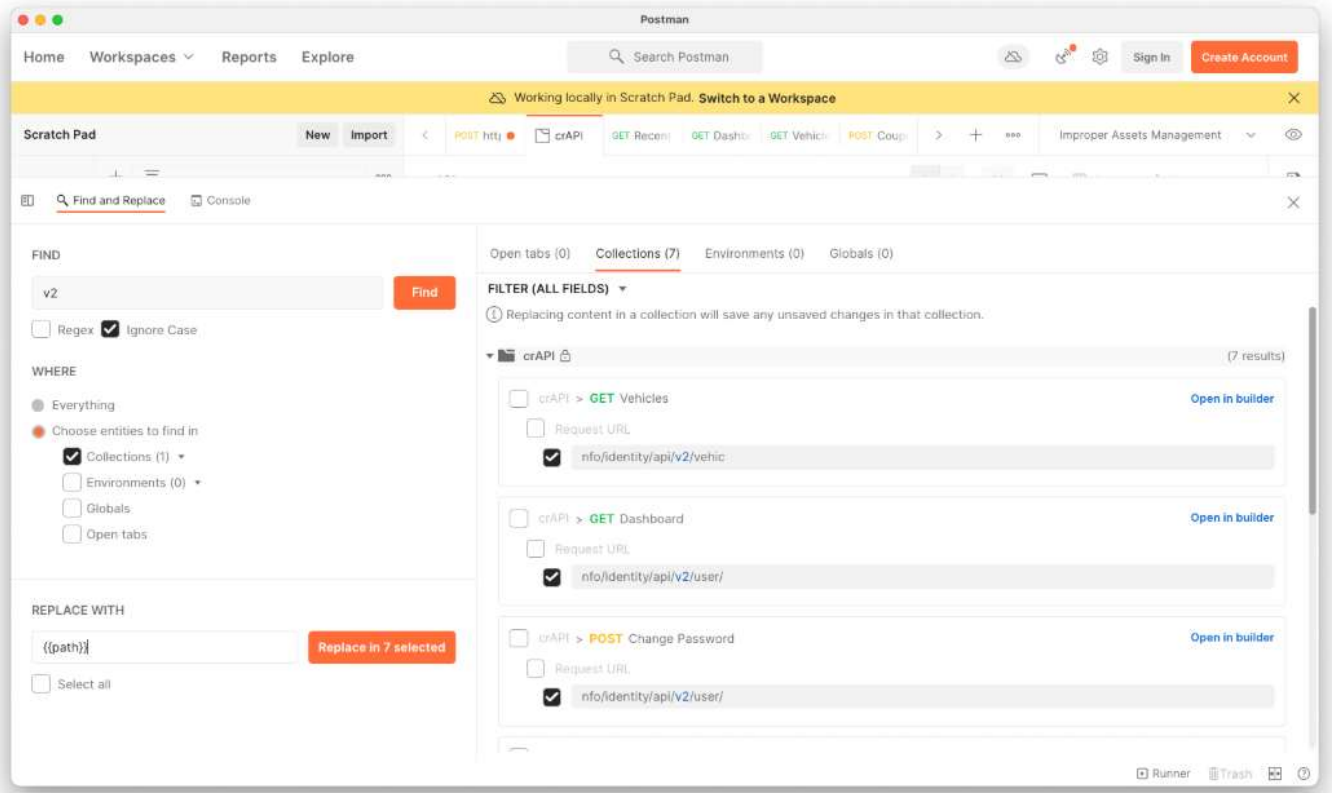
  - Bài kiểm tra sẽ thất bại cho tất cả các yêu cầu, điều này là bình thường vì chúng ta đang kiểm tra lỗi 404.



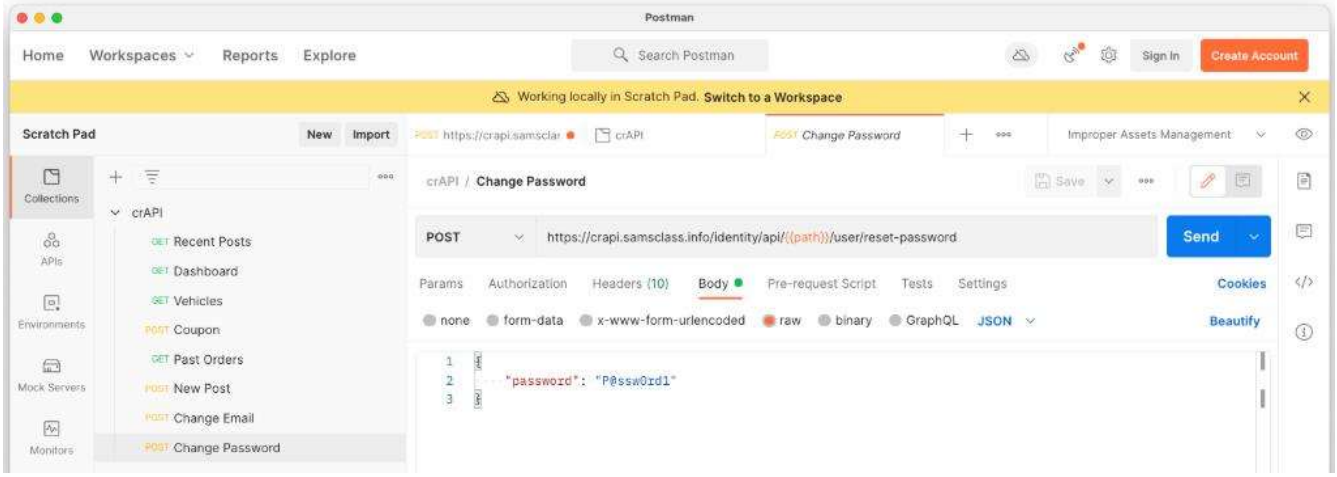
- **Khắc phục sự cố:** Nếu bộ sưu tập của bạn không chạy và bạn thấy lỗi như "No URL" hoặc "No Tests", hãy đảm bảo rằng bạn đã lưu tất cả các yêu cầu và bài kiểm tra.
- **Chèn biến:**
  - Ở góc dưới bên trái, nhấp vào "Find and Replace".



  - Sử dụng tính năng này để thay thế tất cả các trường hợp "v2" bằng biến `{{path}}`.



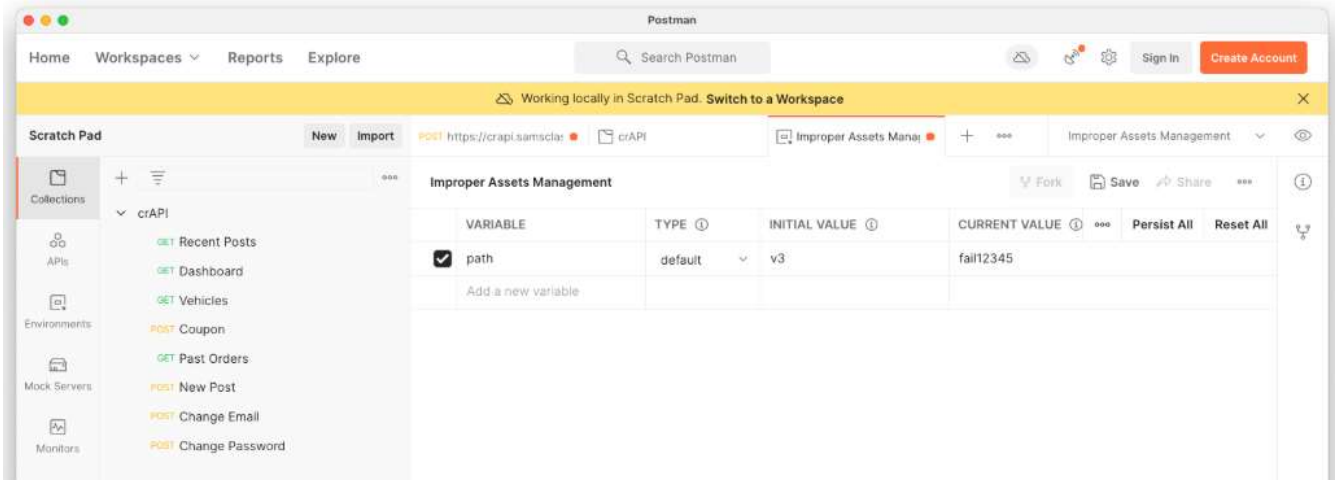
- **Kiểm tra kết quả:**
  - Đóng khung Find and Replace.Ở bên trái, nhấp vào từng yêu cầu (request) để kiểm tra xem thay đổi có hoạt động không.
  - Lưu ý: Tính năng Find and Replace đã bị lỗi. Nó chỉ thay đổi được một mục, sau đó không tìm thấy những mục còn lại.
  - Cách khắc phục: Đóng tất cả các tab thừa trong khu vực tab (ở khung giữa Postman). Sau đó, các yêu cầu có chứa "v2" đều hiển thị biến {{path}} như hình dưới.



- Tìm yêu cầu (request) có chứa "v3" trong URL và thay đổi thủ công nó thành `{{path}}`.

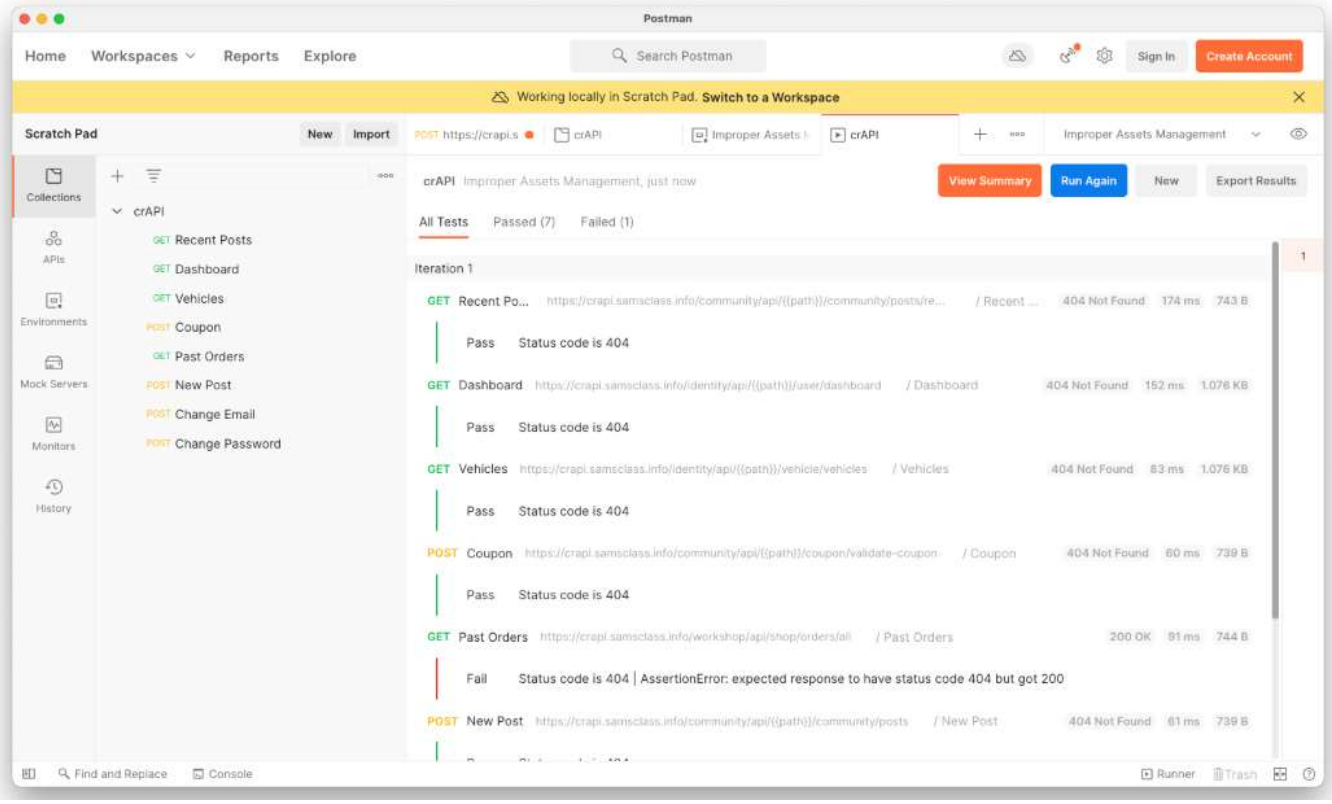
- **Chạy một bản quét lỗi (Fail Scan):**

  - Ở góc trên bên phải, nhấp vào biểu tượng hình con mắt.
  - Trong phần "Improper Assets Management", nhấp vào Edit.
  - Thay đổi CURRENT VALUE của biến path thành `fail12345`, như hình dưới đây.



  - Nhấp vào Save.
  - Trong Postman, ở bên trái, tại dòng crAPI, nhấp vào biểu tượng ba chấm, rồi chọn "Run collection".
  - Trang RUN ORDER sẽ xuất hiện. Ở bên phải, hãy đánh dấu chọn "Save responses".

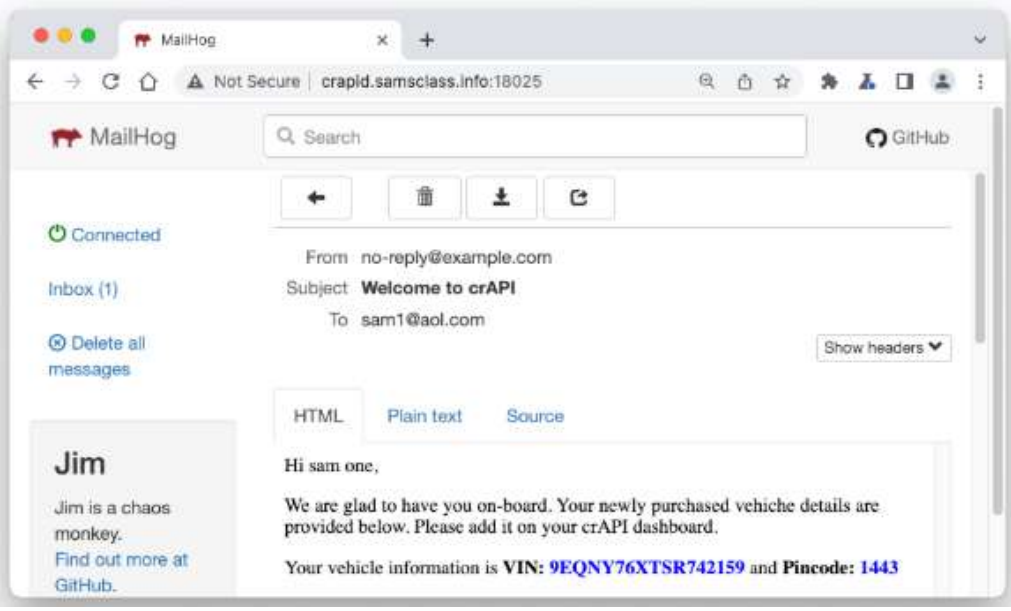
- Nhấp vào nút xanh "Run crAPI".
- Bài kiểm tra sẽ được đánh dấu là Pass cho tất cả các request có chứa số phiên bản, vì chúng trả về lỗi 404, như hình bên dưới.
- Điều này là bình thường, vì không có URL nào thực sự chứa chuỗi "fail12345".



BÀI 3: BOLA VÀ BFLA

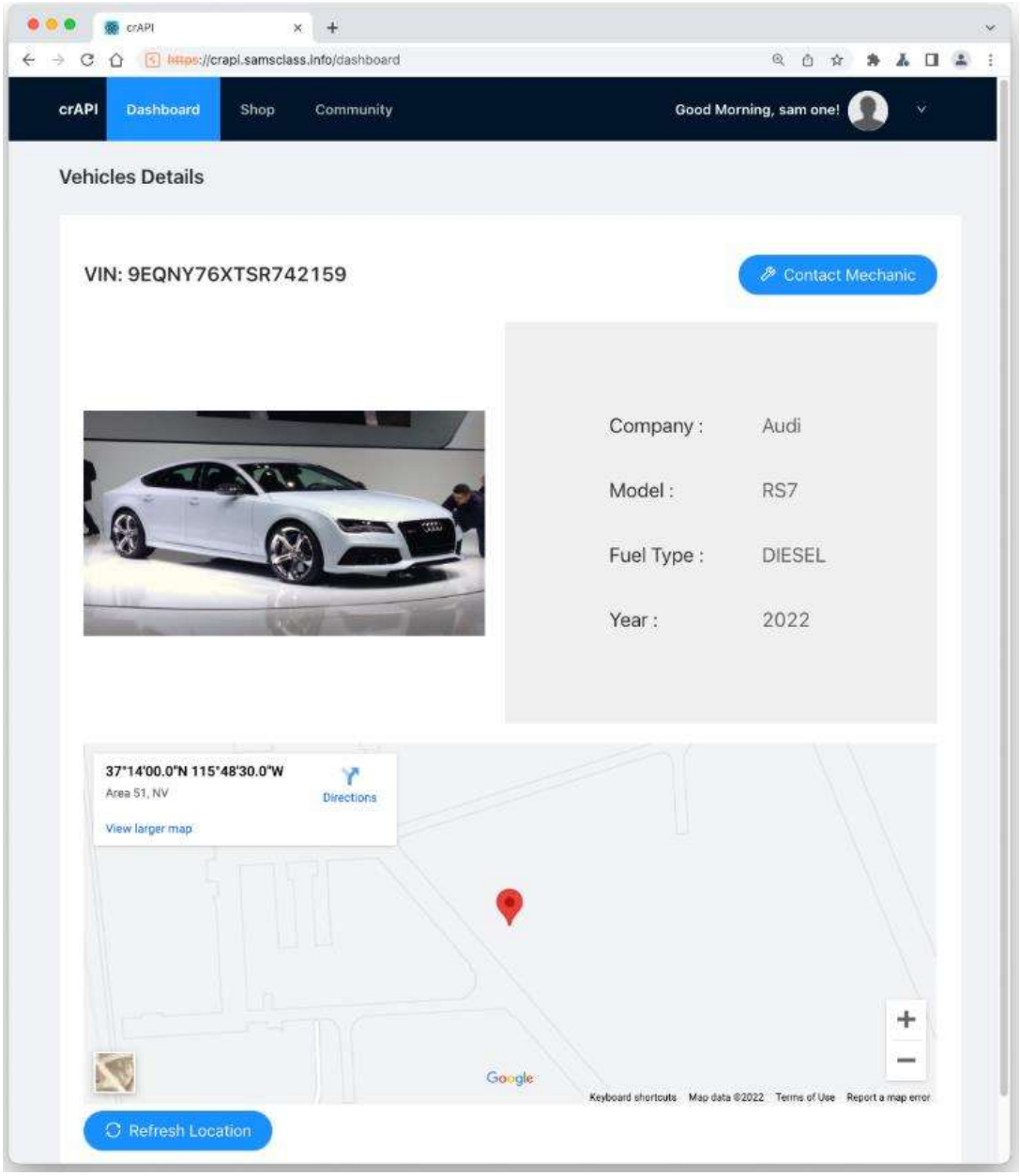
3.1 BROKEN OBJECT-LEVEL ACCESS (BOLA)

- **Phần mềm:** Burp Suite.
- **Mục tiêu:** Thêm nhiều yêu cầu vào bộ sưu tập crAPI và phát hiện lỗ hổng BOLA.
- **Kết nối đến crAPI:** Tương tự các bài tập trước.
- **Đăng nhập:** Tương tự các bài tập trước.
- **Đọc email của bạn:**
  - Mở trang:http://crAPId.samsclass.info:18025
  - Mở email gửi đến địa chỉ của bạn với tiêu đề "Welcome to crAPI".
  - Tìm VIN và Pincode của bạn.



- **Thêm một phương tiện:**
  - Ở góc trên bên phải, nhấn nút "+ Add a Vehicle".

- Nhập VIN và Pincode từ email của bạn, sau đó nhấn "Verify Vehicle Details".
- Nhấn OK. Trang chi tiết phương tiện sẽ mở ra.



- **Xác định vị trí phương tiện của bạn:**
  - Ở cuối trang chi tiết phương tiện, nhấn nút "Refresh Location". Bản đồ Google sẽ cập nhật với vị trí của phương tiện của bạn.Trong Burp, ở tab HTTP History, tìm yêu cầu sau:

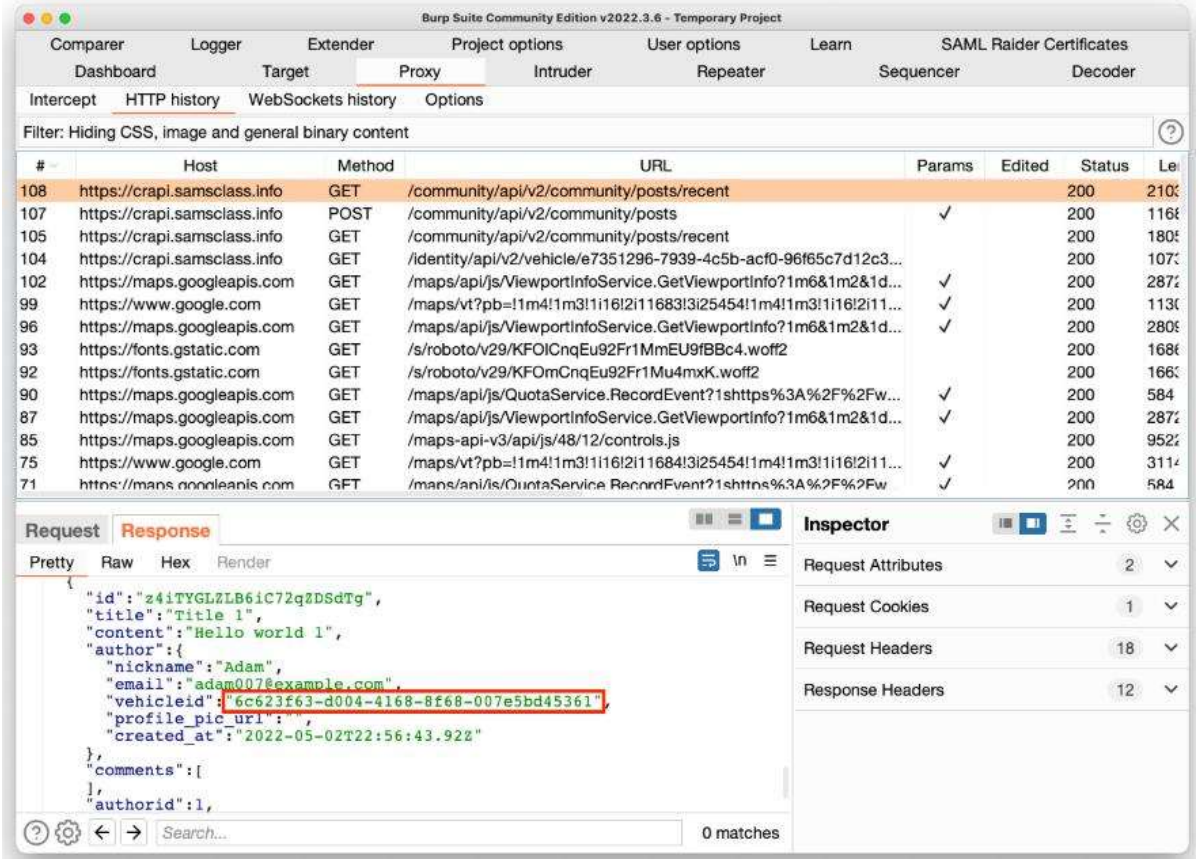
```
GET /identity/api/v2/vehicle/{vehicle_guid}/location
```

- Số GUID dài là mã định danh phương tiện của bạn và sẽ khác với ví dụ.Vị trí là dữ liệu nhạy cảm – bạn không nên được phép biết vị trí của phương tiện thuộc sở hữu của người khác.
- Nhấp chuột phải vào yêu cầu này và chọn "Send to Repeater".

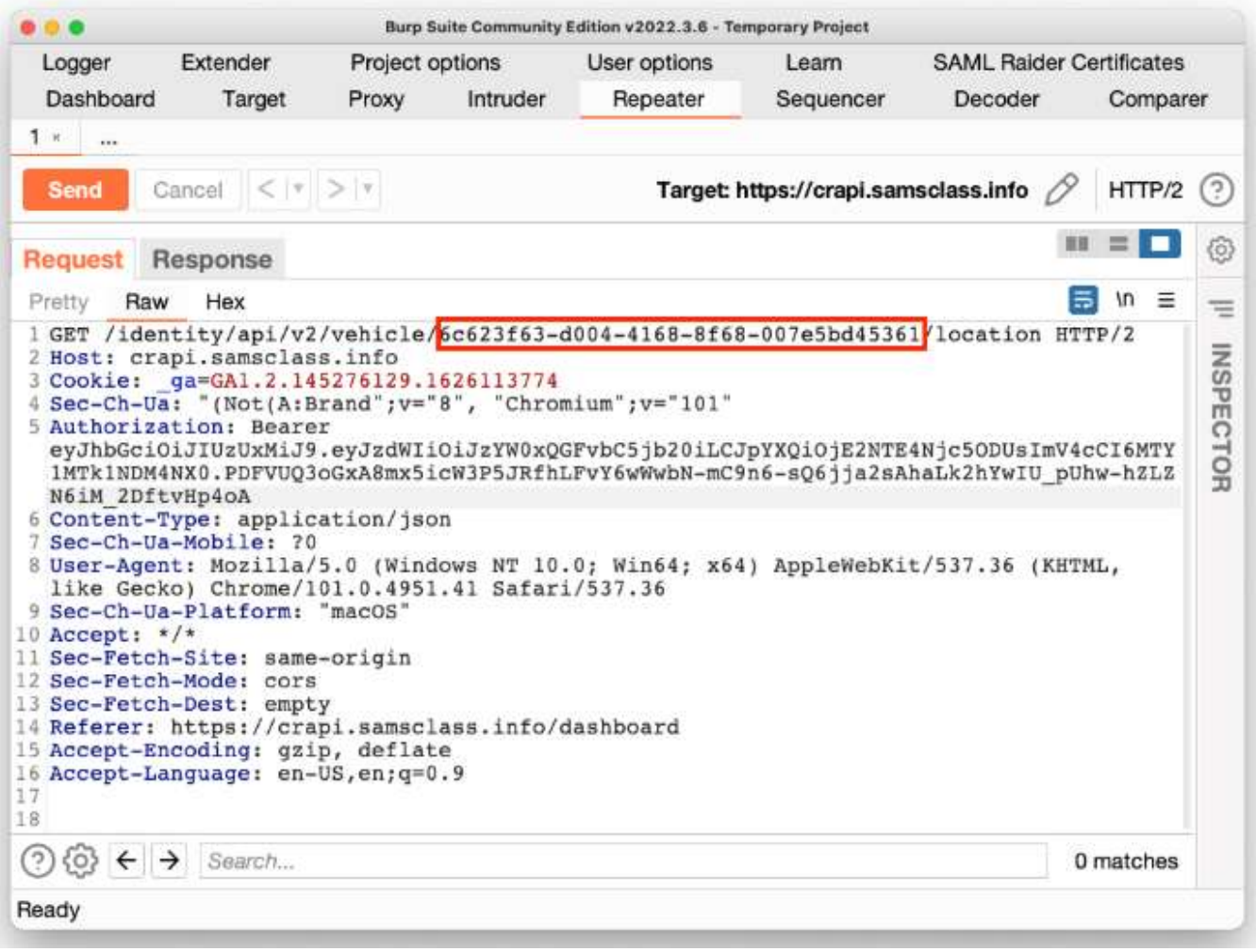
- **Đăng bài trong cộng đồng:**
  - Trong trình duyệt của Burp, ở phía trên, nhấn Community.
  - Nhấn nút "New Post", và thêm một bài viết mới. Một hộp thoại sẽ xuất hiện thông báo "Post Created". Nhấn OK.
- **Kiểm tra yêu cầu bài viết gần đây:**
  - Trong Burp, kiểm tra yêu cầu sau:

```
GET /community/api/v2/community/posts/recent
```

- Trong tab Response, cuộn xuống và tìm vehicleid của người khác.



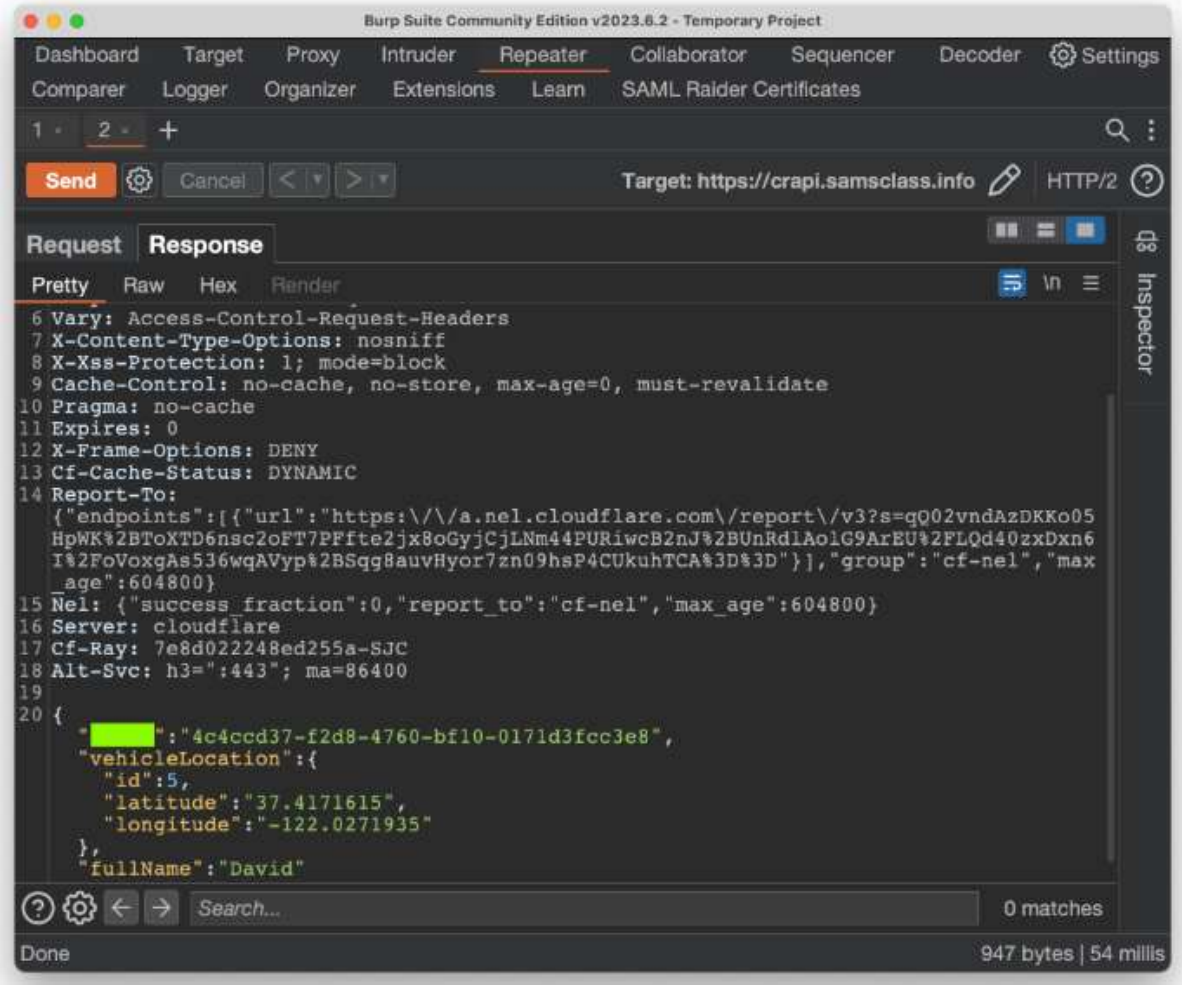
- **Lấy GUID khác:**
  - Trong Burp, ở tab Repeater, thay đổi vehicleid thành giá trị khác mà bạn đã tìm thấy.



  - Gửi yêu cầu.
  - Như được hiển thị, vị trí của phương tiện của người khác được trả về, cùng với tên của họ. Đây là một lỗ hổng BOLA!

- **Cờ AP 104.1 - Thông điệp:**

Gửi yêu cầu. Cờ được bao phủ bởi một hình chữ nhật màu xanh lá cây trong hình ảnh dưới đây.

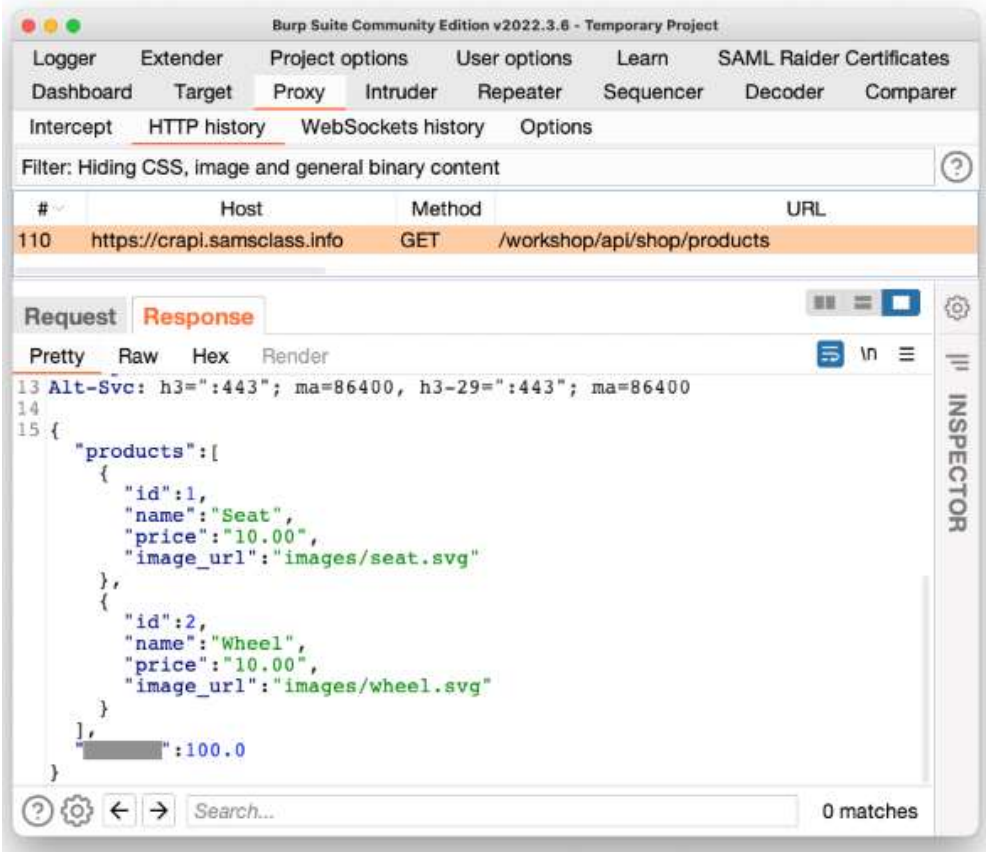


3.2 BROKEN FUNCTION-LEVEL ACCESS (BFLA)

- **Phần mềm:** Burp Suite.
- **Mục tiêu:** Thêm nhiều yêu cầu vào bộ sưu tập crAPI và phát hiện lỗ hổng BOLA.
- **Kết nối đến crAPI:** Tương tự các bài tập trước.
- **Đăng nhập:** Tương tự các bài tập trước.
- **Xem cửa hàng:**
  - Ở đầu trang crAPI, nhấn Shop.
  - Trong Burp, ở tab HTTP History, tìm yêu cầu sau:

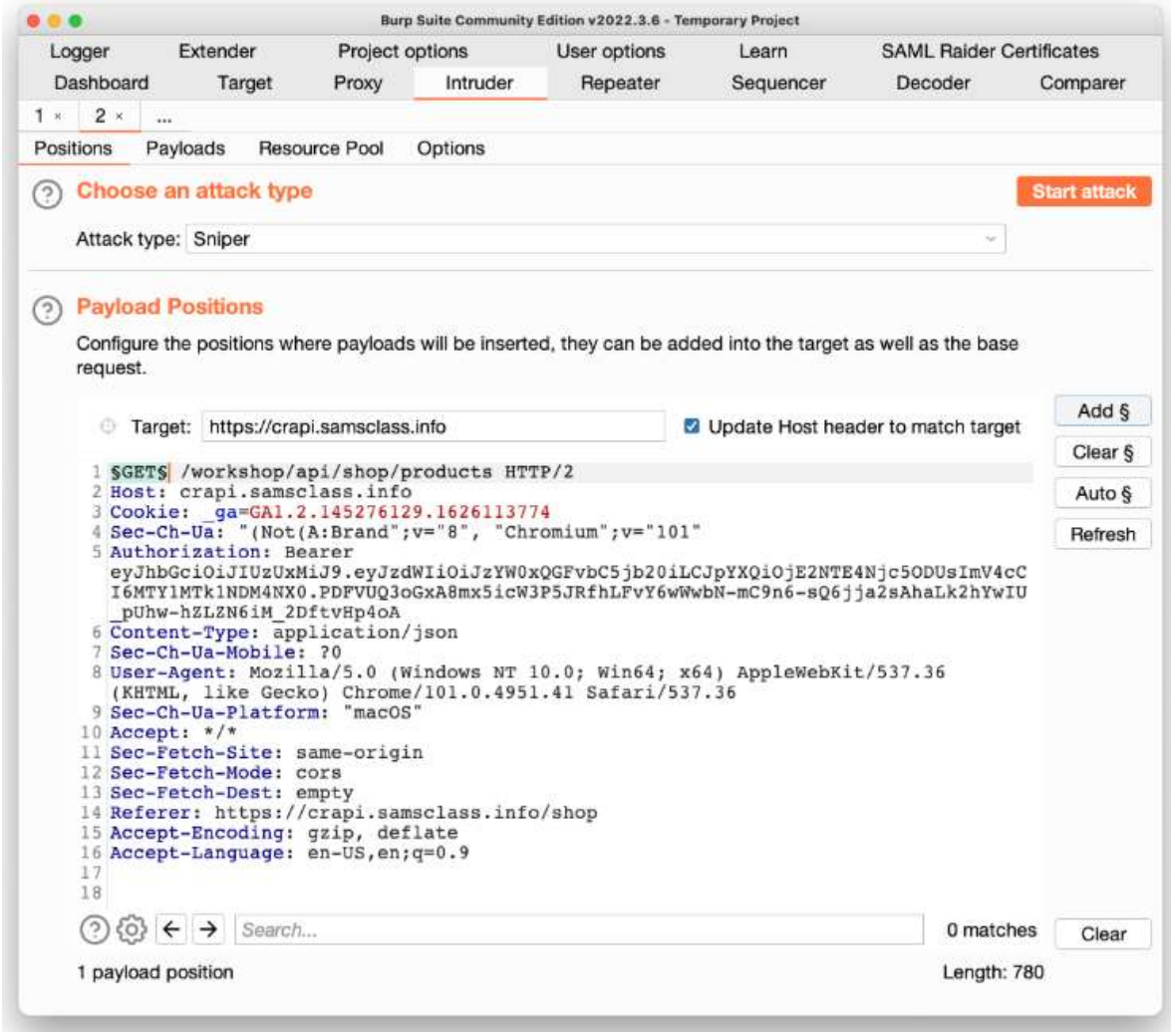
```
GET /workshop/api/shop/products
```

  - Phản hồi sẽ hiển thị các sản phẩm đang bán cùng với giá của chúng.



- Một khách hàng chỉ nên có quyền xem các sản phẩm, không được thêm hoặc thay đổi chúng. Những chức năng đó nên được giới hạn cho quản trị viên.
- Hãy kiểm tra xem hạn chế đó có được thực thi không.
- Nhấp chuột phải vào yêu cầu này và chọn "Send to Intruder".

- **Kiểm tra tất cả các phương thức:**
  - Chúng ta không thể thay đổi dữ liệu với yêu cầu GET. Điều đó sẽ yêu cầu một phương thức khác như POST hoặc PUT. Hãy xem những phương thức nào được phép.
  - Chọn tab Intruder. Nhấn nút "Clear §".
  - Tô sáng phương thức GET và nhấn nút "Add §".
  - Cửa sổ của bạn sẽ trông giống như hình dưới đây.



- Chọn tab Payloads. Sao chép danh sách payloads sau và dán vào hộp Payload Options:

```
PUT

POST

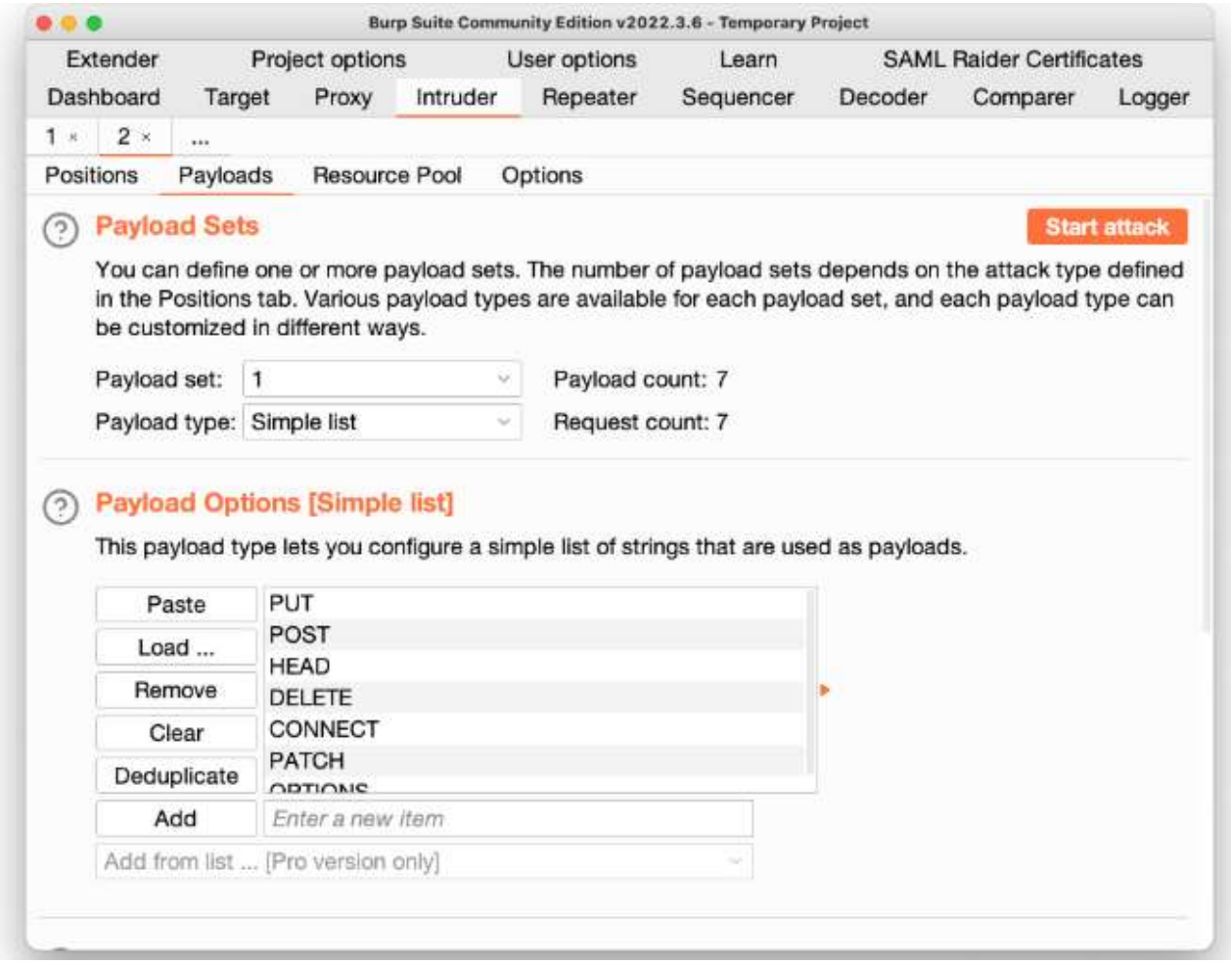
HEAD

DELETE

CONNECT

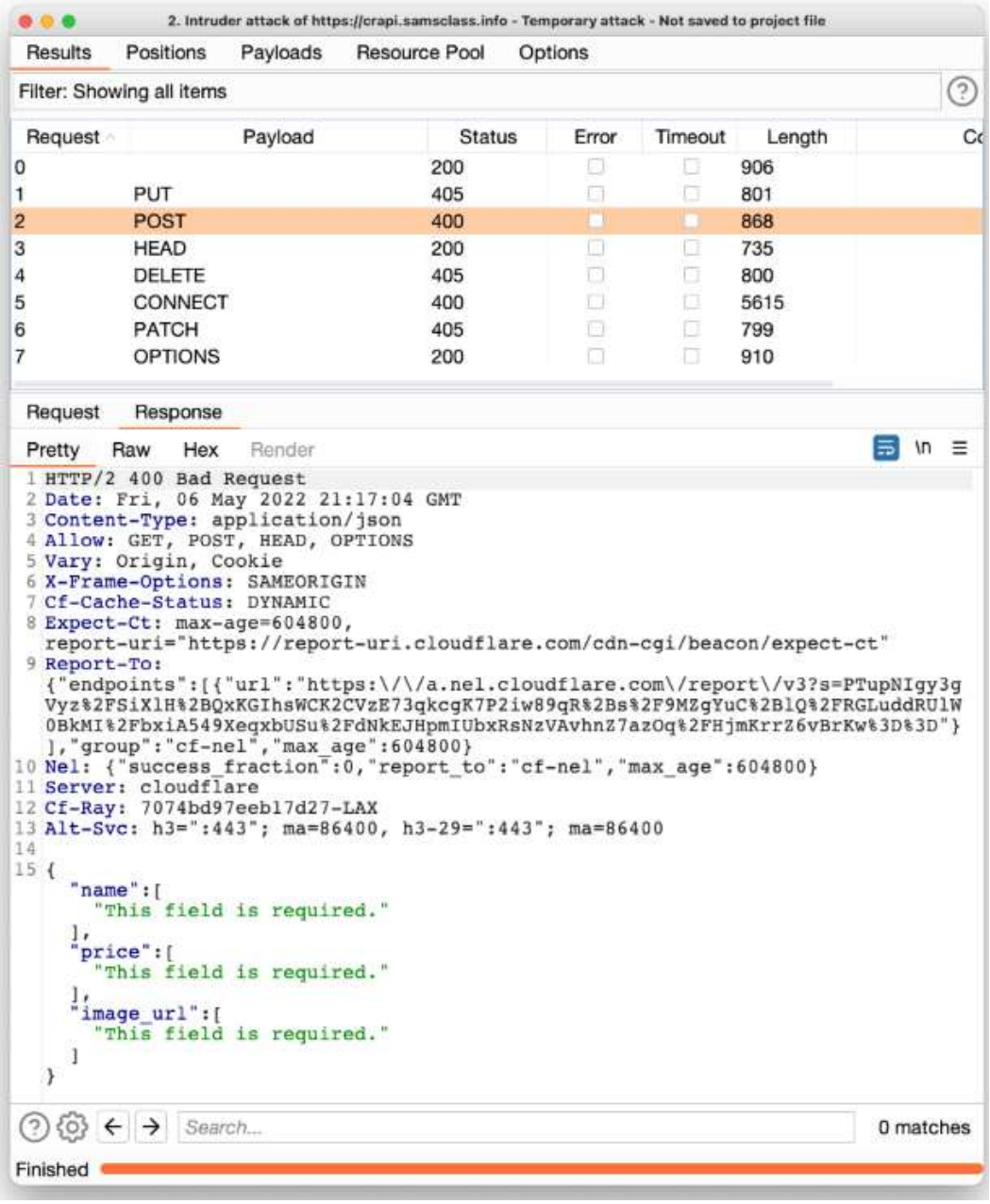
PATCH

OPTIONS
```



- Ở góc trên bên phải, nhấn nút "Start Attack". Nhấn OK.
- Burp sẽ mở một cửa sổ mới và thực hiện cuộc tấn công.
- Các phản hồi sẽ hiển thị nhiều loại phản hồi khác nhau.
- Kiểm tra từng phản hồi và xác minh rằng chúng khớp với bảng dưới đây:
  - PUT: không được phép
  - POST: yêu cầu các trường
  - HEAD: 200 OK
  - DELETE: không được phép
  - CONNECT: Yêu cầu không hợp lệ từ Cloudflare
  - PATCH: không được phép
  - OPTIONS: 200 OK

- HEAD và OPTIONS hoạt động, nhưng chúng chỉ truy xuất dữ liệu từ máy chủ, không gửi dữ liệu. Kết quả thú vị duy nhất là từ POST. Nó cho biết yêu cầu các trường, như hình dưới đây.

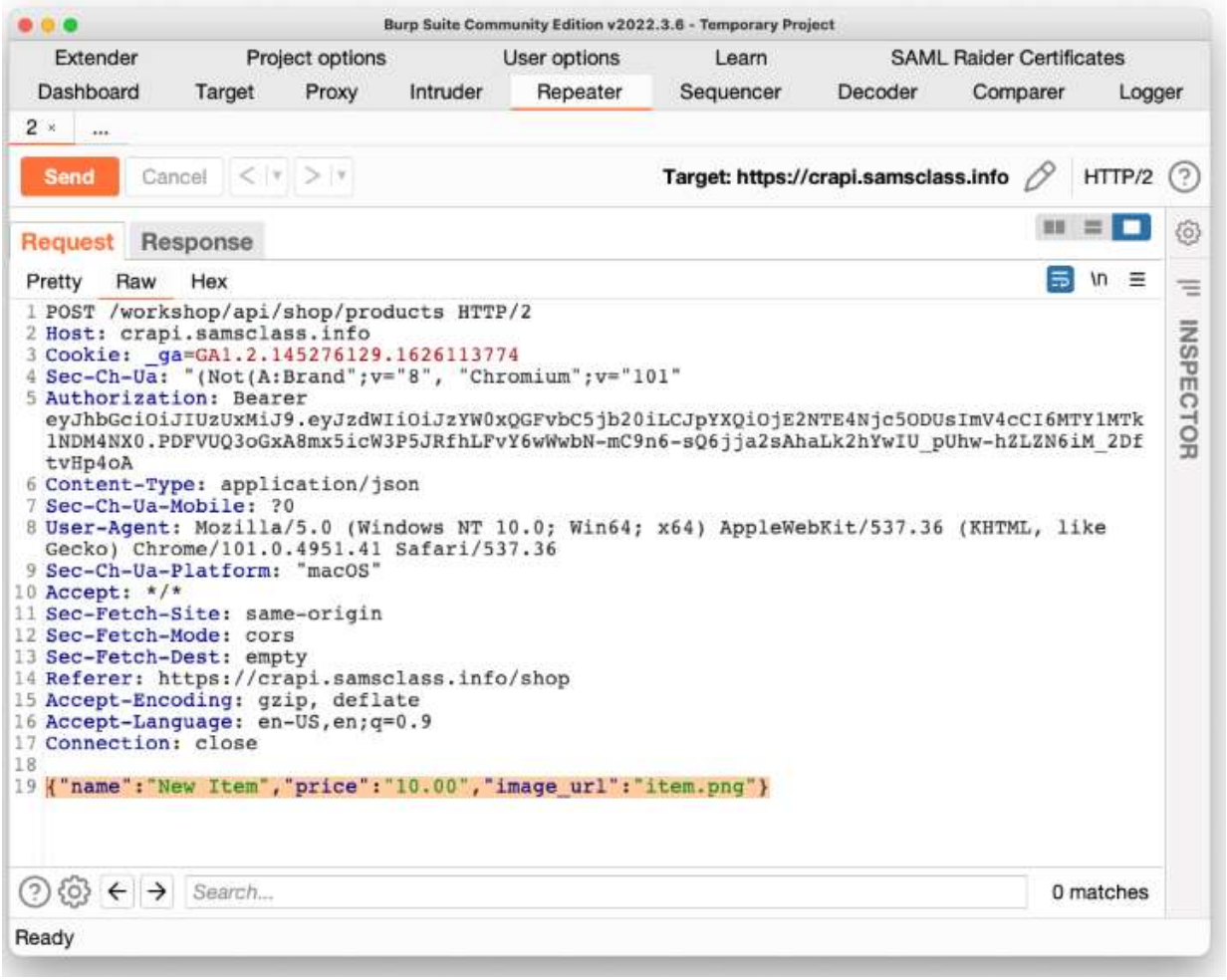


- Phương thức POST lẽ ra nên bị cấm, nhưng không phải vậy. Điều này cho thấy chúng ta có thể tải lên dữ liệu!

- **Thêm một mặt hàng:**

- Trong cửa sổ "Intruder attack" của Burp, nhấp chuột phải vào dòng POST và chọn "Send to Repeater".

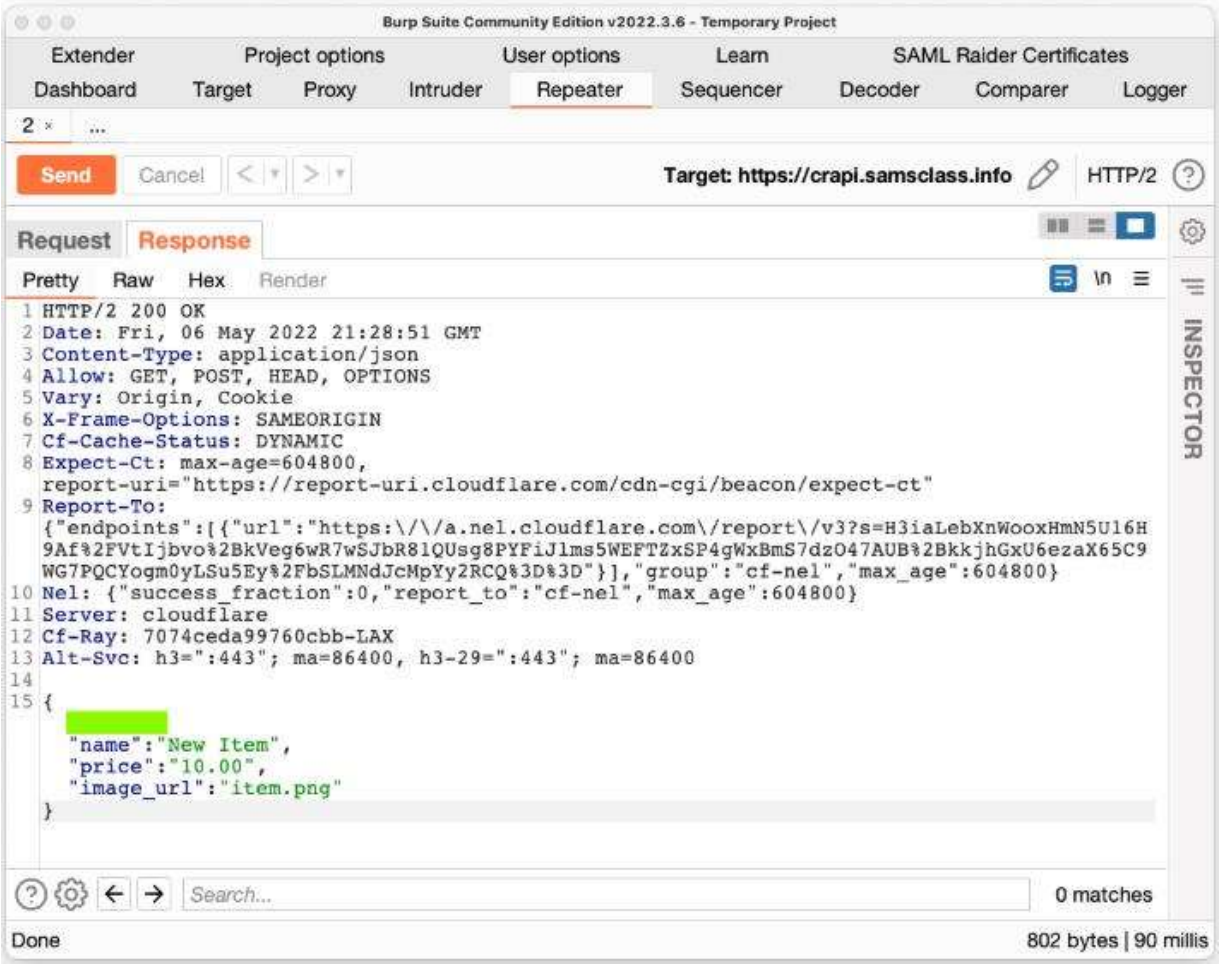
- Thêm một dòng JSON với các tham số cần thiết, như được đánh dấu trong hình dưới đây (Khuyến nghị bao gồm tên của bạn trong tên mặt hàng để bạn có thể phân biệt mặt hàng của mình với những mặt hàng do sinh viên khác thêm vào).



- Gửi yêu cầu.
- Nhấn tab Response. Trạng thái là "200 OK”.

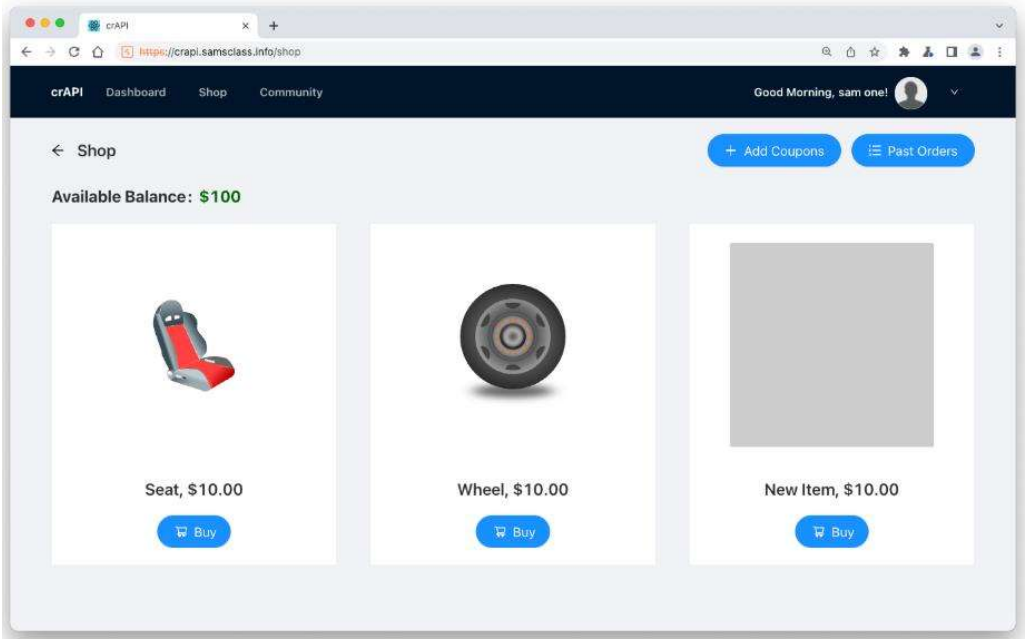
- **Cờ AP 105.1 – Field:**

- Cờ được bao phủ bởi một hình chữ nhật màu xanh lá cây trong hình dưới đây.

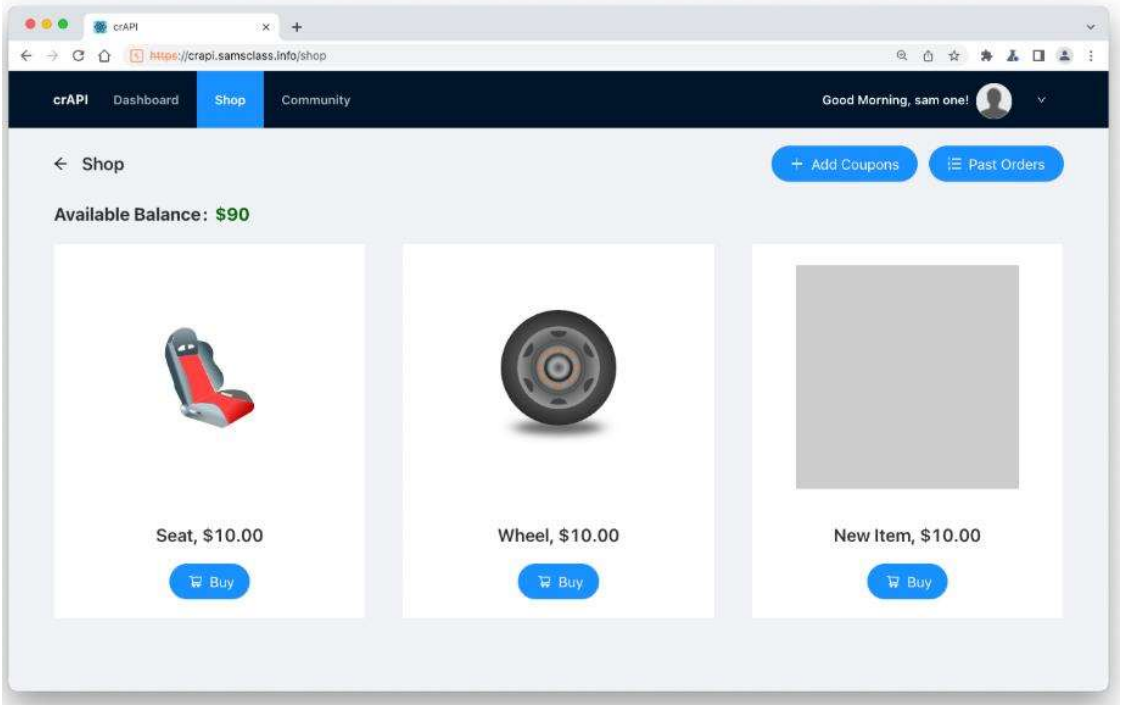


- **Mua một mặt hàng:**

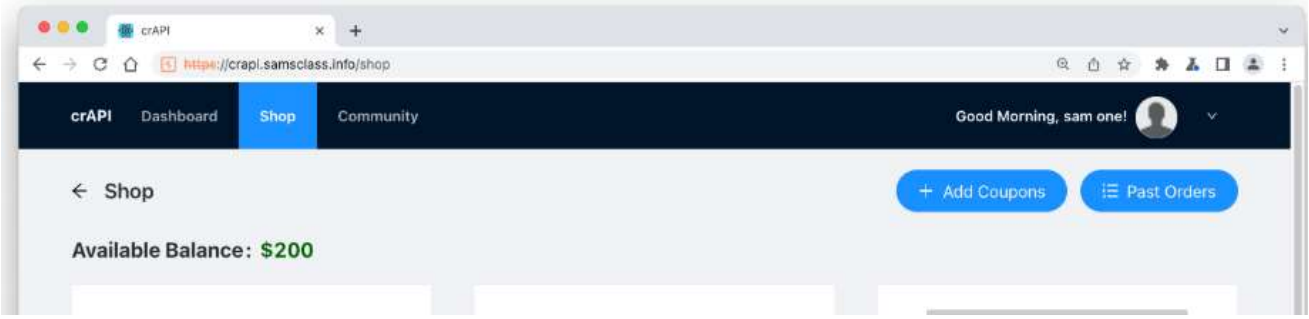
  - Trong trình duyệt của Burp, làm mới trang Shop.Mặt hàng mới sẽ xuất hiện.



- Lưu ý rằng số dư khả dụng của bạn, ở góc trên bên trái, là $100.Trong phần của mặt hàng mới, nhấn Buy. Nhấn OK.
- Ở đầu trang, nhấn Shop.Số dư khả dụng của bạn đã giảm xuống còn $90, như hình dưới đây.



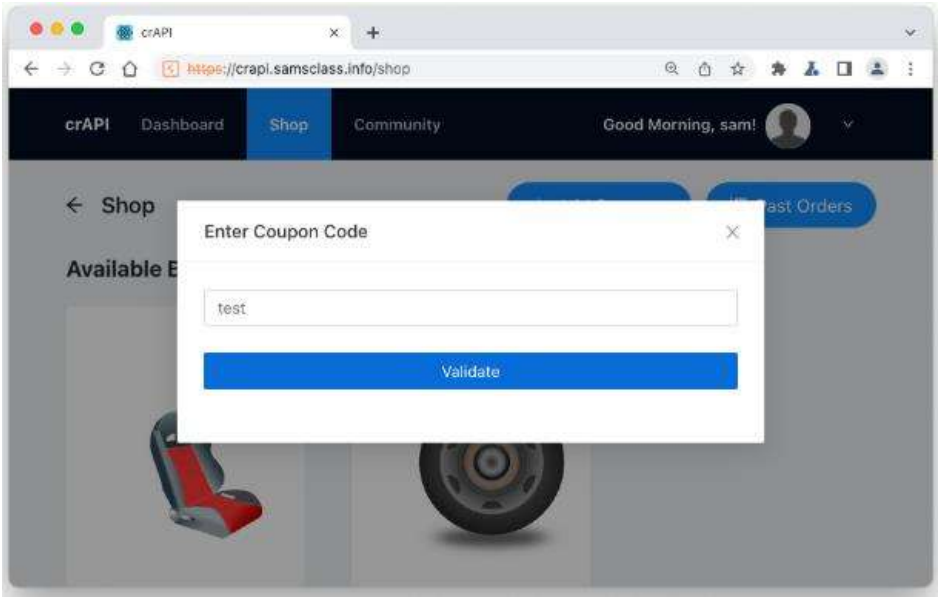
- **Thêm một mặt hàng GIFT:**
  - Gửi một yêu cầu POST khác để tạo một mặt hàng có tên GIFT với giá -110.00.
  - Mua mặt hàng GIFT, để số dư khả dụng của bạn bây giờ là $200, như hình dưới đây.



BÀI 4: NOSQL INJECTION, crAPI

4.1 TẤN CÔNG NOSQL INJECTION

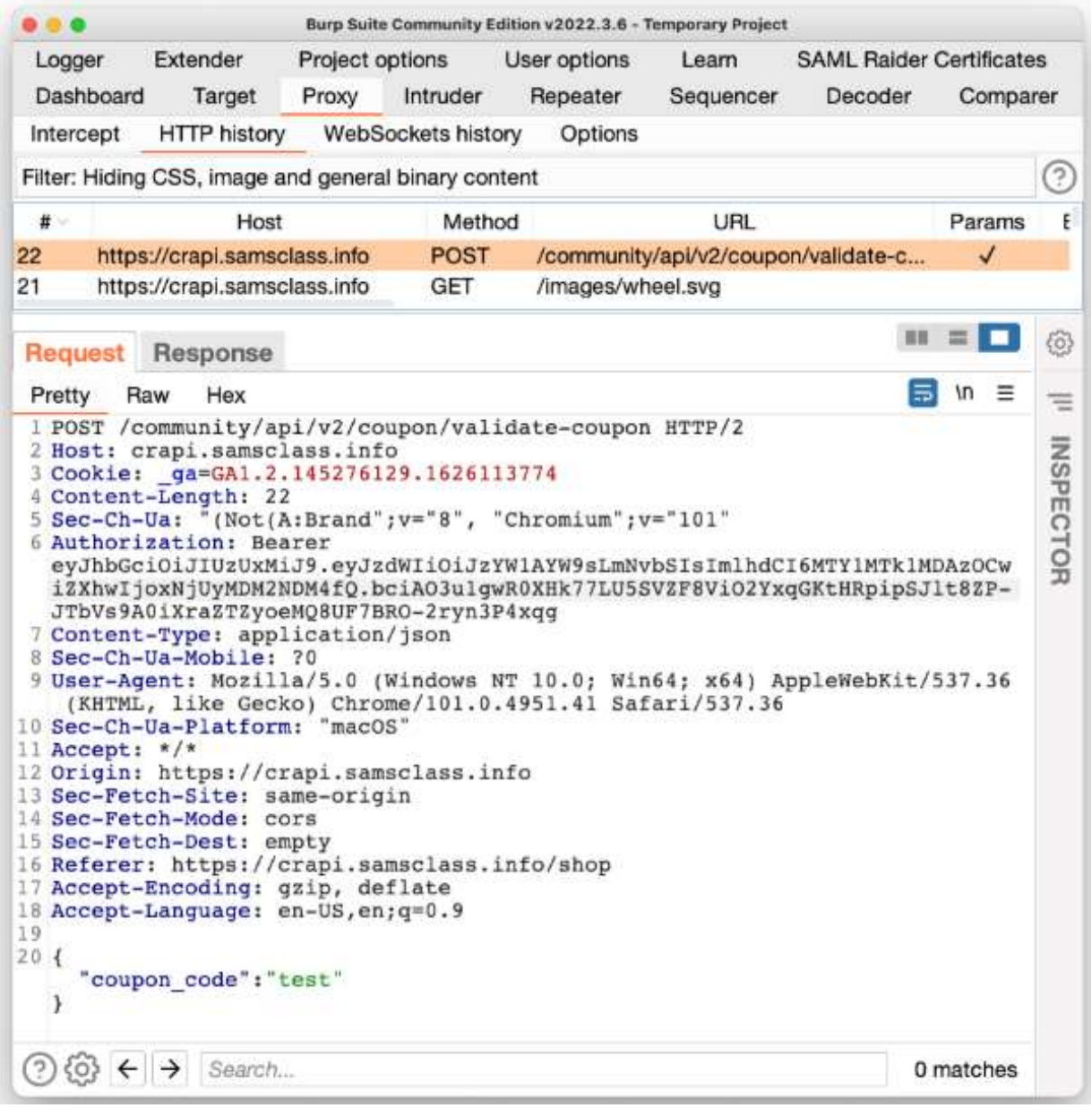
- **Phần mềm:** Burp Suite.
- **Mục tiêu:** Giả mạo mã giảm giá (coupon) thông qua lỗ hổng NoSQL Injection.
- **Kết nối đến crAPI:** Tương tự các bài tập trước.
- **Đăng nhập:** Tương tự các bài tập trước.
- **Xem cửa hàng:**
  - Ở đầu trang crAPI, nhấn Shop.
  - Ở góc trên bên phải, nhấn "Add Coupon".
  - Trong hộp "Enter Coupon Code", nhập một vài ký tự bất kỳ và nhấn “Validate”.



  - Trong Burp, ở tab HTTP History, tìm yêu cầu sau:

```
POST /community/api/v2/coupon/validate-coupon
```

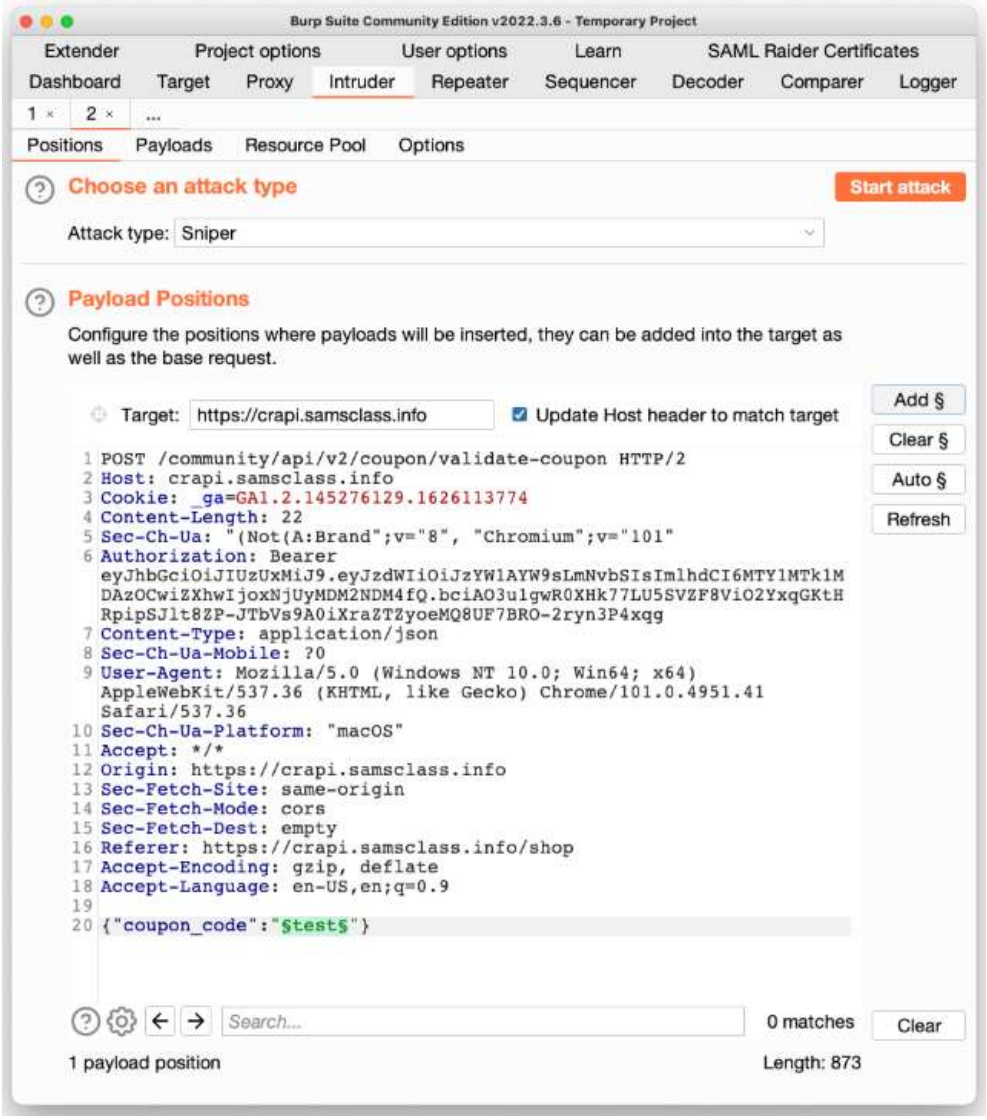
  - Yêu cầu này chỉ chứa một tham số JSON duy nhất.



- Nhấp chuột phải vào yêu cầu này và chọn "Send to Intruder".

- **Kiểm tra các payloads tấn công:**

  - Chọn tab Intruder.Nhấn nút "Clear §".
  - Tô sáng giá trị của coupon_code và nhấn nút "Add §".
  - Cửa sổ của bạn sẽ trông giống như hình dưới đây.



- Chọn tab Payloads.Sao chép danh sách payloads sau và dán vào hộp Payload Options:

```
'

''

;%00

--

-- -

""

;

' OR '1
```

```
' OR 1 -- -

" OR "" = "

" OR 1 = 1 -- -

' OR '' = '

OR 1=1

$gt

{"$gt":""}

{"$gt":-1}

$ne

{"$ne":""}

{"$ne":-1}

$nin

{"$nin":1}

{"$nin":[1]}

|| '1'=='1

//

||'a'\\'a

'||'1'=='1';//

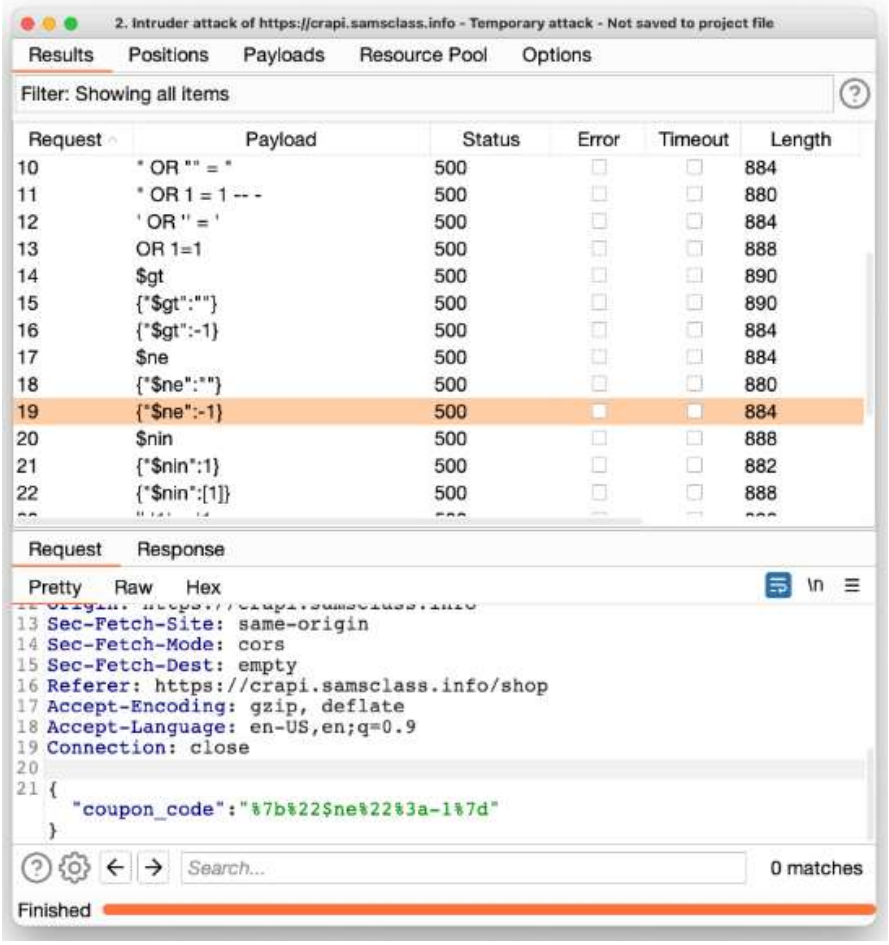
'/{}:

'"\;{}

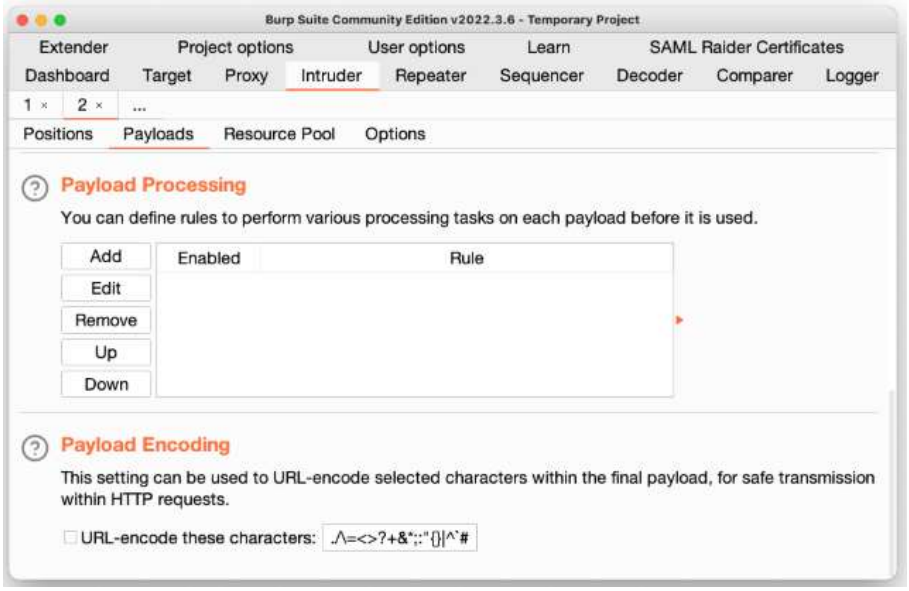
'"\/$[].>

{"$where":  "sleep(1000)"}
```

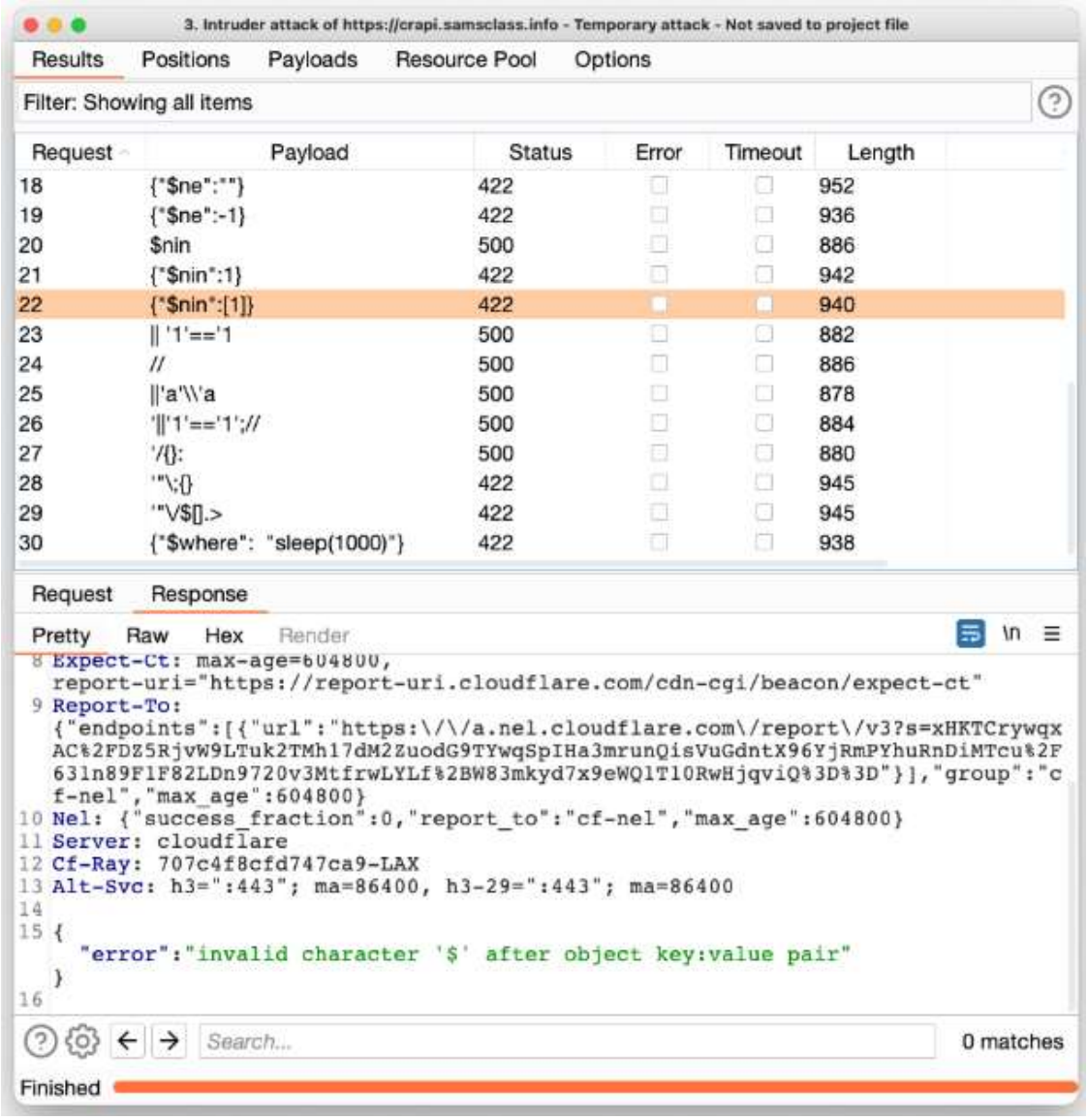
- Ở góc trên bên phải, nhấn nút "Start Attack". Nhấn OK.
- Burp sẽ mở một cửa sổ mới và thực hiện cuộc tấn công.
- Các phản hồi đều có trạng thái 500, điều này cho thấy các payloads đang bị mã hóa URL, có thể ngăn chặn tấn công.



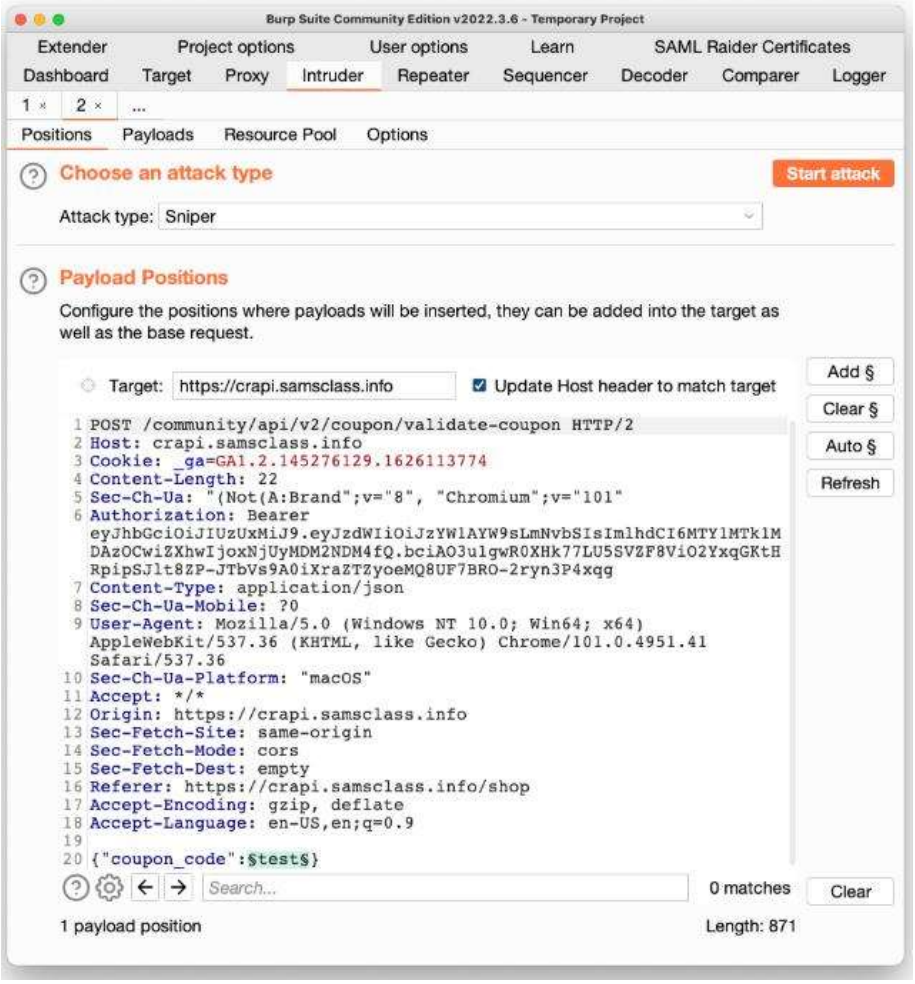
- **Loại bỏ mã hóa URL:**
  - Đóng cửa sổ "Intruder attack". Trên tab Intruder, chọn tab Payloads.
  - Cuộn xuống dưới và bỏ chọn hộp "URL-encode these characters...".



- Thực hiện lại cuộc tấn công.
- Bây giờ, máy chủ phản hồi với một số trạng thái 422: "invalid character...", điều này cho thấy tiến triển.



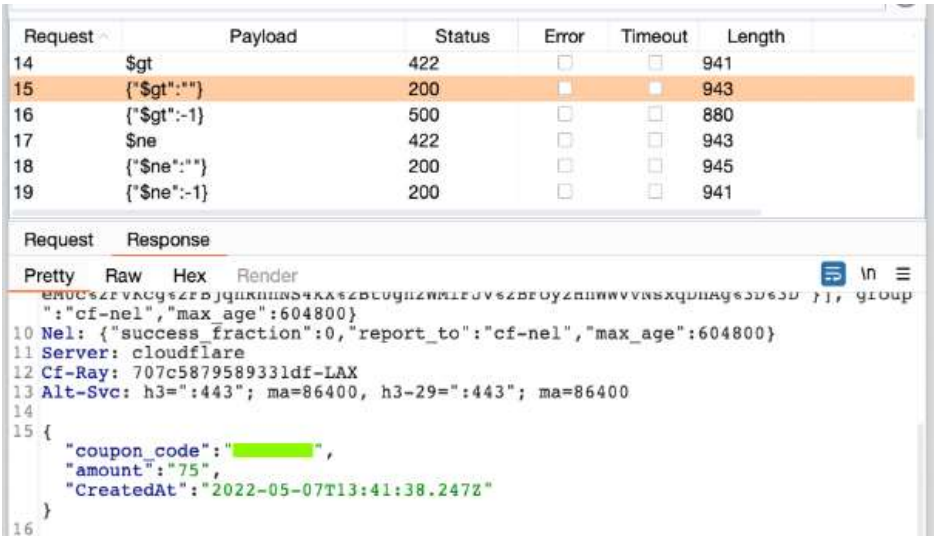
- **Loại bỏ dấu ngoặc kép:**
  - Đóng cửa sổ "Intruder attack".
  - Trên tab Intruder, chọn tab Positions.
  - Ở phần dưới, loại bỏ dấu ngoặc kép xung quanh payload, như hình dưới đây.



- Thực hiện lại cuộc tấn công. Một số payloads thành công với trạng thái 200.

- **Cờ AP 106.1 - coupon_code:**

Cờ được bao phủ bởi một hình chữ nhật màu xanh lá cây trong hình dưới đây.



4.2 CÀI ĐẶT CRAPI

- **Yêu cầu:** Máy chủ Ubuntu 18.04
- **Mục tiêu:** Tự thiết lập máy chủ crAPI để phục vụ cho việc huấn luyện bảo mật.
- **Cài đặt Docker:** Thực hiện các lệnh sau:

```
sudo apt update
sudo apt-get install \
    ca-certificates \
    curl \
    gnupg \
    lsb-release
curl -fsSL https://download.docker.com/linux/debian/gpg | sudo gpg --dearmor -o /usr/share/keyrings/docker-archive-keyring.gpg
echo \
  "deb [arch=$(dpkg --print-architecture) signed-by=/usr/share/keyrings/docker-archive-keyring.gpg] https://download.docker.com/linux/debian \
  $(lsb_release -cs) stable" | sudo tee /etc/apt/sources.list.d/docker.list > /dev/null
```

Lưu ý: Tập lệnh trên sẽ nhận diện hệ điều hành là Debian. Để khắc phục, chỉnh sửa tệp cấu hình:

```
sudo nano /etc/apt/sources.list.d/docker.list
```

Trong nano, thay "debian" bằng "ubuntu" như sau:

```
deb [arch=amd64 signed-by=/usr/share/keyrings/docker-archive-keyring.gpg] https://download.docker.com/linux/ubuntu bionic stable
```

Nhấn Ctrl+X, Y, Enter để lưu tệp. Sau đó, thực hiện các lệnh:

```
sudo apt update
sudo apt install docker-ce docker-ce-cli containerd.io docker-compose-plugin
```

Phiên bản docker-compose trong kho lưu trữ quá cũ. Thực hiện các lệnh sau để cài đặt phiên bản mới hơn:

```
sudo curl -SL
https://github.com/docker/compose/releases/download/v2.4.1/docker-
compose-linux-x86_64 -o /usr/local/bin/docker-compose

sudo chmod +x /usr/local/bin/docker-compose
```

Bây giờ khởi động Docker và thiết lập để tự động khởi động khi reboot:

```
sudo systemctl start docker

sudo systemctl enable docker.service

sudo systemctl enable containerd.service
```

- **Cài đặt crAPI:** Thực hiện các lệnh sau:

```
git clone https://github.com/OWASP/crAPI.git

cd crAPI

sudo deploy/docker/build-all.sh
```

- **Tạo tập lệnh khởi động:** Thực hiện lệnh:

```
sudo nano /usr/local/bin/start_crapi
```

Nhập nội dung sau vào nano, thay "/root" bằng thư mục bạn đã sử dụng để clone crAPI:

```
#!/bin/bash

/usr/local/bin/docker-compose -f /root/crAPI/deploy/docker/docker-
compose.yml --compatibility up -d
```

- **Lưu tệp và đặt quyền thực thi:**

```
sudo chmod a+x /usr/local/bin/start_crapi
```

- **Chuyển tiếp cổng:** crAPI chỉ lắng nghe trên localhost. Để máy chủ có thể truy cập từ bên ngoài, cần sử dụng socat. Cài đặt với lệnh:

```
sudo apt install socat
```

- **Chuẩn bị Crontab:**

Thiết lập để mọi thứ khởi động khi reboot. Trước tiên, chuyển sang người dùng root:

```
sudo su -

crontab -e
```

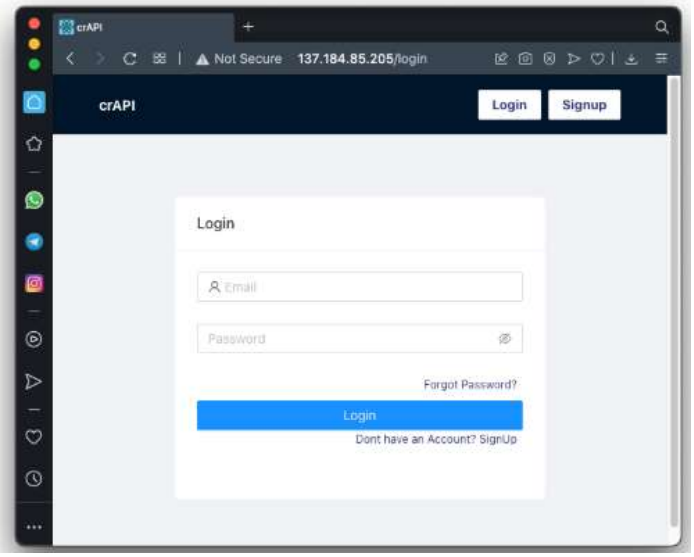
- Thêm các dòng sau vào crontab:

```
@reboot socat tcp-listen:80,reuseaddr,fork tcp:localhost:8888 &

@reboot socat tcp-listen:18025,reuseaddr,fork tcp:localhost:8025 &

@reboot /usr/local/bin/start_crapi
```

- Lưu tệp và reboot máy chủ. Mất vài phút để crAPI khởi động.
- Để kiểm tra, mở địa chỉ IP của máy chủ trong trình duyệt web. Bạn sẽ thấy trang đăng nhập crAPI.



- **Cờ AP 110.1 – Netstat:**

- Trên máy chủ của bạn, thực hiện lệnh:

```
sudo netstat -pant
```

- Cờ được hiển thị trong kết quả của lệnh trên.

BÀI 5: OWASP ZAP QUÉT LỖ HỔNG API

5.1 CÀI ĐẶT VULNERABLE API

- Mở terminal và chạy các lệnh sau:

```
cd
git clone https://github.com/jorritfolmer/vulnerable-api.git
sudo apt update
sudo apt install virtualenv
virtualenv venv
source venv/bin/activate
cd vulnerable-api
pip install -r requirements.txt
python ./vAPI.py -p 8080
```



- Mở trình duyệt web và truy cập địa chỉ IP của máy Debian của bạn với cổng 8080.



- Khởi động lại Vulnerable API: Nếu tắt máy chủ, có thể khởi động lại bằng lệnh:

```
cd

virtualenv venv

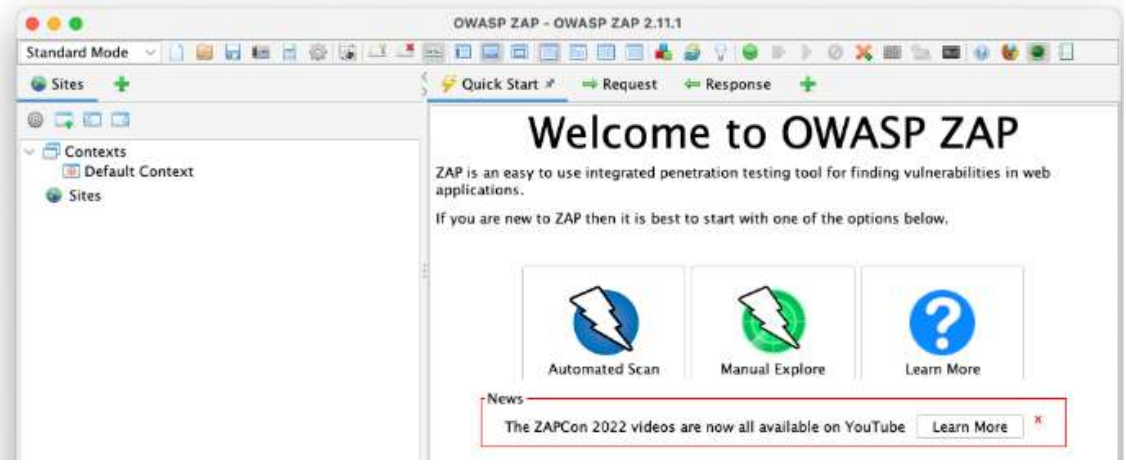
source venv/bin/activate

cd vulnerable-api

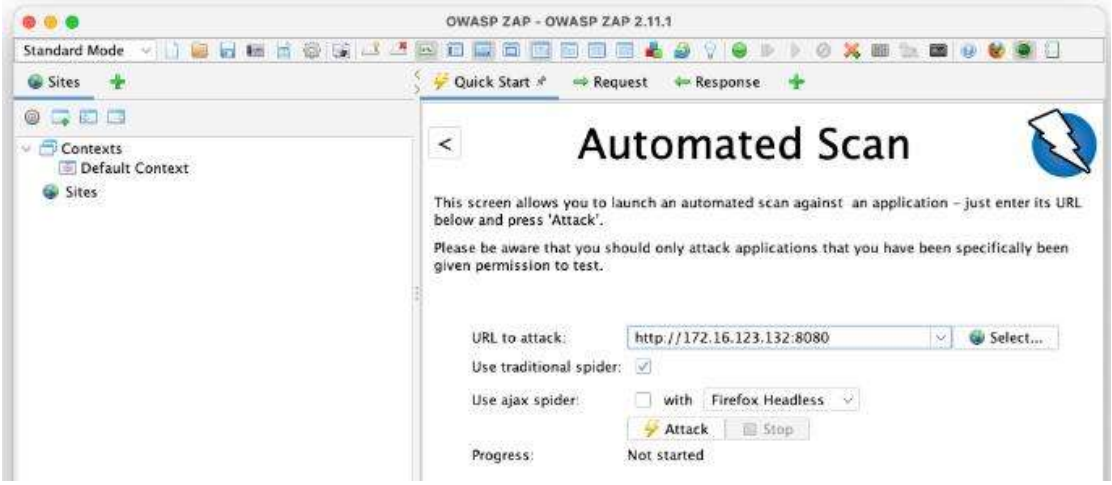
python ./vAPI.py -p 8080
```

5.2 CÀI ĐẶT ZAP

- Tải ZAP từ: https://www.zaproxy.org/download/
- Từ trang chính của ZAP, nhấp vào "Automated Scan".



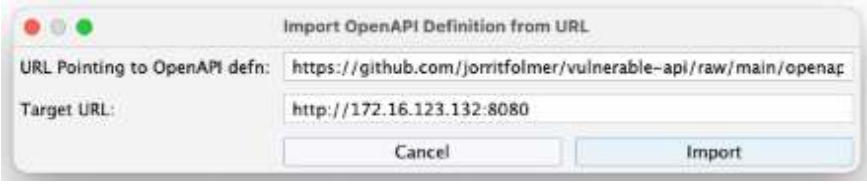
- Nhập URL của Vulnerable API của bạn. Nhấp vào "Attack".



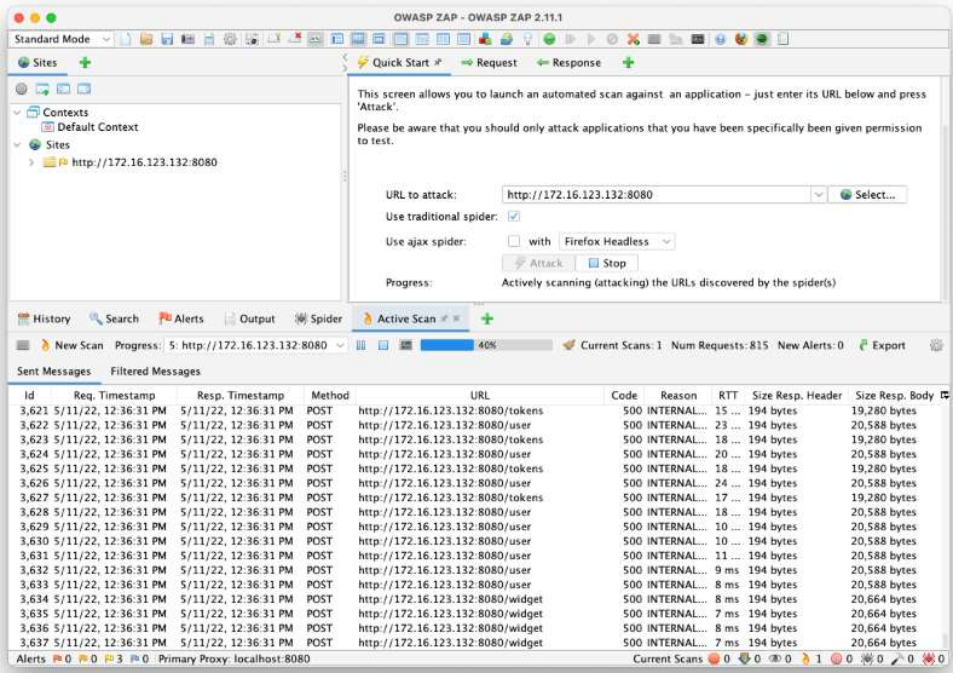
- Cuộc tấn công kết thúc nhanh chóng, chỉ hiển thị một phát hiện về tiêu đề bị thiếu—không quan trọng.
- Nhập định nghĩa OpenAPI: ZAP không tìm thấy các điểm cuối API, do đó không phát hiện được các lỗ hổng thú vị.
    - Trong ZAP, từ menu, nhấp vào "Import", chọn "Import an Open API definition from a URL". Nhập URL sau vào trường trên cùng:

```
https://github.com/jorritfolmer/vulnerable-api/raw/main/openapi/vAPI.yaml
```

    - Nhập URL API của bạn vào trường dưới cùng.

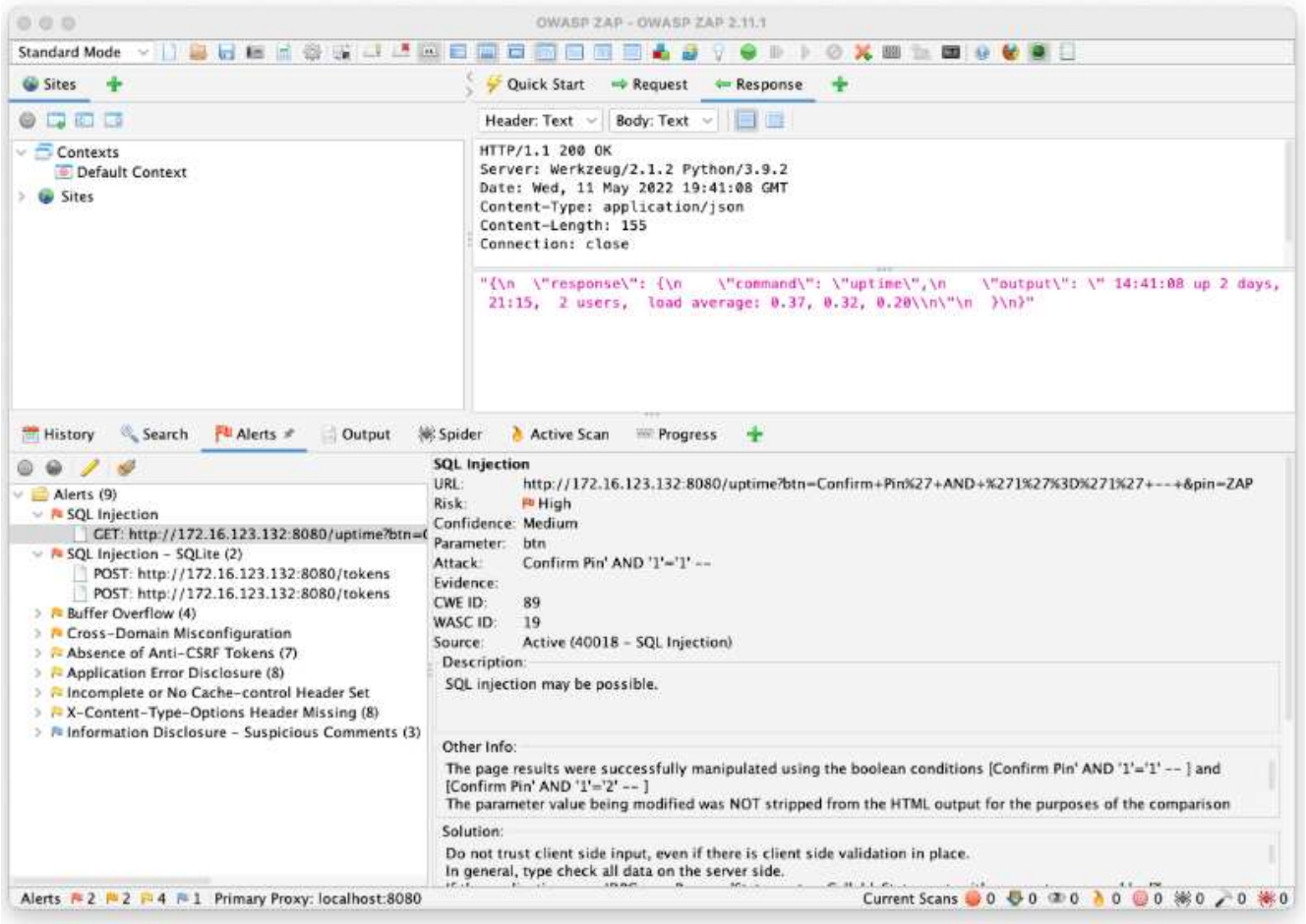


    - Nhấp vào "Import". Một hộp thoại xuất hiện thông báo "Successfully imported...". Nhấp "OK".
- Quét lại API:
    - Ở trên cùng, nhấp vào "Quick Start". Nhấp vào "Attack".
    - Cuộc tấn công mất một hoặc hai phút.

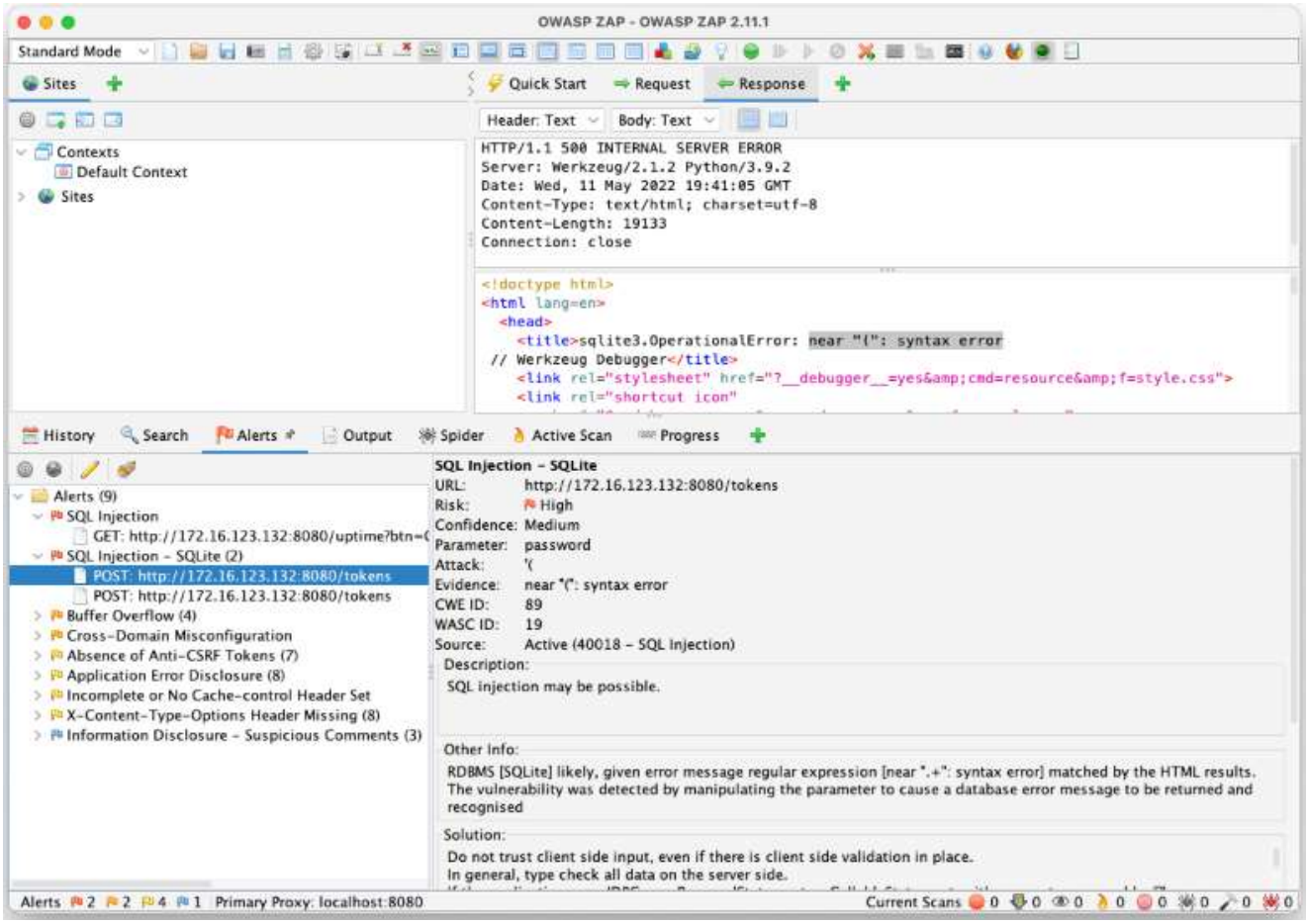


    - Bây giờ, phần "Alerts" hiển thị một số lỗ hổng SQL Injection.

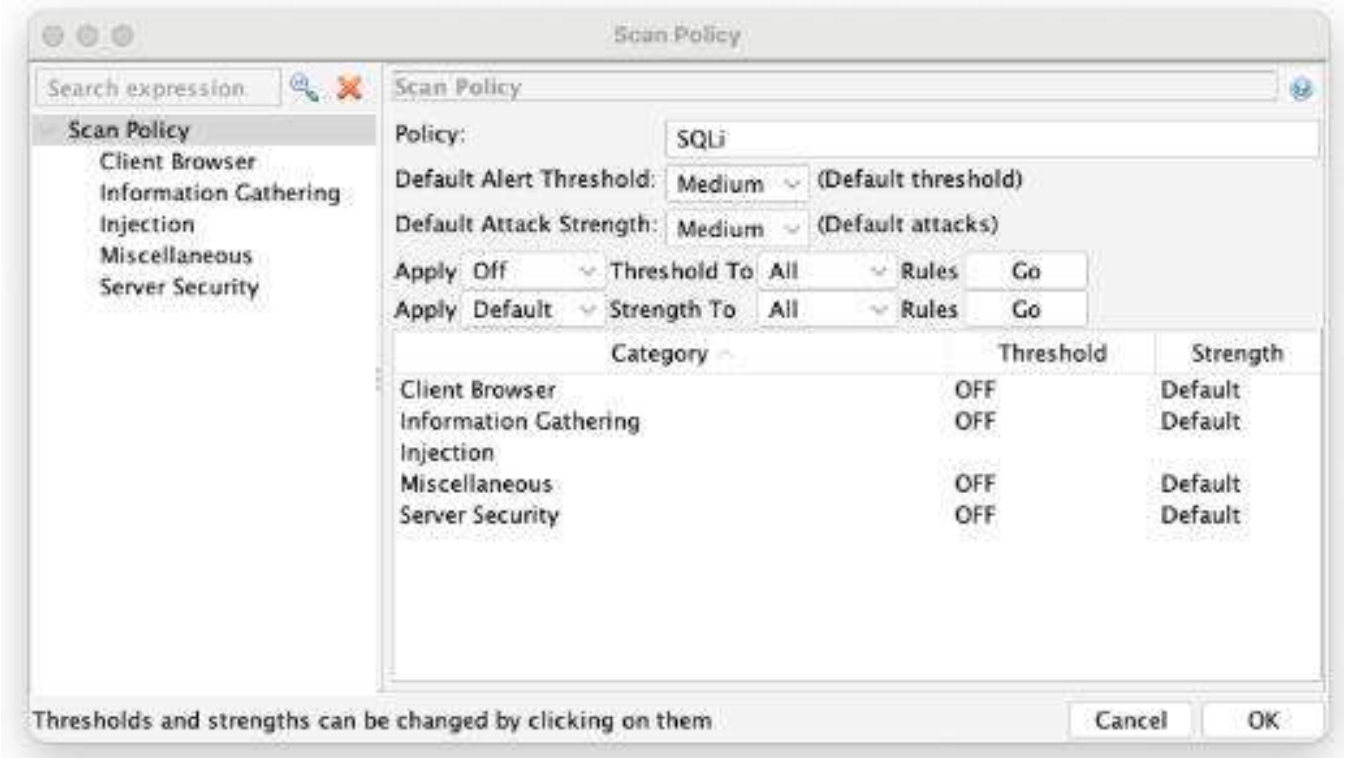
- Injection trong uptime:
  - Nhấp vào lỗ hổng SQL Injection đầu tiên.Ở khung trên bên phải, nhấp vào tab "Response".
  - Điều này cho thấy lệnh đã thực thi lệnh dòng lệnh Linux "uptime", gợi ý rằng có thể có lỗ hổng command injection.



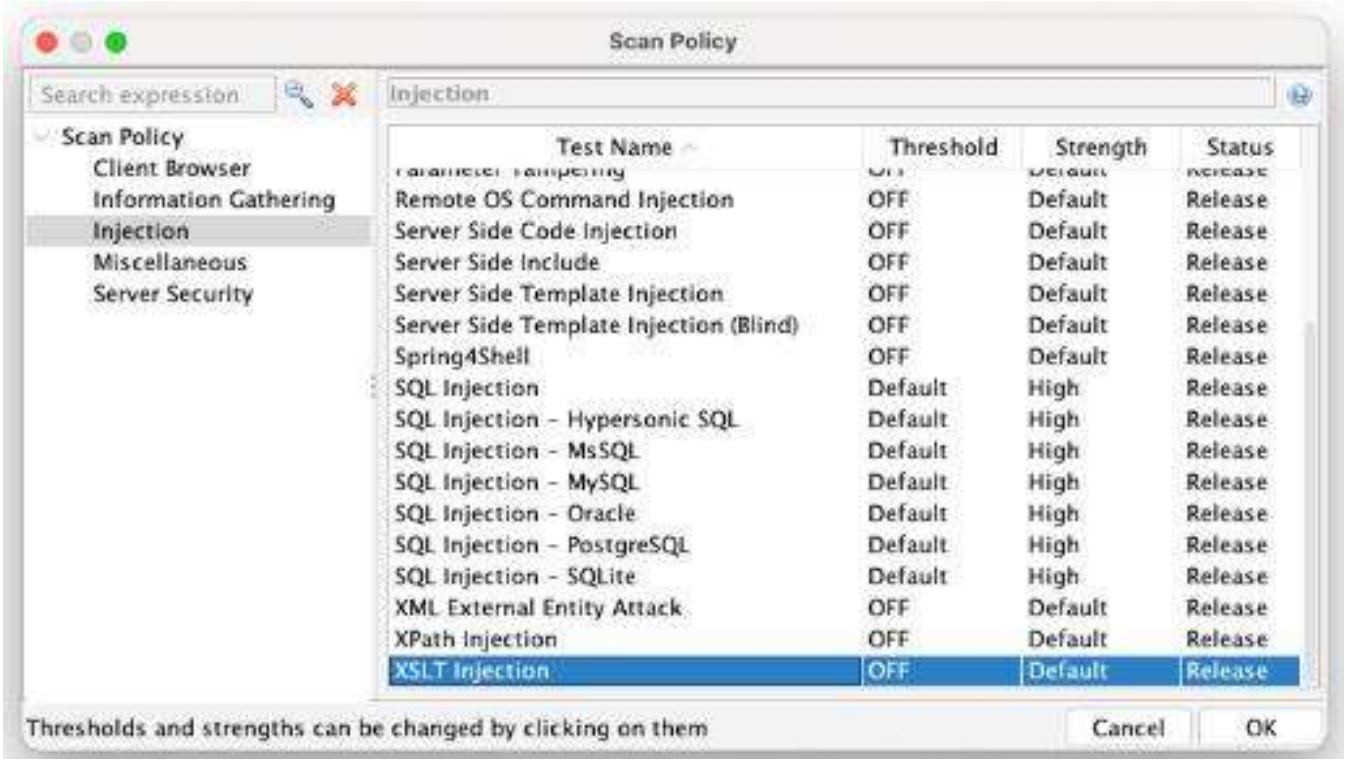
- SQL Injection trong tokens:
  - Nhấp vào lỗ hổng SQL Injection đầu tiên.
  - Điều này trông giống như một SQL injection cổ điển trong trường mật khẩu. Nhập một dấu nháy đơn ở đó dẫn đến lỗi "syntax error".



- Độ mạnh của Quét:
  - Khi sử dụng ZAP 2.15.0, nó không phát hiện được SQL injection.
  - Để khắc phục, thực hiện các bước sau:
    - Trong thanh menu của ZAP, nhấp vào "Analyze", chọn "Scan Policy Manager...".
    - Trong hộp "Scan Policy Manager", nhấp vào "Add".
    - Trong hộp "Scan Policy", ở góc trên bên phải, nhập tên chính sách là "SQLi".
    - Trong phần trên cùng bên phải, ở dòng đầu tiên bắt đầu bằng "Apply", thay đổi "Default" thành "Off" và nhấp vào nút "Go".



- Ở bên trái, nhấp vào "Injection".
- Ở bên phải, cuộn xuống phần kiểm tra "SQL Injection". Thay đổi mỗi cái thành Threshold là "Default" và Strength là "High".
- Ở góc dưới bên phải, nhấp vào "OK".



- Ở khung dưới, bên phải, nhấp vào tab "Active Scan".
- Nhấp vào "New Scan". Chọn chính sách "SQLi".
- Bây giờ, quá trình quét sẽ phát hiện các SQL injections.